CERTIFICATE POLICY & CERTIFICATION PRACTICE STATEMENT (CP/CPS) FOR S/MIME CERTIFICATES

17-Oct-2026
Version 1.01

S/MIME CP/CPS OID: 1.3.6.1.4.1.50977.1.0.1.3

© Copyright: eMudhra. All rights reserved.

emSign

info@emsign.com | www.emsign.com

Table of Contents

1 Introduction 12
1.1 Overview 12
1.2 Document Name and Identification 14
1.3 PKI Participants 16
1.3.1 Certification Authorities 16
1.3.2 Registration Authorities 17
1.3.2.1 Enterprise Registration Authorities 18
1.3.3 Subscribers 18
1.3.4 Relying Parties 19
1.3.5 Other Participants 20
1.3.5.1 emSign CERTInext Enterprise and Partner Accounts 20
1.4 Certificate Usage 20
1.4.1 Appropriate Certificate Uses 20
1.4.2 Prohibited Applications and Certificate Uses 21
1.5 Policy Administration 22
1.5.1 Organization Administering the Document 23
1.5.2 Contact Person 23
1.5.3 Certificate Problem Reporting 23
1.5.3.1 Email Contact 24
1.5.3.2 CERTInext Portal 24
1.5.3.3 Enterprise API / Partner Integrations 24
1.5.4 Person Determining CP/CPS Suitability for the Policy 24
1.5.5 CPS Approval Procedures 24
1.6 Definitions & Acronyms 25
1.6.1 Definitions 25
1.6.2 Acronyms 32
2 Publication and Repository Responsibilities 33
2.1 Repositories 33
2.2 Publication of Certificate Information 34
2.3 Time or Frequency of Publication 34
2.4 Access Controls on Repository 35
3 Identification and Authentication 35

3.1 Naming 35
3.1.1 Types of Names 35
3.1.2 Need for Names to be Meaningful 36
3.1.3 Anonymity or Pseudonymity of Subscribers 36
3.1.4 Rules for Interpreting Various Name Forms 36
3.1.5 Uniqueness of Names 37
3.1.6 Recognition, Authentication, and Role of Trademarks 37
3.2 Initial Identity Validation 37
3.2.1 Method to Prove Possession of Private Key 37
3.2.2 Validation of Mailbox Authorization or Control 38
3.2.3 Authentication of Organization Identity 39
3.2.4 Authentication of Individual Identity 40
3.2.5 Non-Verified Certificate Holder Information 42
3.2.6 Validation Of Authority 42
3.2.7 Criteria for interoperation 42
3.2.8 Reliability of Verification Sources 43
3.2.8.1 Evaluation of Verification Data Sources 43
3.3 Identification and authentication for re-key requests 43
3.3.1 Identification and Authentication for Routine Re-Key 44
3.3.2 Identification and Authentication for Re-Key After Revocation 45
3.4 Identification and Authentication for Revocation Requests 45
4 Certificate Life-Cycle Operation Requirements 46
4.1 Certificate Application 46
4.1.1 Who Can Submit a Certificate Application 46
4.1.2 Enrolment Process and Responsibilities 47
4.2 Certificate Application Processing 47
4.2.1 Performing Identification and Authentication Functions 47
4.2.2 Approval or Rejection Of Certificate Applications 48
4.2.3 Time to Process Certificate Applications 49
4.2.4 Certificate Authority Authorization (CAA) 49
4.2.5 Multi-Perspective Issuance Corroboration 50
4.2.6 Issuer Domain Names Recognised in DNS Validation Records 51
4.3 Certificate Issuance 51
4.3.1 Certification Authority Actions During Certificate Issuance 51

4.3.1.1 emSign Root Certification Authority 52
4.3.1.2 emSign Issuing Certification Authority Certificates 52
4.3.1.3 emSign PKI Registration Authority Appointment 52
4.3.1.4 Registration Authority Officer's Certificate 52
4.3.1.5 Certificate Holder Certificates 52
4.3.1.6 Issuance Safeguards 52
4.3.2 Notification to subscriber by the CA of issuance of certificate 53
4.4 Certificate Acceptance 53
4.4.1 Conduct Constituting Certificate Acceptance 53
4.4.2 Publication of the Certificate by the Certification Authority 53
4.4.3 Notification of Certificate Issuance by the Certification Authority to Other Entities 54
4.5 Key Pair And Certificate Usage 54
4.5.1 Subscriber Private Key and Certificate Usage 54
4.5.2 Relying Party Public Key and Certificate Usage 54
4.6 Certificate Renewal 55
4.6.1 Circumstances for Certificate Renewal 55
4.6.2 Who may request renewal 55
4.6.3 Processing Certificate Renewal Requests 56
4.6.4 Notification of new certificate issuance to subscriber 56
4.6.5 Conduct constituting acceptance of a renewal certificate 56
4.6.6 Publication of the Renewed Digital Certificate by Certification Authority 56
4.6.7 Notification of certificate issuance by the CA to other entities 56
4.7 Certificate Re-Key 56
4.7.1 Circumstance For Certificate Re-Key 56
4.7.2 Who may request certification of a new public key 57
4.7.3 Processing Certificate Re-Key Request 57
4.7.4 Notification of new certificate issuance to subscriber 57
4.7.5 Conduct constituting acceptance of a Re-Key Digital Certificate 57
4.7.6 Publication of the Re-Key Digital Certificate by Certification Authority 57
4.7.7 Notification of Re-Key Digital Certificate Issuance by the Certification Authority to other entities 57
4.8 Certificate Modification 58
4.8.1 Circumstance for certificate modification 58
4.8.2 Who may request certificate modification 58

4.8.3 Processing certificate modification requests 58
4.8.4 Notification of new certificate issuance to subscriber 58
4.8.5 Conduct constituting acceptance of modified certificate 58
4.8.6 Publication of the modified certificate by the CA 58
4.8.7 Notification of certificate issuance by the CA to other entities 58
4.9 Certificate Revocation and Suspension 58
4.9.1 Circumstances For Revocation 58
4.9.2 Who Can Request Revocation 61
4.9.3 Procedure For Revocation Request 61
4.9.4 Revocation Request Grace Period 62
4.9.5 Time within which CA must process the revocation request 62
4.9.6 Revocation Checking Requirement for Relying Parties 63
4.9.7 Certificate Revocation List Issuance Frequency 63
4.9.8 Maximum Latency for Certificate Revocation List publication 63
4.9.9 On-Line Revocation/Status Checking Availability 63
4.9.10 On-Line Revocation Checking Requirement 63
4.9.11 Other Forms of Revocation Advertisements Available 64
4.9.12 Special Requirements in Relation to Key Compromise 64
4.9.13 Circumstances For Suspension 65
4.9.14 Who Can Request Suspension 65
4.9.15 Procedure For Suspension Request 65
4.9.16 Limits On Suspension Period 65
4.10 Certificate Status Services 65
4.10.1 Operational Characteristics 65
4.10.2 Service Availability 65
4.10.3 Optional Features 65
4.11 End Of Subscription 65
4.12 Key escrow and recovery 66
4.12.1 Key escrow and recovery policy and practices 66
4.12.2 Session Key Encapsulation and Recovery Policy and Practices 67
5 Facility, Management, And Operational Controls 67
5.1 Physical Controls 67
5.1.1 Site Location and construction 67
5.1.2 Physical Access 67

5.1.3 Power and Air-Conditioning 68
5.1.4 Water Exposures 68
5.1.5 Fire Prevention and Protection 68
5.1.6 Media Storage 68
5.1.7 Waste Disposal 68
5.1.8 Off-Site Backup 68
5.2 Procedural Controls 69
5.2.1 Trusted Roles 69
5.2.2 Number of Persons Required Per Task 69
5.2.3 Identification and Authentication for Each Role 69
5.2.4 Roles Requiring Separation of Duties 70
5.3 Personnel Controls 70
5.3.1 Qualifications, Experience, and Clearance Requirements 70
5.3.2 Background Check Procedures 70
5.3.3 Training Requirements 71
5.3.4 Retraining Frequency and Requirements 71
5.3.5 Job Rotation Frequency and Sequence 71
5.3.6 Sanctions for Unauthorised Actions 71
5.3.7 Independent Contractor Requirements 71
5.3.8 Documentation Supplied to Personnel 72
5.4 Audit Logging Procedures 72
5.4.1 Types Of Events Recorded 72
5.4.2 Frequency Of Processing Log 73
5.4.3 Retention Period For Audit Log 73
5.4.4 Protection Of Audit Log 74
5.4.5 Audit Log Backup Procedures 74
5.4.6 Audit collection system (internal vs. external) 74
5.4.7 Notification To Event-Causing Subject 74
5.4.8 Vulnerability Assessment 74
5.5 Records Archival 75
5.5.1 Types Of Records Archived 75
5.5.2 Retention Period For Archive 75
5.5.3 Protection Of Archive 76
5.5.4 Archive Backup Procedures 76

5.5.5 Requirements For Time-Stamping Of Records 76
5.5.6 Archive collection system (internal or external) 76
5.5.7 Procedures To Obtain And Verify Archive Information 76
5.6 Key Changeover 76
5.7 Compromise And Disaster Recovery 77
5.7.1 Incident and compromise handling procedures 77
5.7.1.1 Mass Revocation Plan 77
5.7.2 Computing resources, software, and/or data are corrupted 78
5.7.3 Entity private key compromise procedures 78
5.7.4 Business continuity capabilities after a disaster 78
5.8 CA or RA termination 78
6 Technical Security Controls 79
6.1 Key Pair Generation and Installation 79
6.1.1 Key Pair Generation 79
6.1.2 Private Key Delivery to Certificate Holder 80
6.1.3 Public Key Delivery to Certificate Issuer 81
6.1.4 Certification Authority Public Key to Relying Parties 81
6.1.5 Key Sizes 81
6.1.6 Public Key Parameters Generation And Quality Checking 82
6.1.7 Key Usage Purposes (As Per X.509 V3 Key Usage Field) 82
6.2 Private Key Protection And Cryptographic Module Engineering Controls 83
6.2.1 Cryptographic Module Standards and Controls 83
6.2.2 Private key (n out of m) multi-person control 83
6.2.3 Private Key Escrow 84
6.2.4 Private Key Backup 84
6.2.5 Private key archival 84
6.2.6 Private Key Transfer into or from a Cryptographic Module 84
6.2.7 Private Key Storage on Cryptographic Module 84
6.2.8 Method Of Activating Private Key 84
6.2.9 Method Of Deactivating Private Key 85
6.2.10 Method Of Destroying Private Key 85
6.2.11 Cryptographic Module Rating 85
6.3 Other Aspects of Key Pair Management 85
6.3.1 Public Key Archival 85

6.3.2 Certificate Operational Periods and Key Pair Usage Periods 85
6.4 Activation Data 86
6.4.1 Activation Data Generation and Installation 86
6.4.2 Activation Data Protection 86
6.4.3 Other Aspects of Activation Data 86
6.5 Computer Security Controls 86
6.5.1 Specific computer security technical requirements 86
6.5.2 Computer Security Rating 87
6.6 Life Cycle Technical Controls 87
6.6.1 System Development Controls 87
6.6.2 Security Management Controls 88
6.6.3 Life Cycle Security Controls 88
6.7 Network Security Controls 88
6.7.1 Timeframe for Responding to and Remediating Vulnerabilities 88
6.8 Time-Stamping 89
7 Certificate, CRL, And OCSP Profiles 89
7.1 Certificate Profile 89
7.1.1 Version Number(s) 89
7.1.2 Certificate Extensions 89
7.1.2.1 Key Usage 90
7.1.2.2 Certificate Policies Extension 90
7.1.3 Algorithm Object Identifiers 91
7.1.4 Name Forms 91
7.1.5 Name constraints 93
7.1.6 Certificate policy object identifier 93
7.1.7 Usage of Policy Constraints extension 93
7.1.8 Policy qualifiers syntax and semantics 93
7.1.9 Processing semantics for the critical Certificate Policies extension 93
7.2 CRL Profile 93
7.2.1 Version Number(s) 93
7.2.2 CRL and CRL entry extensions 94
7.2.2.1 Fields in CRL 94
7.2.2.2 CRL Extensions 94
7.2.2.3 CRL Entries 94

7.3 OCSP Profile 94
7.3.1 Version Number(s) 94
7.3.2 OCSP Extensions 95
8 COMPLIANCE AUDIT AND OTHER ASSESSMENTS 95
8.1 Frequency or circumstances of assessment 95
8.2 Identity and Qualifications of Assessor 96
8.3 Assessor's Relationship to Assessed Entity 96
8.4 Topics Covered by Assessment 96
8.5 Actions Taken As a Result of Deficiency 96
8.6 Communication of results 97
8.7 Self Audits 97
8.8 Review of Delegated Parties 97
9 Other Business and Legal Matters 98
9.1 Fees 98
9.1.1 Certificate Issuance or Renewal Fees 98
9.1.2 Certificate Access Fees 98
9.1.3 Revocation or Status Information Access Fees 98
9.1.4 Fees for Other Services 98
9.1.5 Refund Policy 98
9.2 Financial Responsibilities 98
9.2.1 Insurance Cover 98
9.2.2 Other Assets 98
9.2.3 Insurance or warranty coverage for end-entities 98
9.2.4 Financial Records 99
9.2.5 No Partnership or Agency 99
9.3 Confidentiality of Business Information 99
9.3.1 Scope of Confidential Information 99
9.3.2 Information not Within the Scope of Confidential Information 99
9.3.3 Responsibility to Protect Private Information 99
9.4 Privacy of Personal Information 100
9.4.1 Privacy Plan 100
9.4.2 Information Treated as Private 100
9.4.3 Information not deemed private 100
9.4.4 Responsibility to Protect Private Information 100

9.4.5 Notice and Consent to Use Private Information 100
9.4.6 Disclosure pursuant to Judicial or Administrative Process 100
9.4.7 Other information disclosure circumstances 100
9.5 Intellectual Property Rights 101
9.6 Representations and Warranties 101
9.6.1 Certification Authority Representation and Warranties 101
9.6.2 RA representations and warranties 102
9.6.3 Subscriber Representation and Warranties 102
9.6.4 Relying Party Representation and Warranties 103
9.6.5 Representation and Warranties of Other Parties 104
9.7 Disclaimer of Warranties 104
9.8 Limitation of Liability 105
9.9 Indemnities 106
9.9.1 Indemnification by emSign PKI 106
9.9.2 Indemnification by Subscribers 106
9.9.3 Indemnification by Relying Parties 107
9.10 Term and Termination 107
9.10.1 Term 107
9.10.2 Termination 107
9.10.3 Effect of Termination and Survival 107
9.11 Individual Notices and Communications with Participants 108
9.12 Amendments 108
9.12.1 Procedure for Amendment 108
9.12.2 Notification Mechanism and Period 108
9.12.3 Circumstances under which OID must be changed 108
9.13 Dispute Resolution Procedures 108
9.14 Governing Law 108
9.15 Compliance with Applicable Law 109
9.16 Miscellaneous Provisions 109
9.16.1 Entire Agreement 109
9.16.2 Assignment 109
9.16.3 Severability 109
9.16.4 Enforcement (attorneys' fees and waiver of rights) 110
9.16.5 Force Majeure 110

9.17 Other Provisions 110
10 Appendix A: Verification Requirements for Subscriber 110
10.1 emSign Mailbox-Validated Strict SMIME Certificate 110
10.2 emSign Individual -Validated Strict SMIME Certificate 111
10.3 emSign Sponsor -Validated Strict SMIME Certificate 112
10.4 emSign Organization-Validated Strict SMIME Certificate 115
10.5 emSign Organization-Validated Multipurpose SMIME Certificate 116
10.6 emSign Sponsor -Validated Multipurpose SMIME Certificate 118
11 Appendix B: Certificate Profiles 121
11.1 Root Certificates 121
11.2 Subordinate CA Certificates (Issuer / Intermediate) 121
11.3 emSign Mailbox-Validated Strict SMIME Certificate 123
11.4 emSign Individual -Validated Strict SMIME Certificate 124
11.5 emSign Sponsor -Validated Strict SMIME Certificate 126
11.6 emSign Organization-Validated Strict SMIME Certificate 129
11.7 emSign Organization-Validated Multipurpose SMIME Certificate 131
11.8 emSign Sponsor -Validated Multipurpose SMIME Certificate 133
12 Appendix C: Change History 136

1 Introduction

eMudhra is a group, engaged in Digital Identity, Authentication and transaction management solutions globally. emSign PKI is part of eMudhra group, represented by eMudhra Inc., USA; CERTInext Inc., USA; eMudhra Limited, India; eMudhra Technologies Limited, India; eMudhra PTE Limited, Singapore; eMudhra DMCC, UAE; eMudhra BV, Netherlands; eMudhra Consumer Services Limited, India; P T eMudhra Technologies Indonesia, Indonesia; Cryptas International GmbH and its subsidiaries.

1.1 Overview

This emSign PKI (operating under the brand emSign) Certificate Policy and Certification Practice Statement (CP/CPS for S/MIME) sets forth the principles, procedures, and practices employed by emSign PKI for the issuance, lifecycle management, and oversight of publicly trusted S/MIME (Secure/Multipurpose Internet Mail Extensions) certificates within the emSign PKI hierarchy.

For the purposes of this CP/CPS, an S/MIME Certificate is a Certificate that contains the Extended Key Usage id-kp-emailProtection (OID 1.3.6.1.5.5.7.3.4) and includes an rfc822Name and/or an otherName of type id-on-SmtpUTF8Mailbox in the subjectAltName extension. Such Certificates bind a Public Key to a Mailbox Address and may additionally bind the identity of a Natural Person or Legal Entity that controls that Mailbox Address, so that the corresponding Key Pair may be used to sign, verify, encrypt and decrypt email.

In this document, the terms “emSign,” “emSign CA,” and “emSign PKI” are used interchangeably and refer collectively to all Root Certification Authorities, Issuing Certification Authorities, and affiliates of eMudhra Limited that operate under the emSign brand.

This CP/CPS governs the Root CA Certificates emSign Root SMIME CA - G1 and emSign Root SMIME CA - G3, every Subordinate CA Certificate issued under them, and every S/MIME Subscriber Certificate issued from those Subordinate CAs. With effect from its effective date it supersedes, for these Root CAs and their hierarchies, the general emSign PKI Certificate Policy and Certification Practice Statement that previously governed them. Other emSign Root CA hierarchies (including those dedicated to TLS server authentication, client authentication and time-stamping) are governed by their respective CP/CPS documents published in the emSign Repository and are outside the scope of this document. The Root CA Certificates in scope, with their SHA-256 fingerprints, are listed in the Repository and in the Common CA Database.

This CP/CPS is applicable to all entities having a defined relationship with the emSign PKI, including:

1. Policy Authorities,
2. Certification Authorities (CAs),
3. Registration Authorities (RAs),

4. Subscribers, and
5. Relying Parties.

Other parties, such as hosting providers, enterprise administrators, or technical integrators, may also perform functions related to certificate lifecycle management, such as issuance or revocation on behalf of Subscribers. In such cases, the principles, procedures, and practices contained in this document shall apply to such parties to the extent practicable, and they shall be held to the same compliance and liability standards as Subscribers, where applicable.

This CP/CPS specifies the principles, procedures, and practices that the emSign PKI follows to conform to the following standards, guidelines, and root program requirements:

1. RFC 3647 of the Internet Engineering Task Force (IETF):
    a. Framework for Certificate Policy and Certification Practice Statement structure.
2. The latest versions (as on date of this CP/CPS) of the CA/Browser Forum Requirements (Ref: https://cabforum.org):
    a. Baseline Requirements for the Issuance and Management of Publicly-Trusted S/MIME Certificates (S/MIME BR), version 1.0.15 or later
    b. Baseline Requirements for the Issuance and Management of Publicly-Trusted Certificates (TLS BR) – as referenced by S/MIME BR Sections 3.2.2.1, 3.2.2.3 and 4.2.2.2 for domain control validation and Multi-Perspective Issuance Corroboration only Network and Certificate System Security Requirements

    (Note: The CA/Browser Forum TLS Baseline Requirements and Code Signing Baseline Requirements are out of scope for this S/MIME CP/CPS, save for those TLS BR provisions expressly incorporated by the S/MIME BR as noted above)
3. WebTrust: Principles and Criteria for Certification Authorities, including:
    a. WebTrust: Principles and Criteria for Certification Authorities – Network Security
    b. WebTrust: Principles and Criteria for Certification Authorities – S/MIME Baseline Requirements
4. Adherence to the latest published version Root Program Requirements and CCADB policy of major relying party software providers:
    – Mozilla Root Store Policy
    – Apple Root Certificate Program
    – Microsoft Root Certificate Program

emSign conforms to the current version of the Baseline Requirements for the Issuance and Management of Publicly-Trusted S/MIME Certificates published at https://www.cabforum.org. In the event of any inconsistency between this document and those Requirements, those Requirements take precedence over this document. The same precedence applies to the other requirements listed above.

All certificates are issued containing the corresponding policy identifier(s) specified in section 1.2 indicating adherence to and conformance with these requirements.

This document is subject to regular review by the emSign Policy Authority, including a formal review at least every 365 days (Section 2.3). It may also be amended at any time to address changes in applicable requirements, law, technology or operational practice. No internal exception, waiver or deviation may authorise a practice that is inconsistent with the S/MIME Baseline Requirements, the requirements incorporated by them, or the policies of the Application Software Suppliers that distribute emSign Root CA Certificates; a conflict between those requirements and applicable law is handled exclusively under Section 9.16.3.

All cross-certificates that form part of an established trust relationship are disclosed by emSign PKI. This CP/CPS addresses the actions of emSign PKI in relation to such cross-certificates, including those issued by emSign PKI to third parties and those issued to emSign PKI by other Certification Authorities. However, this CP/CPS does not govern the operations of third-party CAs that issue such certificates; those parties remain subject to their own certificate policies and practice statements.

Certain Issuing CAs operating under the emSign PKI hierarchy may publish their own CP/CPS applicable to the certificates they issue. Where such a downstream CP/CPS specifies operational, validation, or certificate-lifecycle requirements that differ from those stated in this document, the downstream CP/CPS shall govern the issuance of certificates under that Issuing CA. In no event shall any such downstream CP/CPS permit practices less stringent than those required by the CA/Browser Forum Baseline Requirements or other applicable industry standards referenced in this CP/CPS.

1.2 Document Name and Identification

The OID for emSign PKI is an iso (1) identified-organization (3) dod (6) internet (1) private (4) enterprise (1) eMudhra Technologies Limited (50977) emSign PKI (1).

This document is the emSign PKI Certificate Policy and Certification Practice Statement (CP/CPS) for S/MIME. The object identifier (OID) values corresponding to the emSign S/MIME CP/CPS are as follows:

Entity / Certificate Policy	OID
Organization	1.3.6.1.4.1.50977
emSign PKI	1.3.6.1.4.1.50977.1
emSign CP/CPS	1.3.6.1.4.1.50977.1.0.1
emSign S/MIME CP/CPS	1.3.6.1.4.1.50977.1.0.1.3

Type of certificate

The OID for Certificate Policies under emSign PKI is an iso (1) identified-organization (3) dod (6) internet (1) private (4) enterprise (1) eMudhra Technologies Limited (50977) emSign PKI (1) Certificate Type (2).

emSign PKI organizes its OID arcs for the various Certificates described in this CP/CPS as follows:

Type of Certificate	Policy OID
OCSP Certificate	1.3.6.1.4.1.50977.1.2.600
S/MIME – Mailbox-validated Multipurpose	2.23.140.1.5.1.2, 1.3.6.1.4.1.50977.1.2.460.1.2
S/MIME – Mailbox-validated Strict	2.23.140.1.5.1.3, 1.3.6.1.4.1.50977.1.2.460.1.3
S/MIME – Organization-validated Multipurpose	2.23.140.1.5.2.2, 1.3.6.1.4.1.50977.1.2.460.3.2
S/MIME – Organization-validated Strict	2.23.140.1.5.2.3, 1.3.6.1.4.1.50977.1.2.460.3.3
S/MIME – Sponsor-validated Multipurpose	2.23.140.1.5.3.2, 1.3.6.1.4.1.50977.1.2.460.4.2
S/MIME – Sponsor-validated Strict	2.23.140.1.5.3.3, 1.3.6.1.4.1.50977.1.2.460.4.3
S/MIME – Individual-validated Multipurpose	2.23.140.1.5.4.2, 1.3.6.1.4.1.50977.1.2.460.2.2
S/MIME – Individual-validated Strict	2.23.140.1.5.4.3, 1.3.6.1.4.1.50977.1.2.460.2.3

This CP/CPS applies to any entity asserting one or more of the emSign OIDs identified above. When a CA issues a Certificate containing one of the above-specified policy identifiers, it asserts that the Certificate was issued and is managed in accordance with the requirements applicable to that respective policy.

Subsequent revisions to this CP might contain new OID assignments for the certificate types identified above, or may be amended with new Certificate Types with corresponding new OIDs.

The S/MIME BR defines four Certificate Types, distinguished by the Subject attributes they carry – Mailbox-validated, Organization-validated, Sponsor-validated and Individual-validated – and three Generations for each Type (Legacy, Multipurpose and Strict).

In accordance with S/MIME BR Section 7.1.6.1, emSign SHALL NOT issue S/MIME Subscriber Certificates asserting any Legacy Generation policy identifier (2.23.140.1.5.1.1, 2.23.140.1.5.2.1, 2.23.140.1.5.3.1 or 2.23.140.1.5.4.1). The Legacy Generation was sunset on 15 July 2025 and is not offered by emSign.

Each S/MIME Subscriber Certificate issued by emSign contains exactly one of the reserved CA/Browser Forum policy identifiers listed above, together with the corresponding emSign arc OID and a CPS pointer to https://repository.emsign.com.

1.3 PKI Participants

1.3.1 Certification Authorities

The term Certification Authority (CA) is a trusted third-party entity that issues Certificates and performs all of the functions associated with issuing such Certificates under this CP/CPS. emSign PKI performs the below functions:

1. Perform tasks related to Public Key Infrastructure (PKI) functions, such as:
    a. Certificate lifecycle management
    b. Subscriber registration
    c. Certificate issuance
    d. Certificate renewal and/or rekeying
    e. Certificate distribution (if applicable)
    f. Certificate revocation
2. Provide Certificate revocation information in the form of a Certificate Revocation List (CRL) distribution point and/or Online Certificate Status Protocol (OCSP) responder.

emSign PKI operates secure facilities in order to deliver CA services by itself and/or through infrastructure, personnel and other resources of eMudhra.

The emSign PKI also issues certificates to issuing CAs and subordinate CAs. All such issuing CAs and subordinate CAs are required to operate in conformance with this CP/CPS.

Obligations of the CAs within the emSign PKI include:

- Generating, issuing and distributing public key certificates.
- Distributing CA certificates.
- Generating and publishing certificate status information (such as CRLs).
- Maintaining the security, availability, and continuity of the certificate issuance and CRL signing functions.
- Providing a means for Subscribers to request revocation.
- Revoking public-key certificates.
- Periodically demonstrating internal or external audited compliance with this CP/CPS and with the CA/B Forum S/MIME Baseline Requirements.

As at the date of this CP/CPS all Issuing Certification Authorities (Issuing CAs) under the emSign S/MIME Roots are operated by emSign or an Affiliate of emSign. Should emSign issue a Subordinate CA Certificate to a non-Affiliate, the additional controls of Sections 6.1.1, 7.1.2.2 and 8.4 apply. Issuing CAs are required to act in accordance with their respective Issuing CA Agreements and are bound by the terms of this CP/CPS and applicable industry requirements. Limited functions such as identity validation may be delegated under formal agreements. Issuing CAs may be authorized to issue and manage S/MIME

certificate as defined in this CP/CPS. All operations are subject to emSign PKI oversight and compliance obligations.

Issuing CAs, if authorized by emSign PKI, may utilize third-party Registration Authorities (RAs) to perform Subscriber identity validation and the other functions that Section 1.3.2 permits to be delegated, in accordance with this CP/CPS. Verification of mailbox authorization or control (Section 3.2.2) is never delegated to an RA; CAA processing and Multi-Perspective Issuance Corroboration are performed by emSign or by parties acting under emSign's control within the scope of emSign's audit (Section 1.3.2). The Issuing CA remains fully responsible and liable for all validation activities performed by such RAs. All thirdparty RAs must operate under formal agreements, follow applicable industry requirements, and remain under the oversight of emSign PKI.

1.3.2 Registration Authorities

A Registration Authority (RA) is an entity that performs identification and authentication of certificate applicants, initiates or forwards revocation requests, and approves applications for renewal or rekeying of certificates on behalf of emSign CA.

The requirements in this S/MIME CP/CPS apply to all RAs. emSign CA may also act as an RA for certificates it issues.

emSign PKI may enter into contractual relationships with authorized entities to operate as Registration Authorities, provided they act under the oversight of emSign PKI and comply with this CP/CPS. Such RAs must follow all applicable industry requirements and the terms of their agreements. RAs may implement more restrictive validation practices internally but must not deviate from the baseline requirements set in this CP/CPS.

- Obligations of Registration Authorities within the emSign PKI include: Process digital certificate application requests
- Identifying and authenticating Subscribers in accordance with this CP/CPS
- emSign does not delegate the verification of mailbox authorization or control (Section 3.2.2) to any Registration Authority, Enterprise RA or other Delegated Third Party. The supporting infrastructure used for CAA processing (Section 4.2.4) and Multi-Perspective Issuance Corroboration (Section 4.2.5) may be operated by emSign or by parties acting under emSign's control, in every case within the scope of emSign's audit. Other parts of Section 3.2 may be delegated only where the process as a whole fulfils all requirements of Section 3.2 and the Delegated Third Party is contractually required to (1) meet the qualification requirements of Section 5.3.1 where applicable to the delegated function, (2) retain documentation in accordance with Section 5.5.2, (3) abide by the other provisions of the S/MIME Baseline Requirements applicable to the delegated function, and (4) comply with this CP/CPS or with a practice statement that emSign has verified complies with the S/MIME Baseline Requirements. Delegated Third Parties that are not Enterprise RAs are audited as described in Section 8.4.
- Maintain and process all supporting documentation related to certificate application

- Receiving, authenticating and processing certificate revocation requests
- Providing suitable training to personnel performing RA functions.
- Complying with CP/CPS and emSign/Issuer CA Registration Authority Agreement

emSign also can act as a RA for the certificates it directly issues.

1.3.2.1 Enterprise Registration Authorities

emSign may delegate to an Enterprise RA the verification of Certificate Requests for Subjects within the Enterprise RA's own Organization. emSign accepts a Certificate Request authorised by an Enterprise RA only where: (1) for Mailbox-validated, Organization-validated and Sponsor-validated requests, emSign has itself confirmed the Enterprise RA's authorization or control of the requested email domain(s) in accordance with Section 3.2.2(a) or 3.2.2(c); and (2) emSign has confirmed that subject:organizationName is the name of the delegated enterprise, of an Affiliate of the delegated enterprise, or of a Legal Entity for which the delegated enterprise is an agent. For example, emSign does not issue a Certificate naming "XYZ Co." on the authority of Enterprise RA "ABC Co." unless the two are Affiliated or ABC Co. is the agent of XYZ Co., regardless of whether the email domain falls within ABC Co.'s Registered Domain Name.

An Enterprise RA may also submit Certificate Requests using the Mailbox-validated profile for users whose email domain(s) are not under the delegated Organization's authorization or control; in that case emSign confirms that the mailbox holder controls the requested Mailbox Address(es) in accordance with Section 3.2.2(b) or 3.2.2(d).

These limitations are imposed on every Enterprise RA as a contractual requirement, and emSign monitors each Enterprise RA's compliance with them at least annually in accordance with Section 8.8. Records maintained by an Enterprise RA are accepted as evidence of Individual identity for Sponsor-validated Certificates only under Section 3.2.4(5).

1.3.3 Subscribers

Subscribers include all end users consisting of natural persons and/or legal entities that successfully apply for the certificate and receive it. Prior to verification of identity and issuance of a Certificate, a Subscriber is an Applicant.

A Subscriber, as used herein, refers to both the Subject of the Certificate and the entity that applied for the certificate or contracted with the Issuing CA for the Certificate issuance.

Technically, CAs are also subscribers of emSign certificates either as a CA issuing a self-signed Certificate to itself (Root CA), or as a CA being issued a Certificate by a superior CA (Issuing CA / Subordinate CA).

References to “end entities” and “subscribers” in this CP/CPS, however, apply only to end-user Subscribers.

Obligations of Subscribers within the emSign PKI include:

- Generating or causing to be generated one or more asymmetric key pairs

- Submitting public keys and credentials for registration
- Providing information to the RA that is accurate and complete to the best of the Subscribers' knowledge and belief regarding information in their certificates and identification and authentication information
- Taking appropriate measures to protect their private keys from compromise
- Promptly reporting loss or compromise of private key(s) and inaccuracy of certificate information to Issuing CA / RA
- At all times utilize the Digital Certificate in accordance with all applicable laws and regulations.
- Use the signing Key Pairs for electronic signatures in accordance with the Digital Certificate profile and any other limitations known, or which ought to be known, to the Certificate Holder.
- Discontinue the use of the digital signature Key Pair in the event that emSign/Issuing CA notifies the Certificate Holder that the emSign/Issuing CA has been compromised.
- Using its key pair(s) in compliance with this CP/CPS.
- Any other terms as per Subscriber Agreement

When using automated mechanisms such as ACME clients, emSign CERTInext, or emSign APIs for requesting, renewing, or revoking certificates, the Subscriber remains fully responsible for secure key management and adherence to the requirements of this CP/CPS. The use of such automation does not waive or reduce the Subscriber's obligations regarding identity accuracy, private key protection, or timely revocation reporting.

1.3.4 Relying Parties

A Relying Party is an individual or entity that acts in reliance of an S/MIME certificate issued by an emSign CA. A Relying Party may or may not be a Subscriber of emSign certificates.

While relying on or using a Certificate of emSign PKI, Relying Parties are required to examine the CP/CPS and make their own judgement, and also examine the certificate in repository for expiry or revocation, etc.

Obligations of Relying Parties within the emSign PKI include:

- Confirming the validity of Subscriber public-key certificates.
- Confirming the revocation status of the certificate through CRL / OCSP.
- Verifying that Subscriber possesses the asymmetric private key corresponding to the publickey certificate (e.g., through digital signature verification).
- Confirming that the subscriber uses the public-key in the Subscriber's certificate in compliance with this S/MIME CP/CPS.
- Any other terms as per Relying Party Agreement.

All obligations within this section relate to Reasonable Reliance on the validity of a Digital Signature, not the accuracy of the underlying electronic record. A Relying Party must exercise Reasonable Reliance as set

out in this section. This CP/CPS does not require a Certificate Holder to ensure that potential relying parties are compliant with the relying party obligations.

1.3.5 Other Participants

Other participants may include bridge CAs and CAs that cross-certify Issuing CAs to provide trust among other PKI communities.

emSign Roots and Subordinate CAs shall not cross-certify or bridge any third-party CA where such third-party CA would derive S/MIME issuing capabilities under the emSign PKI hierarchy.

1.3.5.1 emSign CERTInext Enterprise and Partner Accounts

Participants within the emSign PKI ecosystem may include authorized entities using the emSign CERTInext platform, such as Enterprise account holders and Partners. These participants may initiate or manage certificate requests through web portals or APIs for their own organizational needs or on behalf of end-user Subscribers. All such activities are performed under emSign's control, and these entities do not operate as Certification Authorities (CAs) and act as Registration Authorities only where appointed as an Enterprise RA under Section 1.3.2.1.

Enterprise account holders may streamline certificate lifecycle actions (including request, renewal, and revocation) within the boundaries of pre-approved identity and domain validations. Partners are permitted to request certificates for their clients subject to prior authorization and must comply with all applicable agreements and this CP/CPS. emSign PKI retains full responsibility for validation, issuance, and auditability of these interactions.

1.4 Certificate Usage

A digital certificate enables individuals or entities to prove their identity in electronic transactions to other participants in such transactions.

1.4.1 Appropriate Certificate Uses

Certificates issued under this CP/CPS are intended solely for the protection of electronic mail using S/MIME, as indicated by the Extended Key Usage id-kp-emailProtection (OID 1.3.6.1.5.5.7.3.4) and the Key Usage extension included in the Certificate.

These Certificates enable a Subscriber to digitally sign and/or encrypt email messages, and enable a Relying Party to verify the signature on, and to encrypt email to, the holder of the Mailbox Address named in the Certificate. Subscribers are responsible for selecting the Certificate Type and Generation appropriate to the assurance level required for their environment.

emSign issues the following S/MIME certificate profiles:

- Mailbox-validated Certificates: the Subject is limited to the Mailbox Address (and optionally subject:commonName and subject:serialNumber). Only control of the Mailbox Address is verified; no organizational or individual identity is asserted.
- Organization-validated Certificates: the Subject contains verified Legal Entity attributes only, including subject:organizationName and subject:organizationIdentifier validated under Section 3.2.3.
- Sponsor-validated Certificates: the Subject combines verified Natural Person attributes with the subject:organizationName of an associated Legal Entity. Registration may be performed by an Enterprise RA.
- Individual-validated Certificates: the Subject contains verified Natural Person attributes only, validated under Section 3.2.4.

emSign offers each of the four Certificate Types in the Strict and Multipurpose Generations. Mailbox-validated and Individual-validated Multipurpose Generation Certificates are not currently issued, and their certificate profiles will be added to Appendix B before issuance begins. The Legacy Generation is not issued (S/MIME BR Section 7.1.6.1).

A single Certificate may contain more than one Mailbox Address, provided that control of every Mailbox Address has been verified under Section 3.2.2 and every Mailbox Address appearing in the subject field or in a directoryName entry is repeated as an rfc822Name or id-on-SmtpUTF8Mailbox value in the subjectAltName extension.

The Subscriber must ensure that each certificate is used solely for its intended purpose and in accordance with this CP/CPS, applicable agreements, and published certificate profiles.

This section defines the intended technical usage of certificates as governed by their certificate profile and extensions. It does not constitute a representation or guarantee of fitness for a particular purpose. Assurance levels vary based on certificate type and are subject to applicable validation procedures and the Subscriber Agreement.

1.4.2 Prohibited Applications and Certificate Uses

emSign certificates shall not be used for any purpose that is inconsistent with their stated Key Usage or Extended Key Usage (EKU) extensions or outside the scope defined in this CP/CPS and associated certificate profile.

Prohibited uses include, but are not limited to, the following:

1. Use inconsistent with certificate extensions: Any use of the certificate that exceeds the technical purposes indicated by the Key Usage or Extended Key Usage extensions (e.g., using an S/MIME certificate for TLS server authentication, code signing or time-stamping). The values id-kp-serverAuth, id-kp-codeSigning, id-kp-timeStamping and anyExtendedKeyUsage are never present in Certificates issued under this CP/CPS.

2. Exceeding reliance limits: Any use that exceeds the designated reliance limits as specified in the emSign Warranty or Subscriber Agreement.
3. Use in high-risk environments: Use of certificates for control or operation of systems where failure could result in death, personal injury, or severe environmental harm, including but not limited to:
   - Nuclear facilities
   - Aircraft navigation or communication systems
   - Life support or medical devices
   - Critical infrastructure or fail-safe systems
4. Use in unlawful or harmful activities: Use of certificates in connection with or to facilitate illegal or harmful conduct, including but not limited to:
   - Fraud
   - Pornography or child sexual abuse material (CSAM)
   - Obscenity
   - Defamation or harassment
   - Hate speech
   - Any activity contrary to public policy or applicable law

   Unauthorised interception or impersonation: use of a Certificate to sign, decrypt or intercept email for a Mailbox Address not legitimately controlled by the Subscriber, or to impersonate any other Natural Person or Legal Entity, is strictly prohibited.
5. Certificate misuse by role:
   - End-entity certificates must not be used to issue other certificates or act as a Certification Authority (CA).
   - CA certificates must not be used to perform end-entity functions, such as document signing or server authentication.
6. Violation of laws or regulations: Use of certificates must comply with all applicable laws, statutes, regulations, court orders, and governmental mandates.

emSign certificates do not guarantee that the Subject is reputable, trustworthy, or operating a secure system, nor do they imply that the device or software where the certificate is installed is free from defect, malware, or vulnerabilities.

The Key Usage and Extended Key Usage extensions are intended to technically enforce permitted usage. All Subscribers and relying parties must ensure that certificates are only used for the designated purposes, consistent with applicable agreements and this CP/CPS.

1.5 Policy Administration

These emSign PKI policies are administered by emSign Policy Authority.

Obligations of the emSign PKI Policy Authority include:

- Approving and maintaining this CP/CPS.
- Interpreting adherence to this CP/CPS.
- Specifying the content of public-key certificates.
- Resolving or causing resolution of disputes related to this CP/CPS.
- Remaining current regarding security threats and ensuring that appropriate actions are taken to counteract significant threats.

1.5.1 Organization Administering the Document

emSign PKI Policy Authority can be contacted at the following address:

emSign PKI Policy Authority
eMudhra Technologies Limited (eMudhra Group Company)
12-P1-A & 12-P1-B, Hi-Tech Defence and Aerospace Park (IT sector),
Jala Hobli, B.K. Palya,
Bangalore - 562149, Karnataka, India
Phone: +91 80 48484090
Email: info@emsign.com
Website: www.emsign.com

1.5.2 Contact Person

emSign PKI Policy Director can be contacted at the following address:

Attn: Policy Director
emSign PKI Policy Authority
eMudhra Technologies Limited (eMudhra Group Company)
12-P1-A & 12-P1-B, Hi-Tech Defence and Aerospace Park (IT sector),
Jala Hobli, B.K. Palya
Bangalore - 562149, Karnataka, India
Phone: +91 80 48484090
Email: info@emsign.com
Website: www.emsign.com

Certificate Problem Reports and revocation requests: instructions for reporting suspected Private Key Compromise, Certificate misuse or other fraud, and for requesting revocation, are given in Section 1.5.3 (email: problem-reporting@emsign.com) and Section 4.9.12.

1.5.3 Certificate Problem Reporting

To report problems with a certificate issued by emSign or request revocation, parties may contact emSign or use one of the supported automated mechanisms.

1.5.3.1 Email Contact

Certificate-related issues such as key compromise, certificate misuse, or suspected fraudulent issuance may be reported via email:

Attn: Revocation Support
Email: problem-reporting@emsign.com

1.5.3.2 CERTInext Portal

Subscribers, partners, and authorized users may initiate certificate revocation requests through the emSign CERTInext Portal using the certificate management dashboard that is available via Login using:

URL: https://www.emsign.com

1.5.3.3 Enterprise API / Partner Integrations

Enterprise customers and authorized partners integrated with emSign via secure APIs may submit certificate revocation requests programmatically. API access must be pre-authorized and authenticated in accordance with the emSign API Specifications.

emSign authenticates all revocation requests based on the requester's identity and relationship to the certificate. Requests submitted through trusted channels by Subscribers or Subject Organizations are verified using registered credentials or account-based validation. Requests from third parties may undergo additional investigation or corroboration prior to revocation. All revocation requests and corresponding actions are logged and processed in accordance with this CP/CPS.

1.5.4 Person Determining CP/CPS Suitability for the Policy

The CP/CPS suitability for the functions and uses of participants is decided by the Policy Authority of emSign PKI. The Policy Authority consists of representatives from executive management, PKI operations and legal.

1.5.5 CPS Approval Procedures

The CP/CPS shall be reviewed and updated by emSign at least annually, or more frequently as needed to reflect changes in applicable standards, policies, or operational practices. All changes are subject to approval by the emSign Policy Authority. Updates may be initiated in response to new or revised CA/Browser Forum Baseline Requirements, root store policies, or other compliance obligations that require corresponding modifications to the CP or CPS.

1.6 Definitions & Acronyms

1.6.1 Definitions

Affiliate: A corporation, partnership, joint venture or other entity controlling, controlled by, or under common control with another entity, or an agency, department, political subdivision, or any entity operating under the direct control of a Government Entity.

Applicant Representative: A natural person or human sponsor who is either the Applicant, employed by the Applicant, or an authorized agent who has express authority to represent the Applicant: (i) who signs and submits, or approves a certificate request on behalf of the Applicant; and/or (ii) who signs and submits a Subscriber Agreement on behalf of the Applicant; and/or (iii) who acknowledges the Terms of Use on behalf of the Applicant when the Applicant is an Affiliate of the CA or is the CA.

Applicant: The natural person or Legal Entity that applies for (or seeks renewal of) a Certificate. Once the Certificate issues, the Applicant is referred to as the Subscriber. For Certificates issued to devices, the Applicant is the entity that controls or operates the device named in the Certificate, even if the device is sending the actual certificate request.

Application Software Supplier: A supplier of Internet browser software or other relying-party application software that displays or uses Certificates and incorporates Root Certificates.

Attestation Letter: A letter attesting that Subject Information is correct written by an accountant, lawyer, government official, or other reliable third party customarily relied upon for such information.

Audit Period: In a period-of-time audit, the period between the first day (start) and the last day of operations (end) covered by the auditors in their engagement. (This is not the same as the period of time when the auditors are on-site at the CA.) The coverage rules and maximum length of audit periods are defined in this CP/CPS.

Audit Report: A report from a Qualified Auditor stating the Qualified Auditor's opinion on whether an entity's processes and controls comply with the mandatory provisions of these Requirements.

Authorization Domain Name: The Domain Name used to obtain authorization for certificate issuance for a given FQDN. The CA may use the FQDN returned from a DNS CNAME lookup as the FQDN for the purposes of domain validation. If the FQDN contains a wildcard character, then the CA MUST remove all wildcard labels from the left most portion of requested FQDN. The CA may prune zero or more labels from left to right until encountering a Base Domain Name and may use any one of the intermediate values for the purpose of domain validation. (TLS Baseline Requirements term, used in this CP/CPS solely for the methods in Section 3.2.2(e).)

Base Domain Name: The portion of an applied for FQDN that is the first domain name node left of a registry controlled or public suffix plus the registry controlled or public suffix (e.g. "example.co.uk" or "example.com"). For FQDNs where the right most domain name node is a gTLD having ICANN Specification 13 in its registry agreement, the gTLD itself may be used as the Base Domain Name. (TLS Baseline

Requirements term, used in this CP/CPS only within the definition of Authorization Domain Name for Section 3.2.2(e).)

Baseline Requirements (BR) / S/MIME BR: The CA/Browser Forum Baseline Requirements for the Issuance and Management of Publicly-Trusted S/MIME Certificates, published at https://www.cabforum.org. References in this CP/CPS to 'the Baseline Requirements' or 'BR' without qualification mean the S/MIME BR.

TLS Baseline Requirements (TLS BR): The CA/Browser Forum Baseline Requirements for the Issuance and Management of Publicly-Trusted TLS Server Certificates, referenced by this CP/CPS only for the domain validation methods of its Section 3.2.2.4 and the Multi-Perspective Issuance Corroboration requirements of its Section 3.2.2.9.

Basic Constraints: Means an extension that specifies whether the subject of the Certificate may act as a CA or only as an end-entity

CA Key Pair: A Key Pair where the Public Key appears as the Subject Public Key Info in one or more Root CA Certificate(s) and/or Subordinate CA Certificate(s)

CAA: The Certification Authority Authorization (CAA) DNS Resource Record allows a DNS domain name holder to specify the Certification Authorities (CAs) authorized to issue certificates for that domain.

Publication of CAA Resource Records allows a public Certification Authority to implement additional controls to reduce the risk of unintended certificate misuse.

Certificate Data: Certificate requests and data related thereto (whether obtained from the Applicant or otherwise) in the CA's possession or control or to which the CA has access.

Certificate Management Process: Processes, practices, and procedures associated with the use of keys, software, and hardware, by which the CA verifies Certificate Data, issues Certificates, maintains a Repository, and revokes Certificates.

Certificate Policy: A set of rules that indicates the applicability of a named Certificate to a particular community and/or PKI implementation with common security requirements.

Certificate Problem Report: Complaint of suspected Key Compromise, Certificate misuse, or other types of fraud, compromise, misuse, or inappropriate conduct related to Certificates.

Certificate Profile: A set of documents or files that defines requirements for Certificate content and Certificate extensions in accordance with Section 7, e.g. a Section in a CA's CPS or a certificate template file used by CA software.

Certificate Revocation List: A regularly updated time-stamped list of revoked Certificates that is created and digitally signed by the CA that issued the Certificates.

Certificate System: Means the system used by emSign or a delegated third party in providing identity verification, registration and enrollment, Certificate approval, issuance, validity status, support, and other PKI-related services

Certificate: An electronic document that uses a digital signature to bind a public key and an identity.

Certification Authority Authorization (CAA): Means a DNS domain holder specify one or more CAs authorized to issue certificates for that domain name. For S/MIME Certificates, CAA is processed using the issuemail property tag described in RFC 9495, which extends RFC 8659

Certification Authority: An organization that is responsible for the creation, issuance, revocation, and management of Certificates. The term applies equally to both Roots CAs and Subordinate CAs.

Certification Practice Statement: One of several documents forming the governance framework in which Certificates are created, issued, managed, and used.

Common Criteria: Is a framework in which computer system users can specify their security functional and assurance requirements (SFRs and SARs respectively) in a Security Target (ST), and may be taken from Protection Profiles (PPs). It is an international standard (ISO/IEC 15408) for computer security certification

Control: "Control" (and its correlative meanings, "controlled by" and "under common control with") means possession, directly or indirectly, of the power to: (1) direct the management, personnel, finances, or plans of such entity; (2) control the election of a majority of the directors; or (3) vote that portion of voting shares required for "control" under the law of the entity's Jurisdiction of Incorporation or Registration but in no case less than 10%.

Country: Either a member of the United Nations OR a geographic region recognized as a Sovereign State by at least two UN member nations.

Critical Vulnerability: A system vulnerability that has a CVSS v2.0 score of 7.0 or higher according to the NVD or an equivalent to such CVSS rating (see http://nvd.nist.gov/home.cfm https://nvd.nist.gov/vuln-metrics/cvss), or as otherwise designated as a Critical Vulnerability by the CA or the CA/Browser Forum

Cross Certificate: A certificate that is used to establish a trust relationship between two Root CAs.

CSPRNG: A random number generator intended for use in cryptographic system.

Delegated Third Party: A natural person or Legal Entity that is not the CA but is authorized by the CA to assist in the Certificate Management Process by performing or fulfilling one or more of the CA requirements found herein.

Domain Label: From RFC 8499 (http://tools.ietf.org/html/rfc8499): "An ordered list of zero or more octets that makes up a portion of a domain name. Using graph theory, a label identifies one node in a portion of the graph of all possible domain names."

Domain Name Registrar: A person or entity that registers Domain Names under the auspices of or by agreement with: (i) the Internet Corporation for Assigned Names and Numbers (ICANN); (ii) a national Domain Name authority/registry; or (iii) a Network Information Center (including their affiliates, contractors, delegates, successors, or assigns).

Domain Name: The label assigned to a node in the Domain Name System.

Enterprise RA: An employee or agent of an organization unaffiliated with the CA who authorizes issuance of Certificates to that organization.

Expiry Date: The "Not After" date in a Certificate that defines the end of a Certificate's validity period.

Fully-Qualified Domain Name: A Domain Name that includes the labels of all superior nodes in the Internet Domain Name System.

Mailbox Address: Also Email Address. The format of a Mailbox Address is defined as a "Mailbox" as specified in Section 4.1.2 of RFC 5321 and amended by Section 3.2 of RFC 6532, with no additional padding or structure.

Mailbox Field: A field in a Certificate that contains a Mailbox Address, being an rfc822Name or an otherName of type id-on-SmtpUTF8Mailbox in the subjectAltName extension, or a subject:emailAddress attribute.

S/MIME Certificate: A Certificate containing the Extended Key Usage id-kp-emailProtection (OID 1.3.6.1.5.5.7.3.4) and an rfc822Name and/or an otherName of type id-on-SmtpUTF8Mailbox in the subjectAltName extension.

Certificate Type: One of the four Subject profiles defined by the S/MIME Baseline Requirements – Mailbox-validated, Organization-validated, Sponsor-validated or Individual-validated.

Generation: One of the three profile strictness levels defined by the S/MIME Baseline Requirements – Legacy, Multipurpose or Strict. emSign does not issue the Legacy Generation.

Legal Entity: An association, corporation, partnership, proprietorship, trust, government entity or other entity with legal standing in a country's legal system.

Natural Person: An individual human being, as distinct from a Legal Entity.

Personal Name: A name of a Natural Person, presented as subject:givenName and/or subject:surname, being a meaningful representation of the Subject's name as verified under Section 3.2.4.

Pseudonym: An identifier assigned to a Natural Person in place of a Personal Name, used where privacy conditions require it, and verified in accordance with Section 3.1.3.

Registration Reference: A unique identifier assigned to a Legal Entity under a Registration Scheme (NTR, VAT, PSD, LEI, GOV or INT) and carried in subject:organizationIdentifier.

Registration Scheme: A scheme for assigning a Registration Reference, as listed in Appendix A of the S/MIME Baseline Requirements.

Natural Person Identifier: An identifier for a Natural Person carried in subject:serialNumber under the PAS, IDC, PNO, TAX, TIN or EID schemes.

Attestation: A written statement, accompanied by supporting documentation, from an accountant, lawyer, government official, notary or other reliable third party in the Applicant's jurisdiction customarily relied upon for the fact attested, verified under Section 3.2.8.

Reliable Data Source: An identification document or source of data used to verify Subject Identity Information that is generally recognized among commercial enterprises and governments as reliable, and which was created by a third party for a purpose other than the Applicant obtaining a Certificate. The procedure by which emSign evaluates and approves Reliable Data Sources is described in Section 3.2.8.

Approved Framework: A trust service framework recognised by the CA/Browser Forum S/MIME Certificate Working Group as providing an equivalent level of identity assurance to these Requirements.

Government Entity: A government-operated legal entity, agency, department, ministry, branch, or similar element of the government of a country, or political subdivision within such country (such as a state, province, city, county, etc.).

Grace Period: Means the period during which the Subscriber must make a revocation request.

Issuing CA: In relation to a particular Certificate, the CA that issued the Certificate. This could be either a Root CA or a Subordinate CA.

Key Compromise: A Private Key is said to be compromised if its value has been disclosed to an unauthorized person, an unauthorized person has had access to it, or there exists a practical technique by which an unauthorized person may discover its value. A Private Key is also considered compromised if methods have been developed that can easily calculate it based on the Public Key (such as a Debian weak key, see http://wiki.debian.org/SSLkeys) or if there is clear evidence that the specific method used to generate the Private Key was flawed.

Key Generation Script: A documented plan of procedures for the generation of a CA Key Pair.

Key Pair: The Private Key and its associated Public Key.

Multi-Perspective Issuance Corroboration: A process in which the results of domain validation and CAA checking performed by the Primary Network Perspective are confirmed by additional Network Perspectives prior to issuing a certificate.

Network Perspective: Related to Multi-Perspective Issuance Corroboration. A Network Perspective refers to a system (such as a cloud-hosted server) or a group of network elements (like a VPN and its supporting infrastructure) used to send outbound Internet traffic during domain control validation and/or CAA checking. The location of a Network Perspective is defined as the point where outbound Internet traffic before any encapsulation is initially passed to the Internet service provider or network infrastructure responsible for connectivity.

Object Identifier: A unique alphanumeric or numeric identifier registered under the International Organization for Standardization's applicable standard for a specific object or object class.

OCSP Responder: An online server operated under the authority of the CA and connected to its Repository for processing Certificate status requests.

Online Certificate Status Protocol: An online Certificate-checking protocol that enables relying party application software to determine the status of an identified Certificate.

Online Channel: Refers to emSign's online platforms such as CERTInext, ACME, API, and any other internet-based interfaces or services that enable Subscribers or Relying Parties to access emSign services through automated or self-service mechanisms.

Parent Company: A company that Controls a Subsidiary Company.

Private Key: The key of a Key Pair that is kept secret by the holder of the Key Pair, and that is used to create Digital Signatures and/or to decrypt electronic records or files that were encrypted with the corresponding Public Key.

Public Key Infrastructure: A set of hardware, software, people, procedures, rules, policies, and obligations used to facilitate the trustworthy creation, issuance, management, and use of Certificates and keys based on Public Key Cryptography.

Public Key: The key of a Key Pair that may be publicly disclosed by the holder of the corresponding Private Key and that is used by a Relying Party to verify Digital Signatures created with the holder's corresponding Private Key and/or to encrypt messages so that they can be decrypted only with the holder's corresponding Private Key.

Publicly-Trusted Certificate: A Certificate that is trusted by virtue of the fact that its corresponding Root Certificate is distributed as a trust anchor in widely-available application software.

Qualified Auditor: A natural person or Legal Entity that meets the requirements of this CP/CPS.

Random Value: A value specified by a CA to the Applicant that exhibits at least 112 bits of entropy.

Registered Domain Name: A Domain Name that has been registered with a Domain Name Registrar.

Registration Authority (RA): Any Legal Entity that is responsible for identification and authentication of subjects of Certificates, but is not a CA, and hence does not sign or issue Certificates. An RA may assist in the certificate application process or revocation process or both. When “RA” is used as an adjective to describe a role or function, it does not necessarily imply a separate body, but can be part of the CA.

Reliable Method of Communication: A method of communication, such as a postal/courier delivery address, telephone number, or email address, that was verified using a source other than the Applicant Representative.

Relying Party Agreement: means an agreement between emSign and a Relying Party that must be read and accepted by a Relying Party prior to validating, relying on or using a Certificate and is available for reference in the Repository.

Relying Party: Any natural person or Legal Entity that relies on a Valid Certificate. An Application Software Supplier is not considered a Relying Party when software distributed by such Supplier merely displays information relating to a Certificate.

Repository: An online database containing publicly-disclosed PKI governance documents (such as Certificate Policies and Certification Practice Statements) and Certificate status information, either in the form of a CRL or an OCSP response.

Root CA System: Means a system used to create a Root Certificate or to generate, store, or sign with the Private Key associated with a Root Certificate.

Root CA: The top level Certification Authority whose Root Certificate is distributed by Application Software Suppliers and that issues Subordinate CA Certificates.

Root Certificate: The self-signed Certificate issued by the Root CA to identify itself and to facilitate verification of Certificates issued to its Subordinate CAs.

Sovereign State: A state or country that administers its own government, and is not dependent upon, or subject to, another power.

Subject Identity Information: Information that identifies the Certificate Subject. Subject Identity Information does not include a Mailbox Address listed in the subject:commonName or subject:emailAddress fields, or in the subjectAltName extension.

Subject: The Natural Person, device, system, unit, or Legal Entity identified in a Certificate as the Subject. The Subject is either the Subscriber or a mailbox under the control and operation of the Subscriber.

Subordinate CA: A Certification Authority whose Certificate is signed by the Root CA, or another Subordinate CA.

Subscriber Agreement: An agreement between the CA and the Applicant/Subscriber that specifies the rights and responsibilities of the parties.

Subscriber: A natural person or Legal Entity to whom a Certificate is issued and who is legally bound by a Subscriber Agreement or Terms of Use.

Subsidiary Company: A company that is controlled by a Parent Company.

Technically Constrained Subordinate CA Certificate: A Subordinate CA certificate which uses a combination of Extended Key Usage settings and Name Constraint settings to limit the scope within which the Subordinate CA Certificate may issue Subscriber or additional Subordinate CA Certificates.

Terms of Use: Provisions regarding the safekeeping and acceptable uses of a Certificate issued in accordance with these Requirements when the Applicant/Subscriber is an Affiliate of the CA or is the CA.

Trustworthy System: Computer hardware, software, and procedures that are: reasonably secure from intrusion and misuse; provide a reasonable level of availability, reliability, and correct operation; are reasonably suited to performing their intended functions; and enforce the applicable security policy.

Valid Certificate: A Certificate that passes the validation procedure specified in RFC 5280.

Validation Specialists: Someone who performs the information verification duties specified in this CP/CPS . This includes the RA / Trusted Personnel of CA.

Validity Period: The period of time measured from the date when the Certificate is issued until the Expiry Date.

WebTrust for Certification Authorities: Means the current program for CAs located at CPA Canada Webtrust Principles and Criteria.

X.509: Means the ITU-T standard for Certificates and their corresponding authentication framework

1.6.2 Acronyms

#	Acronyms	Meaning
1	ACME	Automated Certificate Management Environment
2	AICPA	American Institute of Certified Public Accountants
3	API	Application Programming Interface
4	CA	Certification Authority
5	CAA	Certification Authority Authorization
6	CABF	CA/Browser Forum
7	ccTLD	Country Code Top-Level Domain
8	CICA	Canadian Institute of Chartered Accountants
9	CP	Certificate Policy
10	CPS	Certification Practice Statement
11	CRL	Certificate Revocation List
12	CSR	Certificate Signing Request
13	DBA	Doing Business As
15	DN	Distinguished Names
16	DNS	Domain Name System
17	DSA	Digital Signature Algorithm
19	ECDSA	Elliptic Curve Digital Signature Algorithm
20	EKU	Extended Key Usage
22	FIPS	(US Government) Federal Information Processing Standard
23	FQDN	Fully-Qualified Domain Name
24	GET	Get Everything Transmitted
25	HTTP	Hypertext Transfer Protocol
26	IANA	Internet Assigned Numbers Authority
27	ICANN	Internet Corporation for Assigned Names and Numbers
28	IDN	Internationalized domain names
29	IDS	Intrusion Detection System
30	IETF	Internet Engineering Task Force

#	Acronyms	Meaning
31	IPS	Intrusion Prevention System
32	ISO	International Organization for Standardization
33	MITM	Man-in-the-middle
34	MPIC	Multi-Perspective Issuance Corroboration
35	NIST	National Institute of Standards and Technology (USA)
36	NTP	Network Time Protocol
37	OCSP	Online Certificate Status Protocol
38	OID	Object Identifier
39	OV	Organization Validated
40	PKI	Public Key Infrastructure
41	POST	Power-On Self-Test
42	PQC	Post Quantum Cryptography
43	PSL	public suffix list
44	RA	Registration Authority
45	RSA	Rivest Shamir Adleman
46	SMIME	Secure MIME (Multipurpose Internet Mail Extensions)
47	SAN	Subject Alternative Name
48	SOA	Start of Authority (DNS resource record)
50	TLS	Transport Layer Security
51	TSA	Time Stamp Authority
52	URL	Uniform Resource Locator
53	UTC	Coordinated Universal Time
54	VESDA	Very Early Smoke Detection Appliance

2 Publication and Repository Responsibilities

2.1 Repositories

The emSign PKI online repository is available at:
https://repository.emsign.com

The repository ensures that emSign PKI's Root Certificates, publicly trusted Subordinate CA Certificates, and revocation data (CRLs and/or OCSP responses) are available 24 hours a day, 7 days a week, and with

resources sufficient to provide a response time of ten seconds or less under normal operating conditions (Section 4.10.2).

Each Issuing CA operating under the emSign PKI hierarchy shall ensure that relevant certification information, including Root and Subordinate CA Certificates, Cross-Certificates (if any), revocation data, this CP/CPS, and applicable Subscriber and Relying Party Agreements, is published in the emSign repository or other designated location, in accordance with applicable policies and obligations.

emSign PKI reserves the right to withhold publication of any information deemed confidential or security-sensitive.

Repository Responsibilities Include:

- Storing and distributing public key certificates
- Storing and distributing certificate status information (CRLs and/or OCSP)
- Publishing this CP/CPS and updates thereto
- Publishing applicable Subscriber and Relying Party Agreements

2.2 Publication of Certificate Information

emSign publicly discloses this CP/CPS, and its CA business practices to the extent required by its audit scheme, through the emSign Repository at https://repository.emsign.com, which is readily accessible online on a 24x7 basis. This CP/CPS is structured in accordance with RFC 3647 and includes all material required by RFC 3647. The conformance statement in Section 1.1 (emSign conforms to the latest published version of the S/MIME Baseline Requirements, which take precedence over this CP/CPS) applies to all information published under this Section.

emSign and other Issuer CAs shall make the following information publicly accessible on the web:

- All publicly trusted root Certificates.
- Cross Certificates (If applicable).
- Certificate Revocation Lists (CRLs)
- OCSP responses
- CP/CPS
- Subscriber and Relying Party Agreements

Pointers to repository information in CA and end entity Certificates shall only contain valid Uniform Resource Identifiers (URIs) that are accessible by relying parties.

2.3 Time or Frequency of Publication

emSign and other Issuer CA shall publish CA certificates and revocation data as soon as possible after issuance.

emSign reviews and updates this CP/CPS at least every 365 days, and on each such review increments the version number and adds a dated entry to the Change History in Appendix C, even if no other change is made. New or modified versions are published in the Repository within seven days of approval by the Policy Authority.

2.4 Access Controls on Repository

The information published in the emSign PKI online repository is publicly accessible and provided with unrestricted, read-only access. This includes CA certificates, CRLs, CP/CPS documents, and Subscriber and Relying Party Agreements.

emSign has implemented appropriate logical and physical safeguards to prevent unauthorized modification, insertion, or deletion of repository content. Only duly authorized personnel may manage repository contents, ensuring the integrity, authenticity, and availability of published information at all times.

3 Identification and Authentication

emSign issues the S/MIME Certificate Types and Generations listed in Section 1.2. Before issuance emSign confirms control of every Mailbox Address to be included in the Certificate (Section 3.2.2) and, depending on the Certificate Type, verifies the identity of the Legal Entity (Section 3.2.3), the identity of the Natural Person (Section 3.2.4) and the authority of the Applicant Representative (Section 3.2.6). Verification of mailbox control is performed only by emSign; the remaining identification and authentication activities may be performed by emSign or by Registration Authorities authorised under Section 1.3.2, in every case following the requirements of this CP/CPS and the S/MIME Baseline Requirements.

3.1 Naming

3.1.1 Types of Names

All names included in S/MIME Certificates issued by emSign PKI conform to X.500 and X.501 Distinguished Name (DN) standards and to RFC 5280. The Subject field is populated according to the applicable Certificate Type and Generation as set out in Sections 7.1.4 and Appendix B, and Subject attributes are never populated with metadata such as '.', '-' or a space to indicate that a value is absent or not applicable.

Where the subject:commonName of a Certificate issued to an Individual does not contain a Mailbox Address, it contains a Personal Name or a Pseudonym as described in Section 7.1.4. Names consisting of multiple words are permitted; given names joined by a hyphen are treated as a single given name. A Subject with more than one given name may select one or several of them, in any order, in accordance with national preference. emSign may allow common variations or abbreviations of Personal Names consistent with local practice.

3.1.2 Need for Names to be Meaningful

All certificates issued under this CP/CPS whether for Root CAs, Issuing CAs, or end-entity Subscribers contain Subject Distinguished Names (DNs) that are meaningful and conform to X.500/X.501 and RFC 5280 standards.

For S/MIME end-entity Certificates, Personal Names are a meaningful representation of the Subject's name as verified in the identifying documentation or in Enterprise RA records under Section 3.2.4, and organizational names are a meaningful representation of the Legal Entity as verified under Section 3.2.3. The subjectAltName extension is always present and is the primary identifier of the Mailbox Address(es) bound to the Certificate.

For Root and Issuing CA certificates, the Subject DN identifies the CA entity and clearly reflects its role and authoritative namespace. The Subject name in a CA certificate MUST match the Issuer name in certificates it issues, as required by RFC 5280.

3.1.3 Anonymity or Pseudonymity of Subscribers

emSign permits the use of Pseudonyms in Sponsor-validated and Individual-validated Certificates, in accordance with S/MIME BR Section 3.1.3. Where used, the subject:pseudonym attribute contains either a unique identifier selected by emSign for the Subject, an identifier selected by the Enterprise RA which uniquely identifies the Subject within the Organization named in subject:organizationName, or (for Individual-validated Certificates) an identifier verified against government-issued identity documents.

The identity of the Subject is always verified under Section 3.2.4 before a Pseudonym is issued; Pseudonym Certificates are therefore not anonymous. emSign and its Enterprise RAs treat all Individual identity information linking a Pseudonym to the real identity of the Subject as private information under Section 9.4.2. Mailbox-validated and Organization-validated Certificates SHALL NOT contain a subject:pseudonym attribute.

3.1.4 Rules for Interpreting Various Name Forms

Distinguished Names in Certificates are interpreted using X.500 standards and ASN.1 syntax. For URIs and HTTP References, refer RFC 2253 and 2616 for further information on how X.500 distinguished names in certificates are interpreted.

Non-ASCII character substitution: emSign may convert Subject Identity Information rendered in non-ASCII characters using a system commonly used in the Applicant's jurisdiction or recognised by the United Nations or ISO. Accented characters may be represented by their ASCII equivalent (e.g. é, à, í, ñ, ç as e, a, i, n, c) and umlauted characters (ä, ö, ü) as either ae, oe, ue or a, o, u. An ASCII name that is not a direct conversion of the registered name is included only where verified in a Reliable Data Source or a suitable Attestation.

Geographic names: emSign may use geographic endonyms and exonyms in the subject:localityName and subject:stateOrProvinceName attributes, and avoids archaic geographic names.

3.1.5 Uniqueness of Names

Each Certificate issued by emSign under this CP/CPS includes a non-sequential serial number greater than zero and less than 2^159, containing at least 64 bits of output from a CSPRNG. The Subject Distinguished Name may be reused across multiple Certificates for the same Subscriber; uniqueness of Mailbox Addresses is inherently managed through the global DNS and the operator of the relevant mail domain.

3.1.6 Recognition, Authentication, and Role of Trademarks

emSign requires that Certificate Applicants avoid including names in their certificate requests that may infringe upon the intellectual property rights of others. While emSign evaluates subject information in line with applicable certificate validation requirements, it does not independently assess trademark ownership, nor does it adjudicate disputes related to trademarks, service marks, or trade names.

If emSign becomes aware of a potential rights conflict, it reserves the right to deny or revoke a certificate application to protect the integrity of the PKI. Any Subject information containing an organization's name, Assumed Name or related identifier is verified through the documented processes specified in Section 3.2.3 of this CP/CPS and the S/MIME Baseline Requirements.

3.2 Initial Identity Validation

emSign PKI, through its Issuing CAs or authorised Registration Authorities, authenticates the identity attributes of the Subject and the Subject's control over every Mailbox Address to be included in an S/MIME Certificate before issuance. The validation applicable to each Certificate Type is:

Mailbox-validated – mailbox control under Section 3.2.2 only.

Organization-validated – mailbox control under Section 3.2.2 and organization identity under Section 3.2.3.

Sponsor-validated – mailbox control under Section 3.2.2, organization identity under Section 3.2.3 and individual identity under Section 3.2.4.

Individual-validated – mailbox control under Section 3.2.2 and individual identity under Section 3.2.4.

Reuse of completed validations and supporting evidence is permitted only within the limits set out in Section 4.2.1. Validation procedures may be revised to meet updated policy, compliance or legal obligations.

3.2.1 Method to Prove Possession of Private Key

For S/MIME certificates, the Applicant must demonstrate control of the private key corresponding to the public key in the certificate request. This is typically done by submitting a PKCS#10 Certificate Signing Request (CSR) that is signed using the private key. Other industry-approved methods may be used, subject to emSign PKI's validation and approval.

emSign PKI does not generate Key Pairs on behalf of Subscribers except where an Enterprise Subscriber has expressly requested central generation of encryption Key Pairs to support the key-escrow service described in Section 4.12. The controls applied when emSign or a Delegated Third Party generates a Private Key on behalf of a Subscriber are set out in Section 6.1.2.

3.2.2 Validation of Mailbox Authorization or Control

emSign verifies that the Applicant controls the email account associated with every Mailbox Field referenced in the Certificate, or has been authorised by the email account holder to act on that holder's behalf. This verification is never delegated. emSign records, for every Mailbox Address and every domain validated, which validation method was used and the version number of the S/MIME Baseline Requirements or TLS Baseline Requirements under which it was performed.

emSign uses only the following methods:

(a) Validating authority over mailbox via domain (S/MIME BR 3.2.2.1) – emSign confirms that the Applicant, such as an Enterprise RA, has been authorised by the email account holder by verifying the Applicant's control over the domain portion of the Mailbox Address, using only the currently approved methods of Section 3.2.2.4 of the TLS Baseline Requirements. For this purpose the term Applicant includes the Applicant's Parent Company, Subsidiary Company or Affiliate. The TLS Baseline Requirements methods emSign uses for this purpose are listed under (e) below.

(b) Validating control over mailbox via email (S/MIME BR 3.2.2.2) – emSign sends a unique Random Value by email to the Mailbox Address being validated and receives a confirming response utilising that Random Value. The Random Value is sent only to the Mailbox Address being validated, is unique in each email, and remains valid for use in a confirming response for no more than 24 hours from creation. The Random Value is reset upon each instance of the email being sent, and is reset upon first use where it is intended for any further use as an authentication factor.

(c) Validating the Applicant as operator of the associated mail server(s) (S/MIME BR 3.2.2.3) – emSign confirms control of the SMTP FQDN to which a message delivered to the Mailbox Address would be directed, identified using the address resolution algorithm of RFC 5321 Section 5.1. Where more than one SMTP FQDN is discovered, emSign follows the selection process in RFC 5321 Section 5.1. Aliases in MX record RDATA are not used for this method. Control of the SMTP FQDN is confirmed using only the currently approved methods of Section 3.2.2.4 of the TLS Baseline Requirements. The TLS Baseline Requirements methods emSign uses for this purpose are listed under (e) below.

(d) Validating control over mailbox using ACME extensions (S/MIME BR 3.2.2.4) – emSign's ACME server may confirm control of a Mailbox Field using ACME for S/MIME as defined in RFC 8823, sending the Random Value token components by email and SMTP and receiving a confirming response. token-part1 contains at least 128 bits of entropy and token-part2 contains at least 128 bits of entropy. A Random Value generated for this method is never reused for another Certificate Request and remains valid for no more than 24 hours. ACME External Account Binding as defined in RFC 8555 may be used.

(e) TLS Baseline Requirements methods used under (a) and (c) – emSign confirms control of the domain portion of a Mailbox Address, or of the SMTP FQDN identified under RFC 5321 Section 5.1, using only the following currently approved methods of Section 3.2.2.4 of the TLS Baseline Requirements, each performed with Multi-Perspective Issuance Corroboration under Section 4.2.5 where the method is DNS-, HTTP- or ACME-based: (1) Constructed Email to Domain Contact – a Random Value sent to admin@, administrator@, webmaster@, hostmaster@ or postmaster@ the Authorization Domain Name and a confirming response using it (TLS BR 3.2.2.4.4); (2) DNS Change – a Random Value present in a DNS CNAME or TXT record on the Authorization Domain Name (TLS BR 3.2.2.4.7); (3) Email to DNS CAA Contact – a Random Value sent to the DNS CAA Email Contact found using the RFC 8659 Section 3 search algorithm (TLS BR 3.2.2.4.13); (4) Email to DNS TXT Contact – a Random Value sent to the DNS TXT Record Email Contact and a confirming response using it (TLS BR 3.2.2.4.14); (5) Phone Contact with DNS TXT Record Phone Contact – a call to the DNS TXT Record Phone Contact and a confirming response (TLS BR 3.2.2.4.16); (6) Agreed-Upon Change to Website v2 – a Random Value in a file under the /.well-known/pki-validation directory of the Authorization Domain Name retrieved over HTTP/HTTPS on an Authorized Port (TLS BR 3.2.2.4.18); (7) Agreed-Upon Change to Website – ACME – the ACME HTTP challenge of RFC 8555 (TLS BR 3.2.2.4.19); and (8) DNS Labeled with Account ID – ACME DNS validation using account-specific labels (TLS BR 3.2.2.4.21). Random Values used in these methods exhibit at least 112 bits of entropy and remain valid for use in a confirming response for no more than 30 days from creation, as required by the TLS Baseline Requirements. Where a method relies on an issuer-domain-name value, the values in Section 4.2.6 are recognised. No other method, and no method that has been retired from the TLS Baseline Requirements, is used.

Completed validations of Applicant authority may support the issuance of multiple Certificates over time, subject to the reuse limits in Section 4.2.1. Mailbox Fields may be expressed in Subscriber Certificates as rfc822Name or otherName values of type id-on-SmtpUTF8Mailbox in the subjectAltName extension, and in Subordinate CA Certificates as rfc822Name entries in permittedSubtrees within the nameConstraints extension.

emSign rejects a Certificate Request where the Key Pair does not meet Sections 6.1.5 and 6.1.6, where there is clear evidence that the method used to generate the Private Key was flawed, where emSign is aware of a demonstrated method that exposes or allows computation of the Applicant's Private Key (such as a Debian weak key), or where emSign has previously been made aware that the Applicant's Private Key has suffered Key Compromise.

3.2.3 Authentication of Organization Identity

For Organization-validated and Sponsor-validated Certificates, emSign or its authorised RA collects and retains evidence supporting: (1) the formal name of the Legal Entity; (2) any registered Assumed Name to be included in the Subject; (3) any Affiliate of the Legal Entity to be included as subject:organizationalUnitName; (4) an address of the Legal Entity, if included; (5) the Jurisdiction of Incorporation or Registration; and (6) the identifier and type of identifier for the Legal Entity, which is

included in the Certificate as subject:organizationIdentifier in accordance with Section 7.1.4 and Appendix A of the S/MIME BR.

emSign verifies the full legal name and (where included in the Subject) an address of the Legal Entity Applicant using documentation provided by, or communication with, at least one of: a government agency in the jurisdiction of the Legal Entity's creation, existence or recognition; a Legal Entity Identifier (LEI) data reference; a site visit by emSign or its agent; or an Attestation accompanied by supporting documentation of legal existence and current status. Where a government agency or an Attestation is relied upon, emSign verifies that the status of the Applicant is not designated "ceased", "inactive", "invalid", "not current" or the equivalent. Where an LEI is relied upon, emSign verifies that the RegistrationStatus is ISSUED, the EntityStatus is ACTIVE and the ValidationSources entry is FULLY_CORROBORATED; an LEI is not used where ValidationSources is PARTIALLY_CORROBORATED, PENDING or ENTITY_SUPPLIED_ONLY.

Assumed Name: where an Applicant requests that an Assumed Name be included, emSign verifies that the Applicant has registered its use of that Assumed Name with the appropriate government agency in the jurisdiction of its incorporation or registration and that the filing continues to be valid, or relies on an Attestation to that effect.

Disclosure of verification sources: emSign verifies the Registration Reference to be included in a Certificate from a register maintained or authorised by the relevant government agency, and discloses the authorised sources it uses to verify an Applicant's creation, existence or recognition – together with the jurisdictions to which each source applies – in the Approved Verification Sources list published at https://repository.emsign.com. That list is maintained by the emSign Policy Authority, reviewed at least annually, and publicly accessible online without restriction. emSign may obtain register information through a third-party vendor provided the vendor obtains that information directly from the government register concerned. Where the Registration Reference is an LEI, emSign verifies the associated data record with the Global Legal Entity Identifier Foundation at https://search.gleif.org/.

3.2.4 Authentication of Individual Identity

For Sponsor-validated and Individual-validated Certificates, emSign or its authorised RA collects and retains evidence supporting the Individual Applicant's current given name(s) and surname(s), any Pseudonym used, any Title used, any address displayed in the Subject, and such further information as is needed to identify the Applicant uniquely. Evidence relating to Individual identity is gathered and retained in compliance with applicable data protection legislation and Section 9.4.

emSign accepts authoritative evidence of Individual identity from at least one of the following sources, and documents and publishes the document types, eID schemes and mDL issuing jurisdictions it accepts at https://repository.emsign.com:

(1) A physical identity document – only government-issued passports or identity cards, or other official identity documents of comparable reliability (such as a driving licence or military ID), bearing a face photo and/or other information capable of comparison with the Applicant's physical appearance. The document is presented in its original form; a remote process ensures

the Applicant has the document in hand and presents it in real time before a camera. The registration agent makes a visual comparison of the Applicant against the face photo, has access to authoritative sources on document appearance, and records the issuer, validity period and unique document number.

(2) A digital identity document – only eMRTD documents compliant with ICAO 9303 part 10, accepted only where the issuer's digital signature validates against the relevant country signing certificates (for example from the ICAO Public Key Directory). The issuer, validity period, unique document number, the identity attributes and the face photo are recorded, and the registration agent makes a visual comparison of the Applicant's physical appearance against the face photo and/or other information on the document. Automated and manual processes may be combined, provided an automated process that yields an uncertain result falls back to a registration agent.

(3) An electronic identification scheme (eID) – only "notified" eID schemes under Article 9 of the eIDAS Regulation conforming to LoA "Substantial" or "High". emSign confirms both that the eID scheme is suitable (the eID being accessible via a notified eIDAS-Node) and that the individual eID presented is valid, that is, not expired, suspended or revoked, at the time of validation. The authentication is created as part of the identity validation process and evidence of the validation with the eID's Identity Provider is retained.

(4) A digital signature applied by the Applicant using a valid personal Certificate issued under an Approved Framework. The signature is created as part of the identity validation process, is validated by emSign, and identity attributes are evidenced by the signing Certificate rather than by the content of the signed document. Attributes not present in the signing Certificate are collected and validated from other sources.

(5) Enterprise RA records – for Sponsor-validated Certificates approved by an Enterprise RA, records maintained by the Enterprise RA are accepted as evidence of Individual identity. The Enterprise RA validates all identity attributes to be included in the Certificate and maintains records sufficient to satisfy S/MIME BR Sections 1.3.2 and 8.8.

(6) Affiliation from a company attestation – for Sponsor-validated Certificates not approved by an Enterprise RA, emSign may verify the authority or affiliation of an Individual to represent an Organization using an Attestation provided by that Organization and verified under Section 3.2.8. Individual identity and Organization identity are still verified under Sections 3.2.4 and 3.2.3 respectively.

(7) A general attestation from a qualified legal practitioner or notary in the Applicant's jurisdiction, verified under Section 3.2.8.

(8) Authorised reference sources as supplementary evidence – emSign may additionally gather and verify supplementary evidence from official documents, government or regulatory registers or national population registers; for example to evidence a change of name, to verify a professional or corporate Title, to verify a role LEI assigned to the Individual and the subject:organizationName, or to verify (but not to establish) an address. Supplementary evidence is never the sole source of authoritative evidence.

(9) A Mobile Driver Licence (mDL) – only an mDL issued by an Issuing Authority legally authorised to issue driving licences, conforming to ISO/IEC 18013-5, supporting validation through ISO/IEC 18013-7, and demonstrating a valid Certificate chain from the Document Signer Certificate to an Issuing Authority Certificate verifiable through a publicly available trust anchor or trust list. emSign authenticates to the holder's device, verifies the authenticity and integrity of the mDL data through the Mobile Security Object and its signature chain, validates the Document Signer Certificate chain, and verifies that the mDL is current and not revoked. mDL authentication is performed in real time and never relies on previously captured mDL data.

Where evidence has an explicit validity period, emSign verifies that the time of identity validation falls within that period. emSign may reuse existing evidence subject to the limits in Section 4.2.1. Automated and manual processes may be used in combination, provided an automated process that yields an uncertain result falls back to a registration agent.

3.2.5 Non-Verified Certificate Holder Information

emSign does not include unverified information in publicly trusted S/MIME certificates. Any information appearing in a certificate is subject to verification as per the applicable validation requirements. Information that has not been verified in accordance with this CP/CPS and the S/MIME Baseline Requirements is never included in a publicly-trusted S/MIME Certificate. Certificates issued for internal demonstration or testing purposes are issued only from a CA hierarchy that does not chain to any emSign Root CA Certificate distributed by an Application Software Supplier.

3.2.6 Validation Of Authority

When a certificate request includes an Organizational Name, emSign or its authorized Registration Authorities shall validate that the Applicant is duly authorized to act on behalf of the Organization. This validation includes confirming the Applicant's role, position, or explicit authorization using verified organizational records, direct confirmation from authoritative contacts within the Organization, or other reliable and documented sources. The method of validation may vary based on the certificate type and ensures that only appropriately authorized individuals can submit certificate requests on behalf of the Organization.

Before commencing to issue Organization-validated or Sponsor-validated Certificates for an Applicant, emSign uses a Reliable Method of Communication to verify the authority and approval of the Applicant Representative to act as an Enterprise RA, to request issuance or revocation of Certificates, or to assign those responsibilities to others. emSign may establish a process allowing an Applicant to specify the individuals who may act as Applicant Representatives on an ongoing basis, and provides an Applicant with a list of its authorised Applicant Representatives on verified written request.

3.2.7 Criteria for interoperation

Cross-certification, where performed, does not grant any certificate issuance rights or control over CA private keys to external entities. Any interoperation for trust path compatibility must fully comply with

this CP/CPS, maintain exclusive control by emSign or eMudhra over all issuance processes and keys, and be subject to approval by the emSign Policy Authority. emSign discloses all Cross Certificates that identify an emSign CA as the Subject, where emSign arranged for or accepted the establishment of the trust relationship, in the Repository and in the CCADB.

3.2.8 Reliability of Verification Sources

Before relying on a source of verification data, emSign verifies its suitability as a Reliable Data Source. Enterprise RA records are a Reliable Data Source for Individual Subject attributes in Sponsor-validated Certificates issued to the Enterprise RA's Organization. Where emSign relies on an Attestation, it verifies that the letter was written by an accountant, lawyer, government official or other reliable third party in the Applicant's jurisdiction customarily relied upon for such information, that the Attestation includes a copy of the supporting documentation, and that the Attestation is authentic – confirmed by contacting the sender using a Reliable Method of Communication.

3.2.8.1 Evaluation of Verification Data Sources

Prior to using any data source as a Reliable Data Source, the emSign Validation Policy team evaluates that source for its reliability, accuracy, and resistance to alteration or falsification. The evaluation is documented on an Approved Verification Source Assessment record, is approved by the emSign Policy Authority before the source enters production use, and is reviewed at least annually and upon emSign becoming aware of any event calling the source's reliability into question. Each evaluation records emSign's assessment of: (1) the age of the information provided by the source; (2) the frequency with which the source updates its information; (3) the identity of the data provider and the purpose for which the data was collected; (4) the extent to which the data is publicly accessible; and (5) the relative difficulty of falsifying or altering the data. The categories of source evaluated and approved under this procedure are: government company and business registers in the Jurisdiction of Incorporation or Registration; the Global Legal Entity Identifier Foundation (GLEIF) LEI data record; government-issued physical and digital identity documents and eMRTD documents; notified electronic identification schemes under Article 9 of the eIDAS Regulation at Level of Assurance Substantial or High; Mobile Driver Licences conforming to ISO/IEC 18013-5 issued by an authorised Issuing Authority; Enterprise RA records maintained under a written Enterprise RA agreement; and Attestations verified in accordance with Section 3.2.8. The approved sources, and the jurisdictions to which each applies, are published in the Approved Verification Sources list at https://repository.emsign.com. A database maintained by emSign PKI, where the information in it was primarily collected for the purpose of fulfilling a validation under this CP/CPS, does not qualify as a Reliable Data Source. Where emSign obtains register information through a third-party vendor, that vendor SHALL obtain the information directly from the government register concerned.

3.3 Identification and authentication for re-key requests

For CA Certificates, re-keying is permitted by issuing a new certificate with an extended validity period for the same Distinguished Name (DN).

For Subscriber Certificates, re-keying (renewal) may be allowed using previously validated information only if the original identification and authentication was performed within the reuse periods set out in Section 4.2.1 and the table in Section 3.3.1, being 30 days for mailbox control validated under Section 3.2.2(b) or 3.2.2(d) (ACME), 398 days for domain or mail-server control validated under Section 3.2.2(a) or 3.2.2(c), and 825 days for organization identity, individual identity and validation of authority.

In such cases, and only if the certificate has not been revoked, emSign PKI may accept the renewal request using a previously verified Certificate Signing Request (CSR), or permit re-authentication via secure methods such as a passphrase, shared secret, account-based authentication, or any other mechanism approved by emSign PKI. Renewal or re-keying based on a revoked certificate is explicitly prohibited.

3.3.1 Identification and Authentication for Routine Re-Key

Re-keying is a process where new private key / key pair is generated by the subscriber and a request is made to provide certificate, with information similar to a previous certificate.

Subscribers may request Re-key any number of times during the validity period of the certificate. A re-keyed Certificate is a newly issued Certificate and may be given a new Validity Period not exceeding the maximum in Section 6.3.2 and not extending beyond the notAfter of its Issuing CA Certificate. The requirement that the expiration date be unchanged applies only to a replacement Certificate issued on a previously verified Certificate Request under Section 4.7.3 and S/MIME BR Section 4.1.2.

Where the initial Subscriber identification & authentication process as per this CP/CPS will be been performed as below:

Validation Type	Certificate Issued On or After	Certificate Issued Before	Maximum Data Reuse Period	Re-Key Authentication Condition
Organization identity, Individual identity and Validation of Authority (S/MIME BR 3.2.3, 3.2.4, 3.2.6)	–	–	825 days	Re-key using previously validated information is permitted only if the initial validation was completed within 825 days prior to issuance; otherwise identity is re-validated under Section 3.2.
Mailbox control by email or ACME (S/MIME BR 3.2.2.2 / 3.2.2.4)	–	–	30 days	Control of each Mailbox Address must be re-confirmed by Random Value (Section 3.2.2(b)) or ACME (Section 3.2.2(d)) within 30 days prior to Certificate issuance.
Domain / mail-server control (S/MIME BR 3.2.2.1 / 3.2.2.3)	–	–	398 days	Control of the domain portion of the Mailbox Address, or of the associated SMTP FQDN, must be validated within 398 days prior to Certificate issuance.

3.3.2 Identification and Authentication for Re-Key After Revocation

Identification and Authentication for Re-Key after revocation is based on the same requirements as issuance of new Certificates.

3.4 Identification and Authentication for Revocation Requests

A request to revoke keys or digital certificates may be submitted by the Subscriber or an individual authorized under applicable contractual agreements. Revocation requests may be initiated through secure mechanisms such as emSign's subscriber portal, CERTInext enterprise and partner platforms, ACME clients, or authorized APIs integrated with emSign PKI.

To validate a revocation request, emSign PKI requires the requester to authenticate using secure challenge-response methods, such as logging in with verified credentials, demonstrating domain/email control, or signing the request using the corresponding private key.

emSign PKI may revoke a certificate without authentication in circumstances where there is evidence or reasonable suspicion of key compromise, misuse, fraud, or based on instructions from a competent legal or regulatory authority or an event that triggers revocation of one or more certificates based on inconsistencies identified between practice and policy. All such revocation actions are logged, and validation personnel ensure traceability of the requester (where applicable), action taken, and reason.

Requests related to CA certificate revocation are subject to elevated review and must be authorized by the emSign Policy Authority.

4 Certificate Life-Cycle Operation Requirements

4.1 Certificate Application

S/MIME certificate requests may be submitted through authorised online channels including the CERTInext portal, enterprise integrations using emSign APIs, or automated systems using ACME for S/MIME (RFC 8823). Each application must include sufficient information to allow emSign to confirm the identity of the requesting entity, validate control over the Mailbox Address(es) to be certified, and verify that the individual submitting the request is authorized to act on behalf of the applicant organization, where applicable. Additionally, the application must enable validation that the public key submitted corresponds to a private key legitimately held by the applicant.

All applications are subject to verification procedures appropriate to the certificate type requested. Issuance proceeds only after successful completion of identity and domain validation steps by emSign or its authorized Registration Authorities. Applicants must review the issued certificate for accuracy and promptly report any errors or inconsistencies.

4.1.1 Who Can Submit a Certificate Application

Certificate applications must be submitted by individuals or entities authorized to act on behalf of the Applicant. Submissions may occur through approved emSign interfaces, including the CERTInext portal, emSign enterprise API integrations, or automated protocols such as ACME.

All required registration details must be provided in accordance with this CP/CPS and the applicable Certificate Holder Agreement or Subscriber Agreement. Each application is subject to review, approval, and acceptance by emSign or its authorized Registration Authorities.

Organization-validated and Sponsor-validated applications are submitted by an Applicant Representative whose authority has been verified under Section 3.2.6 (or by an Enterprise RA appointed under Section 1.3.2.1) and are accompanied by an executed Subscriber Agreement or acknowledged Terms of Use.

Applications will not be accepted from individuals or entities listed on government sanctions, deniedpersons, or prohibited lists relevant to the jurisdiction of the Issuing CA entity .

4.1.2 Enrolment Process and Responsibilities

Applicants seeking S/MIME Certificates under the emSign PKI shall complete an enrollment process designed to ensure the integrity, authenticity, and accountability of all issued certificates. While Issuing CAs may define specific implementation workflows, the enrollment process shall include the following minimum steps:

- The Applicant's identity whether representing an organization or an individual shall be verified in accordance with the procedures outlined in Appendix A.
- The Applicant shall generate a secure cryptographic key pair and demonstrate possession of the private key, typically through submission of a digitally signed Certificate Signing Request (CSR).
- The verified identity shall be bound to the public key in accordance with this CP/CPS.
- The Applicant must submit a Certificate Request, in a form prescribed by emSign, containing a request for issuance and a certification by or on behalf of the Applicant that all information in it is correct, and must enter into a binding Subscriber Agreement or acknowledge the Terms of Use (Section 9.6.3). One Certificate Request may support multiple Certificates to the same Applicant within the reuse periods of Section 4.2.1, and a previously verified Certificate Request may be relied upon for a replacement Certificate only where the previous Certificate has not been revoked, the replacement has the same expiration date and the Subject Information is unchanged. The Issuing CA shall operate under a formal agreement with emSign PKI.
- All communications supporting the application and issuance process whether electronic or out-of-band shall maintain the confidentiality and integrity of transmitted data using cryptographic methods appropriate to the key size and security profile.

Applicants are responsible for submitting accurate and complete information, responding to validation requests in a timely manner, and protecting the confidentiality of their private keys. Certificates shall only be issued once all validation requirements have been fulfilled and applicable agreements accepted.

4.2 Certificate Application Processing

4.2.1 Performing Identification and Authentication Functions

Certificate applications may be submitted directly to emSign or through authorized Registration Authorities (RAs), including enterprise interfaces such as the emSign CERTInext portal, API-based integrations, or automated channels like ACME. All applications are ultimately processed and issued by emSign's Issuing CAs.

Prior to issuance, emSign or its authorized RAs perform validation procedures to ensure:

- The Applicant is eligible to request the specified certificate type;

- A valid Certificate Signing Request (CSR) is submitted;
- The submitted public key is appropriately bound to the Applicant's identity;
- The Subscriber Agreement has been accepted by the Applicant;
- The certificate request conforms with applicable requirements outlined in Section 3.1 and Appendix A.

For S/MIME Certificates, emSign verifies control of every Mailbox Address to be included in the Certificate using one or more of the methods set out in Section 3.2 of this CP/CPS.

Where the certificate asserts organizational or individual identity, emSign additionally validates the Legal Entity under Section 3.2.3 and/or the Natural Person under Section 3.2.4, and the authority of the Applicant Representative under Section 3.2.6.

emSign performs Certification Authority Authorization (CAA) checks for the domain portion of every Mailbox Address in accordance with RFC 9495 and S/MIME BR Section 4.2.2.1, as further described in Section 4.2.4.

Validation reuse: emSign reuses completed validations and supporting evidence only within the limits of S/MIME BR Section 4.2.1 – no more than 30 days for mailbox control validated by email (Section 3.2.2(b)) or by ACME (Section 3.2.2(d)), no more than 398 days for control of a mail server or of the domain portion of a Mailbox Address, and no more than 825 days for organization identity, individual identity and validation of authority. A prior validation is not reused where any data or document used in it was obtained more than the maximum permitted reuse period before issuance.

Subscribers whose DNS zones contain CAA records with one or more issuemail property tags, and who intend to request S/MIME Certificates from emSign, must include an issuemail property tag set to "emsign.com" to authorise emSign to issue; CAA records containing only issue or issuewild property tags do not restrict S/MIME issuance (Section 4.2.4).

emSign applies Multi-Perspective Issuance Corroboration (MPIC) to CAA checking and to every validation of the domain portion of a Mailbox Address or of an SMTP FQDN performed under Section 3.2.2(a) or 3.2.2(c), as described in Section 4.2.5.

DNSSEC validation of all DNS queries associated with CAA record lookups is performed as described in Section 4.2.4.

4.2.2 Approval or Rejection Of Certificate Applications

emSign or its authorized Registration Authorities (RAs) shall approve a certificate application only after successful completion of all required validation procedures as defined in this CP/CPS and Appendix A. The Issuing CA shall reject any application that fails validation or where the submitted information cannot be

verified. Additionally, emSign reserves the right to reject a certificate application at its discretion, including but not limited to cases where:

- The Applicant or request is associated with high-risk domains, prohibited geographies, or restricted entities;
- Issuance may compromise the trustworthiness, security, or reputation of emSign;
- There is suspected misuse, fraud, or conflict with applicable laws or industry standards.

emSign is not obligated to provide specific reasons for the rejection of an application. Applicants whose requests have been denied may submit a new application following corrective action.

Subscribers are responsible for ensuring the ongoing accuracy of the information provided in their certificate applications. Failure to notify emSign of changes that affect certificate validity may result in certificate revocation in accordance with Section 4.9 and the terms of the Subscriber Agreement.

4.2.3 Time to Process Certificate Applications

Registration Authorities and Issuing CAs operating within the emSign PKI are under no obligation to process Digital Certificate Applications other than within a commercially reasonable time.

4.2.4 Certificate Authority Authorization (CAA)

Prior to issuing any Certificate that includes a Mailbox Address, emSign retrieves and processes CAA records for the domain portion of that Mailbox Address in accordance with Section 4 of RFC 9495 (Certification Authority Authorization (CAA) Processing for Email Addresses) and S/MIME BR Section 4.2.2.1. Where a Certificate includes more than one Mailbox Address, emSign performs this procedure for each Mailbox Address.

When processing CAA records, emSign processes the issuemail property tag as specified in RFC 9495. Additional property tags may be supported but do not conflict with or supersede the authorisations to issue S/MIME Certificates expressed in the issuemail property tag. A Certificate is not issued where an unrecognised property is encountered with the critical flag set.

Where a CAA RRset is present, emSign determines whether the Certificate Request is consistent with it, processing the issuemail property tag in accordance with RFC 9495. Where the Relevant RRset contains one or more issuemail property tags and none of them authorises emsign.com, the request is rejected. Where the Relevant RRset contains no issuemail property tag, CAA does not restrict S/MIME issuance and issuance may proceed. emSign does not issue a Certificate unless it determines that the Certificate Request is consistent with the applicable CAA RRset.

If the Relevant RRset for a domain contains no restrictive tags then CAA does not restrict issuance. If no CAA record exists for the domain, issuance may proceed.

If emSign issues a Certificate following a CAA check, issuance occurs within the Time-To-Live (TTL) of the CAA record, or 8 hours, whichever is greater. This does not prevent emSign from checking CAA records at any other time. All actions taken in consequence of a CAA check are logged.

emSign does not treat a CAA record lookup failure as permission to issue, except where all of the following are met: (i) the failure is outside emSign's infrastructure; (ii) the lookup has been retried at least once; and (iii) emSign has confirmed that the domain is "Insecure" as defined in RFC 4035 Section 4.3. Where these conditions are not met, emSign fails closed and does not issue the Certificate.

DNSSEC validation of CAA records (S/MIME BR 4.2.2.1.1): DNSSEC validation back to the IANA DNSSEC root trust anchor is performed on all DNS queries associated with CAA record lookups performed by the Primary Network Perspective. The resolver used performs DNSSEC validation using the algorithm of RFC 4035 Section 5, supports NSEC3 (RFC 5155) and SHA-2 (RFC 4509 and RFC 5702), and properly handles the security concerns of RFC 6840 Section 4. emSign does not use local policy to disable DNSSEC validation on any such query, and does not treat a DNSSEC validation error observed by the Primary Network Perspective (for example SERVFAIL) as permission to issue.

In accordance with S/MIME BR Section 4.2.2.1, emSign may rely on the following exception where applicable:

CAA checking is optional for Certificates issued by a Technically Constrained Subordinate CA Certificate as set out in Section 7.1.5, where the absence of CAA checking is an explicit contractual provision in the contract with the Technically Constrained Subordinate CA Applicant.

emSign documents all actions taken based on CAA records. Potential issuance prevented by a CAA record is documented in sufficient detail to provide feedback to the CA/Browser Forum on the circumstances, and emSign dispatches reports of such issuance requests to the contacts stipulated in any CAA iodef record present, using the mailto: or https: URL schemes.

emSign recognizes the following domain name values in CAA records as granting authorization for issuance by emSign PKI:

- emsign.com

emSign applies Multi-Perspective Issuance Corroboration to every CAA record lookup as described in Section 4.2.5. A remote Network Perspective's CAA check response is interpreted as permission to issue even where the responses are not byte-for-byte identical, and an acceptable CAA record lookup failure (as defined above) at one or both perspectives is treated as corroborating, in accordance with S/MIME BR Section 4.2.2.1.

4.2.5 Multi-Perspective Issuance Corroboration

emSign implements Multi-Perspective Issuance Corroboration (MPIC) in accordance with Section 3.2.2.9 of the current TLS Baseline Requirements, as required by S/MIME BR Section 4.2.2.2, for every CAA record lookup (Section 4.2.4) and for every validation of the domain portion of a Mailbox Address or of an SMTP FQDN performed under Section 3.2.2(a) or 3.2.2(c) using a DNS-, HTTP- or ACME-based method.

emSign uses at least the number of remote Network Perspectives required by the phased implementation timeline of TLS BR Section 3.2.2.9 in force at the time of validation. The remote Network Perspectives are located in at least two distinct Regional Internet Registry service regions, are separated from each other

and from the Primary Network Perspective by a straight-line distance of at least 500 km, each use a recursive DNS resolver within the same RIR service region as the perspective, and share no DNS cache or validation result with any other perspective. DNS queries and HTTP/ACME validations are performed independently from each perspective.

Issuance proceeds only where the number of remote Network Perspectives that fail to corroborate the Primary Network Perspective does not exceed the maximum permitted by TLS BR Section 3.2.2.9 (one where two to five remote perspectives are used; two where six or more are used). Where the quorum is not met, or where an inconsistency indicative of a BGP hijack, DNS manipulation or other network-level interference is detected, the validation or CAA check is treated as failed and no Certificate is issued. The outcome of each corroboration, including any non-corroborating Network Perspective, is logged for every validation and CAA check.

4.2.6 Issuer Domain Names Recognised in DNS Validation Records

Where the domain portion of a Mailbox Address is validated under Section 3.2.2(a) or 3.2.2(c) using a TLS Baseline Requirements Section 3.2.2.4 method listed in Section 3.2.2(e) that permits a persistent value identifying the issuing CA to be placed in a DNS record, emSign recognises the following issuer domain names in such records:

- emsign.com
- certinext.io

4.3 Certificate Issuance

4.3.1 Certification Authority Actions During Certificate Issuance

Issuing CAs operating under this CP/CPS shall comply with all applicable requirements and processes defined in the emSign PKI CP/CPS for S/MIME. Certificate issuance shall occur only after successful validation of the Applicant and verification of all certificate data in accordance with the applicable certificate profile and Appendix A.

Linting of to-be-signed Certificate content: emSign operates a pre-issuance Linting process that tests the technical conformity of every to-be-signed S/MIME Certificate against the S/MIME Baseline Requirements, as required by S/MIME BR Section 4.3.1.2 with effect from 15 September 2025. Linting is performed on the tbsCertificate before the signing operation, and issuance does not proceed where a Linting result classified as an error (as distinct from a warning or notice) is returned. emSign uses Linting tools widely adopted by the industry in addition to any internally developed lints. emSign may also lint issued Certificates under S/MIME BR Section 4.3.1.3, and uses a Linting process within the self-audit sample under Section 8.7.

4.3.1.1 emSign Root Certification Authority

The Root CA Certificates are self-signed and generated in an offline environment. Root CA private keys are maintained in secure, offline cryptographic modules in compliance with industry standards and are only used to sign Subordinate CA certificates and CRLs/OCSP responses as required.

emSign PKI publishes its Root CA Certificates, along with their certificate chains, in the online repository: https://repository.emsign.com.

4.3.1.2 emSign Issuing Certification Authority Certificates

emSign operates its own Issuing CAs under this CP/CPS. These CAs are directly subordinate to an emSign-operated offline Root CA. All Issuing CA certificates are published in the repository, including the hierarchy path to the Root.

Where necessary, emSign may operate issuing CAs under other emSign subordinate CAs within the same hierarchy, subject to strict internal controls and authorization by the emSign Policy Authority.

4.3.1.3 emSign PKI Registration Authority Appointment

Any Issuing CA (under emSign PKI) can appoint external Registration Authorities, who must accept the terms and conditions of emSign PKI Registration Authority Agreement. Upon final approval of the application by Issuing CA, the Registration Authority becomes duly appointed. Upon appointment, they shall be appropriately trained and qualified staff members of the Registration Authority are eligible for Registration Authority Officer Digital Certificates.

4.3.1.4 Registration Authority Officer's Certificate

As part of the application process, Registration Authorities are required to nominate one or more persons within their Organisation to take responsibility for the operation of their Registration Authority functions. Those nominated persons will each be issued a Registration Authority Officer's Digital Certificate.

4.3.1.5 Certificate Holder Certificates

Upon the Applicant's acceptance of the terms and conditions of the Certificate Holder Agreement or other relevant agreement, the successful completion of the application process and final approval of the application by the Issuing CA, the Issuing CA issues the Digital Certificate to the Applicant or Device.

emSign deploys multi-factor authentication for all accounts capable of directly causing certificate issuance.

4.3.1.6 Issuance Safeguards

- All issuance systems are subject to automated and manual controls to prevent misissuance.
- Certificates SHALL NOT be backdated to circumvent policy requirements.
- Linting pre and post-issuance validation tools (e.g., PKILint, ZLint, x509lint) are employed prior to issuance to detect non-compliant fields.

- All certificate issuance actions are logged, and evidence of validation (whether internal or via authorized RA) is retained for audit and compliance purposes.
- The Root CA does not support automated issuance. Certificate issuance by a Root CA requires at least two individuals authorised by emSign (CA system operator, system officer or PKI administrator) acting together in a witnessed key ceremony, one of whom deliberately issues a direct command for the Root CA to perform each Certificate signing operation (S/MIME BR 4.3.1.1).

4.3.2 Notification to subscriber by the CA of issuance of certificate

The Issuing CA shall notify the Subscriber of the issuance of a Certificate in a convenient and appropriate way based on information submitted during the enrolment process.

4.4 Certificate Acceptance

Certificate acceptance is governed by the requirements outlined in this CP/CPS. A certificate is considered accepted when the Subscriber uses the certificate, downloads or installs it, or authorizes its use by another entity. Acceptance may also be inferred if 30 days pass from the date of issuance without objection.

By accepting a certificate, the Subscriber:

- Agrees to be bound by the terms of the Subscriber Agreement and this CP/CPS;
- Confirms that the certificate contents are accurate and truthful as submitted during the application process;
- Warrants that no unauthorized individual has had access to the private key associated with the certificate; and
- Accepts the responsibility to securely retain and control the private key, use a trustworthy system, and take reasonable precautions to prevent its compromise, misuse, or unauthorized disclosure.

If a certificate is not accepted, eMudhra reserves the right to revoke the certificate. However, use of the certificate or any reliance upon it constitutes deemed acceptance, binding the Subscriber to the terms and conditions stated herein.

4.4.1 Conduct Constituting Certificate Acceptance

The downloading, installing or otherwise taking delivery (through physical or electronic means via certificate delivered over link/download in the Issuing CA website or in email, etc) by the subscriber, or by an entity authorized/consented by subscriber, of a Digital Certificate constitutes acceptance of a Digital Certificate within the emSign PKI.

4.4.2 Publication of the Certificate by the Certification Authority

Issuing CAs may publish a Certificate by sending the Certificate to the Subscriber and/or publishing in a suitable Repository.

S/MIME Certificates are not logged to Certificate Transparency logs; Certificate Transparency is not required by the S/MIME Baseline Requirements and no CT-based exception to CAA checking is available under this CP/CPS.

However, emSign maintains internal issuance records and audit-traceable logs for all publicly trusted S/MIME certificates, in accordance with the CA/B Forum S/MIME Baseline Requirements

4.4.3 Notification of Certificate Issuance by the Certification Authority to Other Entities

In addition to the Subscriber, emSign may notify:

- Registration Authorities or authorized enterprise portals involved in processing the application;
- Reseller partners or web host integrators through their designated notification channels; and
- The emSign Policy Authority, in cases involving CA certificate issuance;

4.5 Key Pair And Certificate Usage

4.5.1 Subscriber Private Key and Certificate Usage

By accepting the S/MIME Certificate, the Subscriber agrees to use the Certificate strictly in accordance with its designated key usage extensions as defined in the Certificate Profile. Subscribers must ensure that their private keys are protected against unauthorized access, disclosure, or use, and must only use the key for lawful purposes and in line with the intended use.

Subscribers are responsible for:

- Generating and storing private keys in a secure environment,
- Preventing loss, modification, or unauthorized access to the private key,
- Promptly notifying emSign if there is any suspicion of key compromise.

4.5.2 Relying Party Public Key and Certificate Usage

Relying Parties are individuals or entities that depend on the validity of a Digital Certificate issued under this CP/CPS to establish trust in digital communications or transactions. A Relying Party may accept a Digital Certificate only to the extent that:

- They are authorized to do so by contract with the Certificate Holder, or
- It is permitted by applicable law or regulation in the jurisdiction where the Certificate is issued.

For S/MIME Certificates:

- Relying Parties are expected to use software that complies with X.509 standards, the S/MIME message specification (RFC 8551), and other applicable industry standards.

- emSign PKI does not guarantee or warrant that third-party software enforces the certificate validation procedures, and Relying Parties must obtain independent legal or technical advice if needed.
- Relying Parties must validate the certificate before relying on it, by checking its revocation status using emSign PKI-provided CRL or OCSP services.
- emSign PKI assumes no responsibility for any risk or damages resulting from reliance on a certificate that has not been properly validated.

Any entity querying the existence or validity of an emSign PKI-issued certificate is deemed to have accepted the Relying Party Agreement and the terms of this CP/CPS.

Relying Parties must assess, at a minimum:

- That the certificate is not being used in a manner prohibited by this CP/CPS;
- The appropriateness of the certificate for the intended purpose;
- That the certificate's usage aligns with its key usage and extended key usage fields;
- That the certificate is valid at the time of reliance by checking its status via CRL or OCSP mechanisms.

Warranties provided under this CP/CPS are only valid if the Relying Party has performed the above verification and assessment steps.

4.6 Certificate Renewal

4.6.1 Circumstances for Certificate Renewal

An Issuing CA may process a renewal request if all of the following conditions are met:

- The public key remains valid and suitable for continued use.
- The associated private key has not been compromised.
- The certificate subject information and Subscriber attributes remain unchanged.
- All validations supporting the renewal remain within the reuse periods of Section 4.2.1: 30 days for mailbox control validated under Section 3.2.2(b) or 3.2.2(d), 398 days for domain or mail-server control under Section 3.2.2(a) or (c), and 825 days for organization identity, individual identity and validation of authority. Where any required validation has aged beyond its reuse period, it is re-performed under Section 3.2 before the renewed Certificate is issued.

Renewal may be permitted even after certificate expiration, provided the above conditions are met. However, the original certificate shall not be further renewed, rekeyed, or modified once expired.

4.6.2 Who may request renewal

Renewal may be requested by the original Subscriber or by a Registration Authority acting on their behalf. All renewal requests must be authenticated using approved subscriber authentication methods, such as

passphrases, shared secrets, or account-based authentication. Submission of a CSR is optional, but if used, it must contain the same public key.

4.6.3 Processing Certificate Renewal Requests

emSign PKI reserves the right to request re-authentication or updated information prior to processing a renewal request. In such cases, the same validation procedures applicable to new issuance may be applied. The original certificate may remain valid or may be revoked at emSign's discretion. In every case, any validation that has aged beyond its reuse period under Section 4.2.1 is re-performed under Section 3.2 before the renewed Certificate is issued.

4.6.4 Notification of new certificate issuance to subscriber

Notification of the renewed certificate shall follow the same process as for new certificate issuance, as defined in Section 4.3.2 of this CP/CPS. Subscribers may also receive email reminders about impending certificate expiration as a courtesy, typically within 60 days prior to expiry.

4.6.5 Conduct constituting acceptance of a renewal certificate

Subscriber conduct constituting acceptance of a renewed certificate shall be the same as defined under Section 4.4.1. This includes usage, installation, or download of the certificate.

4.6.6 Publication of the Renewed Digital Certificate by Certification Authority

Renewed certificates shall be published using the same mechanisms as those for new certificate issuance, including delivery to the Subscriber and publication in the emSign certificate repository where applicable.

4.6.7 Notification of certificate issuance by the CA to other entities

The CA may notify relevant Registration Authorities involved in the renewal process. No additional notifications are sent to external entities unless specifically required under applicable practices or agreements.

4.7 Certificate Re-Key

Certificate re-key refers to the issuance of a new certificate with a newly generated public key, while retaining the same subject information as the original certificate. All re-key operations must comply with the requirements of this CP/CPS, including due diligence in key pair generation, validation, and secure delivery.

4.7.1 Circumstance For Certificate Re-Key

An Issuing CA may re-key a Certificate upon request as long as:

- The original Certificate to be re-keyed has not been revoked;

- All retained details within the Certificate remain accurate and no new or additional validation is required.

4.7.2 Who may request certification of a new public key

Re-key requests may be initiated by:

- The original Certificate Subscriber
- An authorized PKI Sponsor or delegated Registration Authority acting on behalf of the Subscriber

4.7.3 Processing Certificate Re-Key Request

Re-key requests are processed using the same procedures applicable to new certificate issuance. The Subscriber must authenticate as required for routine re-keying under this CP/CPS.

A re-key requires a new Certificate Request containing the newly generated Public Key and proof of possession of the corresponding Private Key; emSign performs new validation or reuses existing validation evidence only within the limits of Section 4.2.1. Separately, a previously verified Certificate Request (with the existing Public Key) may be relied upon to issue a replacement Certificate – which is not a re-key – only where (1) the previous Certificate has not been revoked, (2) the replacement Certificate has the same expiration date as the previous Certificate, and (3) the Subject Information is unchanged (S/MIME BR 4.1.2). All other issuance requirements of this CP/CPS apply.

4.7.4 Notification of new certificate issuance to subscriber

The notification to subscriber on new certificate issuance (for re-key certificate) shall be same as the process defined in this CP/CPS for new certificate issuance notification to Certificate Holder.

4.7.5 Conduct constituting acceptance of a Re-Key Digital Certificate

The conduct constituting the certificate acceptance for re-key shall be same as the process defined in this CP/CPS for new certificate acceptance.

4.7.6 Publication of the Re-Key Digital Certificate by Certification Authority

The publication of certificate in case of re-key shall be same as the process defined in this CP/CPS for new certificate publication.

4.7.7 Notification of Re-Key Digital Certificate Issuance by the Certification Authority to other entities

The notification to other entities for re-key certificate shall be same as the process defined in this CP/CPS for new certificate issuance notification to other entities.

4.8 Certificate Modification

emSign PKI does not support modifying S/MIME certificates after they are issued. If any certificate information needs to change, the Subscriber must request a new certificate.

The new request will follow the full validation process as required for the certificate type.

4.8.1 Circumstance for certificate modification

No stipulation.

4.8.2 Who may request certificate modification

No stipulation.

4.8.3 Processing certificate modification requests

No stipulation.

4.8.4 Notification of new certificate issuance to subscriber

No stipulation.

4.8.5 Conduct constituting acceptance of modified certificate

No stipulation.

4.8.6 Publication of the modified certificate by the CA

No stipulation.

4.8.7 Notification of certificate issuance by the CA to other entities

No stipulation.

4.9 Certificate Revocation and Suspension

4.9.1 Circumstances For Revocation

emSign revokes Subscriber Certificates and Subordinate CA Certificates in the circumstances, and within the timeframes, set out in this Section, which reproduce S/MIME BR Sections 4.9.1.1 and 4.9.1.2. A suspected compromise of a Private Key is investigated under Section 4.9.5, and the Certificate is revoked where the investigation establishes a ground for revocation listed in this Section.

emSign SHALL revoke a Subscriber Certificate within 24 hours if one or more of the following occurs:

- The Subscriber requests in writing that emSign revoke the Certificate;
- The Subscriber notifies emSign that the original Certificate Request was not authorized and does not retroactively grant authorization;

- emSign obtains evidence that the Subscriber's Private Key corresponding to the Public Key in the Certificate suffered a Key Compromise;
- emSign is made aware of a demonstrated or proven method that can easily compute the Subscriber's Private Key based on the Public Key in the Certificate (such as a Debian weak key, see https://wiki.debian.org/SSLkeys);
- emSign obtains evidence that the validation of domain authorization or mailbox control for any Mailbox Address in the Certificate should not be relied upon.

emSign SHOULD revoke a Subscriber Certificate within 24 hours and SHALL revoke it within 5 days if one or more of the following occurs:

- The Certificate no longer complies with the requirements of Sections 6.1.5 and 6.1.6;
- emSign obtains evidence that the Certificate was misused;
- emSign is made aware that the Subscriber has violated one or more of its material obligations under the Subscriber Agreement or Terms of Use;
- emSign is made aware of any circumstance indicating that use of an email address or Fully-Qualified Domain Name in the Certificate is no longer legally permitted (for example a court or arbitrator has revoked the right to use the email address or Domain Name, a relevant licensing or services agreement with the Subscriber has terminated, or the account holder has failed to maintain the active status of the email address or Domain Name);
- emSign is made aware of a material change in the information contained in the Certificate;
- emSign is made aware that the Certificate was not issued in accordance with the S/MIME Baseline Requirements or this CP/CPS;
- emSign determines or is made aware that any of the information appearing in the Certificate is inaccurate;
- emSign's right to issue Certificates under the S/MIME Baseline Requirements expires or is revoked or terminated, unless emSign has made arrangements to continue maintaining the CRL/OCSP Repository;
- Revocation is required by this CP/CPS; or
- emSign is made aware of a demonstrated or proven method that exposes the Subscriber's Private Key to compromise, or there is clear evidence that the specific method used to generate the Private Key was flawed.

In addition, emSign may revoke a Subscriber Certificate where:

- A government or regulatory order requiring revocation is received (where the order means that use of an email address or Domain Name in the Certificate is no longer legally permitted, revocation is mandatory within 5 days under S/MIME BR Section 4.9.1.1(9));
- The Subscriber is added to a denied-party, sanctions or prohibited-persons list;

- For Certificates that assert an organizational affiliation, the Affiliated Organization informs emSign or the RA that it no longer authorizes the affiliation of the Subscriber, in which case the affiliation information in the affected Certificates has materially changed and those Certificates are revoked within 5 days under S/MIME BR Section 4.9.1.1(10) and (12); or an Affiliated Organization terminates its relationship with emSign or the RA such that it no longer provides affiliation information;
- The Certificate Holder is subject to bankruptcy or liquidation, or is deceased;
- The Issuing CA ceases operations or is compromised and has not arranged for another CA to provide revocation support; or
- Not revoking the Certificate would compromise the trust status of the Issuing CA or affiliated systems.

Revocation Reason Options:

- keyCompromise (1): the Subscriber must choose this reason when there is reason to believe that the Private Key of the Certificate has been compromised, e.g. an unauthorized person has had access to it.
- affiliationChanged (3): the Subscriber should choose this reason when the Organization's name or other organizational information in the Certificate has changed.
- superseded (4): the Subscriber should choose this reason when requesting a new Certificate to replace the existing Certificate.
- cessationOfOperation (5): the Subscriber should choose this reason when the Subscriber no longer controls all of the Mailbox Addresses in the Certificate, or will no longer be using the Certificate.
- privilegeWithdrawn (9): the Subscriber should choose this reason when the original Certificate Request was not authorized and authorization is not retroactively granted.

Where a reasonCode CRL entry extension is present it indicates the most appropriate reason for revocation. The CRLReason unspecified (0) is never used; where the reason for revocation is unspecified, emSign omits the reasonCode entry extension. The CRLReason certificateHold (6) is not used (Section 4.9.13).

The Issuing CA SHALL revoke a Subordinate CA Certificate within seven (7) days if one or more of the following occurs:

- The Subordinate CA requests revocation in writing;
- The Subordinate CA notifies the Issuing CA that the original certificate request was not authorized and does not retroactively grant authorization;
- If the Certificate no longer complies with the requirements specified in Sections 6.1.5 and 6.1.6 of the S/MIME Baseline Requirements.

- The Issuing CA obtains evidence that the Subordinate CA's Private Key corresponding to the Public Key in the Certificate suffered a Key Compromise or no longer complies with the requirements of this CP/CPS.
- The Issuing CA obtains evidence that the Certificate was misused;
- The Issuing CA is made aware that the Certificate was not issued in accordance with or that Subordinate CA has not complied with this CP or the applicable Certificate Policy or Certification Practice Statement;
- The Issuing CA determines that any of the information appearing in the Certificate is inaccurate or misleading;
- The Issuing CA or Subordinate CA ceases operations for any reason and has not made arrangements for another CA to provide revocation support for the Certificate;
- The Issuing CA's or Subordinate CA's right to issue Certificates under these Requirements expires or is revoked or terminated, unless the Issuing CA has made arrangements to continue maintaining the CRL/OCSP Repository;
- Revocation is required by the Issuing CA's Certificate Policy and/or Certification Practice Statement;
- The technical content or format of the Certificate presents an unacceptable risk to Application Software Suppliers or Relying Parties (e.g. the CA/Browser Forum might determine that a deprecated cryptographic/signature algorithm or key size presents an unacceptable.)

Note: for the avoidance of doubt, and in accordance with S/MIME BR Section 4.9.1.1, emSign revokes a Subscriber Certificate within 24 hours where the Subscriber so requests in writing, where the Subscriber notifies emSign that the original Certificate Request was not authorised, where emSign obtains evidence of Key Compromise, where a demonstrated method exists to compute the Private Key from the Public Key, or where the validation of domain authorization or mailbox control should not be relied upon; and within 5 days (and should within 24 hours) in the remaining circumstances listed in this Section.

4.9.2 Who Can Request Revocation

A revocation request for an S/MIME certificate may be submitted by the Subscriber, an authorized representative of the Subscriber's organization, or a Registration Authority (RA). The Issuing CA may also revoke a certificate at its discretion, without receiving a formal request, if it determines that revocation is necessary for security or compliance reasons. Additionally, third parties such as security researchers or relying parties may report suspected key compromise, misuse, or other certificaterelated issues using the contact details provided in Sections 1.5.3 and 4.9.12.

4.9.3 Procedure For Revocation Request

Issuing CAs and RAs will revoke a Digital Certificate upon receipt of a valid request and may provide automated mechanisms for requesting and authenticating revocation requests. A revocation request may

be sent by the Certificate Holder or Affiliated Organization through any one or many of the following modes, as may be provided by Issuing CA:

emSign maintains a continuous 24x7 ability to accept and respond to revocation requests and Certificate Problem Reports through the channels listed in Sections 1.5.3 of this CP/CPS.

- Submit the revocation request via the emSign CERTInext platform
- Submit the revocation request via the Issuing CA Support Line
- Issuing CA website
- Contact administrators of Issuing CA or Registration Authority directly

Certificate Holders or Affiliated Organization may use a passphrase or any kind of shared secret or any other form of subscriber authentication mechanism, that will be used to activate the revocation process.

If revocation is requested by someone other than an authorized representative of the Subscriber or Affiliated Organization, the Issuer CA or RA shall investigate the alleged basis for the revocation request and take appropriate action.

4.9.4 Revocation Request Grace Period

The revocation request grace period is the time available to the subscriber within which the subscriber must make a revocation request after reasons for revocation have been identified. Subscribers shall request revocation without delay if the Private Key corresponding to the Certificate is lost or compromised or if the certificate data is no longer valid. emSign revokes within the timeframes of Section 4.9.1, that is, within 24 hours for the circumstances listed there as 24-hour reasons and within 5 days for the remaining circumstances, measured from receipt of the revocation request or Certificate Problem Report.

4.9.5 Time within which CA must process the revocation request

Within 24 hours of receiving a Certificate Problem Report, emSign investigates the facts and circumstances related to the report and provides a preliminary report of its findings to both the Subscriber and the entity that filed the report. emSign then works with the Subscriber and the reporting entity to establish whether the Certificate will be revoked and, if so, the date on which it will be revoked; the period from receipt of the Certificate Problem Report or other revocation-related notice to published revocation never exceeds the time frames of Section 4.9.1. In selecting the revocation date emSign considers: (1) the nature of the alleged problem (scope, context, severity, magnitude, risk of harm); (2) the consequences of revocation (direct and collateral impacts to Subscribers and Relying Parties); (3) the number of Certificate Problem Reports received about the Certificate or Subscriber; (4) the entity making the complaint (a report from a law-enforcement official is addressed with higher priority); and (5) relevant legislation. Revocation requests authenticated under Section 3.4 as originating from the Subscriber are processed within 24 hours.

4.9.6 Revocation Checking Requirement for Relying Parties

Certificate status information is provided through the CRL distribution point and OCSP responder referenced in each Certificate. Relying Parties are required to validate the suitability of the Certificate for the purpose intended and to confirm that the Certificate remains valid at the time of reliance by checking the CRL or OCSP response.

4.9.7 Certificate Revocation List Issuance Frequency

The CRL which provides the status of Subscriber Certificates (Issuing CAs), the CRL shall be:

1. Generated and reissued at least once every seven (7) days and following any revocation.
2. Valid for NOT more than ten (10) days from the date of generation.

For other certificates (Root CA and/or CAs that has Sub CAs), the CRL shall be:

1. Generated at least once every twelve (12) months and within twenty-four (24) hours after revoking a Subordinate CA Certificate.
2. Valid for NOT more than twelve (12) months from the date of generation.

CRLs are published and available via a publicly-accessible HTTP URL in the emSign repository.

4.9.8 Maximum Latency for Certificate Revocation List publication

S/MIME BR Section 4.9.8 makes no stipulation. CRLs are published to the Repository promptly after generation.

4.9.9 On-Line Revocation/Status Checking Availability

emSign operates an OCSP responder for every Issuing CA, available 24 hours a day, 7 days a week, subject to routine maintenance. OCSP responses conform to RFC 6960 and/or RFC 5019.

OCSP responses are signed either by the CA that issued the Certificate whose status is being checked, or by a delegated OCSP Responder whose Certificate is issued by that CA. emSign normally uses delegated OCSP Responder Certificates and does not use an OCSP Responder Certificate issued by any other CA. Each OCSP Responder Certificate contains the id-kp-OCSPSigning extended key usage (1.3.6.1.5.5.7.3.9) and an extension of type id-pkix-ocsp-nocheck (1.3.6.1.5.5.7.48.1.5), as defined in RFC 6960, and asserts the OCSP Certificate policy identifier 1.3.6.1.4.1.50977.1.2.600 listed in Section 1.2.

4.9.10 On-Line Revocation Checking Requirement

Relying Parties shall verify the revocation status of a Certificate through either the Certificate Revocation List (CRL) or the Online Certificate Status Protocol (OCSP) before relying upon the Certificate. Failure to perform such verification may limit the Relying Party's ability to demonstrate reasonable reliance on the Certificate.

The OCSP responder URL is included in the authorityInformationAccess extension of every Subscriber and Subordinate CA Certificate. OCSP responders support the HTTP GET and HTTP POST methods as described in RFC 6960 and RFC 5019. For the status of Subscriber Certificates, OCSP responses have a validity interval of at least eight (8) hours and at most ten (10) days; for responses with a validity interval of less than sixteen (16) hours emSign updates the response before one-half of the validity period has elapsed, and for responses with a validity interval of sixteen (16) hours or more at least eight (8) hours before nextUpdate and no later than four (4) days after thisUpdate. For the status of Subordinate CA Certificates, emSign updates OCSP information at least every twelve (12) months and within twenty-four (24) hours after revoking the Certificate.

An authoritative OCSP response is available for every Certificate from the time of its issuance. The OCSP responder does not return a 'good' status for a Certificate serial number that has not been assigned by the Issuing CA using any of its current or previous keys.

4.9.11 Other Forms of Revocation Advertisements Available

Not applicable.

4.9.12 Special Requirements in Relation to Key Compromise

Where emSign receives a Certificate Problem Report alleging Key Compromise, it investigates and provides a preliminary report of its findings to both the Subscriber and the reporting entity within 24 hours, in accordance with Section 4.9.5. Where emSign otherwise becomes aware of information indicating that a Subscriber Private Key may have been compromised, it notifies the affected Subscriber without undue delay. Such information may include newly discovered vulnerabilities, incident reports, or discretionary assessment based on credible evidence.

A report of suspected Key Compromise should include evidence that allows emSign to verify the compromise, such as:

- a Certificate Signing Request (CSR) or other digital signature created with the affected Private Key – for a CSR, using the Common Name “Proof of Key Compromise for emSign”; or
- evidence that the Public Key belongs to a published weak-key set, a demonstrated method of computing the Private Key, or other credible technical evidence of compromise.

emSign does not require the reporter to transmit the Private Key itself. Supporting information such as vulnerability references, technical descriptions or incident sources is encouraged.

Reports should be submitted via email to the contact listed in Section 1.5.3.1 with the subject line “Certificate Problem Report” and should include the reporter's contact details where available, so that emSign can provide the preliminary report required by Section 4.9.5. Reports that do not identify the reporter are nevertheless investigated.

emSign will review each report in accordance with Section 4.9.3 of this CP/CPS.

4.9.13 Circumstances For Suspension

emSign does not currently offer suspension of Certificates. The CRLReason certificateHold (6) is not used for Strict Generation Certificates in any circumstances (S/MIME BR Section 7.2.2), and is not presently used for Multipurpose Generation Certificates.

4.9.14 Who Can Request Suspension

Not Applicable.

4.9.15 Procedure For Suspension Request

Not Applicable.

4.9.16 Limits On Suspension Period

Not Applicable.

4.10 Certificate Status Services

4.10.1 Operational Characteristics

Issuing CAs shall make Certificate status information available via CRL and/or OCSP. Revocation entries on a CRL or in an OCSP response shall not be removed until after the Expiry Date of the revoked Certificate.

4.10.2 Service Availability

emSign operates and maintains its CRL and OCSP services with resources sufficient to provide a response time of ten (10) seconds or less under normal operating conditions, and maintains an online 24x7 Repository that application software can use to check automatically the current status of all unexpired Certificates issued under this CP/CPS. emSign maintains a continuous 24x7 ability to respond internally to high-priority Certificate Problem Reports and, where appropriate, to forward such reports to law-enforcement authorities and/or revoke the Certificate that is the subject of the report.

4.10.3 Optional Features

No stipulation.

4.11 End Of Subscription

A Subscriber's subscription to emSign PKI services shall be considered ended under the following circumstances:

- The Subscriber allows all S/MIME Certificates issued by emSign to expire without requesting renewal or re-key;
- The Subscriber requests revocation of all valid Certificates without applying for replacement;

- The Subscriber Agreement between emSign and the Subscriber is terminated or expires without renewal;
- emSign or the relevant Issuing CA ceases operations impacting the service;
- emSign revokes all Certificates issued to the Subscriber due to non-compliance with the CP/CPS or applicable policies and agreements.

The end of subscription does not absolve the Subscriber from responsibilities accrued prior to termination, including the continued obligation to prevent misuse of any previously issued Certificates.

4.12 Key escrow and recovery

emSign PKI does not support private key escrow for general-purpose S/MIME subscriber certificates. However, under the CERTInext brand, emSign PKI may optionally offer automation services which necessitates S/MIME subscriber private keys to be temporarily escrowed under certain use cases, to enterprise customers, based on explicit agreement. In such cases, CERTInext acts as the escrow agent and stores the Subscriber Private Key in securely encrypted form to facilitate the automation. The process is strictly limited to the enterprise requesting the automation services. Recovery of an escrowed Private Key is logged and handled as described in Section 6.2.3.

4.12.1 Key escrow and recovery policy and practices

Key recovery is only applicable to enterprise S/MIME encryption certificates issued under CERTInext where key escrow has been contractually agreed. Recovery may be initiated only under the following conditions:

- The Private Key has been lost or corrupted.
- The Subscriber organization is no longer operational or is otherwise unavailable.
- A competent legal or governmental authority mandates key recovery.
- Recovery is deemed critical by the Subscriber organization under contractual terms. Only duly authorized administrators of the enterprise account may initiate recovery. All escrowed keys remain encrypted and are protected against unauthorized access. No escrow or recovery is permitted for S/MIME certificates outside of such explicitly approved enterprise agreements, and recovery is never performed for a Private Key whose corresponding Certificate asserts only digitalSignature / nonRepudiation key usage.

An entity receiving Private Key escrow services shall:

- Notify Subscribers that their Private Keys are escrowed,
- Protect escrowed keys from unauthorized disclosure,
- Protect any authentication mechanisms that could be used to recover escrowed Private Keys,

- Release escrowed keys only for properly authenticated and authorized requests for recovery, and Comply with any legal obligations to disclose or keep confidential escrowed keys, escrowed key-related information, or the facts concerning any key recovery request or process.

4.12.2 Session Key Encapsulation and Recovery Policy and Practices

No Stipulation.

5 Facility, Management, And Operational Controls

5.1 Physical Controls

All Issuing CAs of emSign PKI shall implement appropriate physical controls for the following:

1. Physical access control to the hardware used in connection with CA operations.
2. Physical access control over the relevant software.
3. Fire safety protection
4. Protection against failure of supporting utilities like power, telecommunications, etc.
5. Protection against theft.
6. Disaster recovery procedures.

5.1.1 Site Location and construction

All Issuing CAs of emSign PKI shall perform their CA operations from a secure datacenter with the following features:

1. The datacenter shall be equipped with physical and logical controls that makes the CA operations inaccessible to unauthorised persons.
2. The datacenter shall be a facility made of concrete and steel construction.
3. The datacenter shall have security protection mechanisms such as guards, door locks.
4. The datacenter shall be with raised floor construction and an array of resilient security and environmental systems.

For S/MIME Issuing CAs operated in colocation environments, physical access to the racks, HSMs, and related CA infrastructure is fully controlled and managed exclusively by emSign personnel. These systems are physically isolated and are not accessible to the datacenter provider or other tenants.

5.1.2 Physical Access

All Issuing CAs of emSign PKI's systems are located in a secure datacenter. Entry into this secure facility is allowed only to security-cleared and authorised personnel, whose movements within the facility are

logged and audited. Physical access to this facility is also video recorded on a 24/7 basis. Further physical access to this facility is monitored 24/7 by onsite security personnel.

5.1.3 Power and Air-Conditioning

The supply of power to All Issuing CAs of emSign PKI systems are protected with dual power feeds through the use of Uninterrupted Power Supply (UPS) systems and generators in order to prevent abnormal shutdown in the event of a power failure.

Climate control systems have been implemented to ensure that the temperature within all Issuing CAs of emSign PKI facility is maintained within reasonable operating limits

5.1.4 Water Exposures

The facility is located outside any flood prone area. Further, it is located on an upper floor with raised flooring, which provide protection against water exposures. Further the outside walls are also sealed to provide protection from water exposure.

5.1.5 Fire Prevention and Protection

The datacenter is equipped with smoke detection system. It is also equipped with necessary Fire Suppression system (FM200) and Very Early Smoke Detection Appliance (VESDA) for fire protection.

5.1.6 Media Storage

All magnetic media containing emSign PKI information, including backup media, are stored in containers, cabinets or safes with fire protection capabilities. Further they are located either within the emSign PKI service operations area or in a secure off-site storage area and are protected from any unauthorised physical access.

5.1.7 Waste Disposal

All Issuing CAs of emSign PKI shall dispose of commercially sensitive or confidential information as under:

- In case of paper or other printed material containing such information, it shall be shredded or destroyed in a generally accepted procedure.
- In case of magnetic media containing trusted elements of CA or commercially sensitive or confidential information it shall be securely disposed of by physical damage to, or complete destruction of, the asset or by use of an approved utility to wipe or overwrite the magnetic media;

5.1.8 Off-Site Backup

An off-site location is used for the storage and retention of backup software and data.

The off-site storage:

- is available to authorised personnel 24 hours per day seven days per week for the purpose of retrieving software and data; and

- has appropriate levels of physical security in place
- Are stored in fire-rated safes and containers.

5.2 Procedural Controls

All Issuing CAs of emSign PKI shall ensure that they adhere to all Administrative processes and procedures as detailed in this CP/CPS and as dealt with and described in detail in the various documents used within and supporting the emSign PKI.

5.2.1 Trusted Roles

Trusted roles are created in the emSign PKI system in order to ensure that one person acting alone cannot circumvent security safeguards implemented in the CA system. To ensure this the responsibilities are shared by multiple roles and individuals. This is accomplished by creating separate roles and accounts on various components of the CA system, and each role has a limited amount of capability. This method allows a system of "checks and balances" to occur among the various roles.

The trusted roles within the emSign PKI system defined includes various roles like Admin Officer, Audit Officer, Registration Officer, Security Officer, Systems Officer, etc. These are defined in detail along with their responsibilities as part of internal policy documents and may be confidential in nature.

5.2.2 Number of Persons Required Per Task

emSign maintains sufficient trusted personnel that no single individual can circumvent the security safeguards of the CA system, and that dual control is available for every task requiring it. CA Private Keys are backed up, stored and recovered only by personnel in Trusted Roles under at least dual control in a physically secured environment. Each Issuer CA shall require that at least two people acting in a trusted role take action requiring a trusted role, such as activating the Issuer CA's Private Keys, generating a CA Key Pair, or creating a backup of a CA Private Key. Such sensitive operations also require active participation and oversight of senior management.

Issuing CAs will utilize commercially reasonable practices to ensure that one person acting alone cannot circumvent safeguards. Issuing CAs shall use commercially reasonable efforts to identify a separate individual for each trusted role. Issuing CAs must ensure that no single individual may gain access to any Private Key (other than the individual's own Private Key).

5.2.3 Identification and Authentication for Each Role

All Issuing CAs of emSign PKI shall perform appropriate security screening procedure including background check before appointing a person to the trusted role. Each role described here are identified and authenticated in a manner to guarantee that the right person has the right role to support the CA.

5.2.4 Roles Requiring Separation of Duties

Issuing CAs shall enforce role separation for each of the roles and Individual trusted-personnel shall be specifically designated to the roles Identified & defined in this CP/CPS and/or as part of CA's Operating procedures.

emSign assigns roles so that no individual simultaneously performs two roles whose combination would defeat separation of duties for a given task.

5.3 Personnel Controls

All Issuing CAs of emSign PKI shall conduct appropriate background checks on all persons selected to take up a trusted role in accordance with the designated security screening procedure, prior to the commencement of their duties. CA shall determine the nature and extent of any background checks, in its sole discretion.

emSign remains fully responsible to Certificate Beneficiaries and Application Software Suppliers for the performance of all CA functions carried out by its employees, agents and contractors in Trusted Roles, in accordance with Section 9.8 and the S/MIME Baseline Requirements, irrespective of whether a particular act was authorised. Nothing in this Section limits that responsibility; the consequences of unauthorised conduct for the individual concerned are governed by emSign's employment and contractual terms and by Section 5.3.6.

All employees, agents or independent contractors performing trusted roles, shall be bound by these personnel controls' requirements.

5.3.1 Qualifications, Experience, and Clearance Requirements

All Issuing CAs of emSign PKI requires that personnel meet a certain minimum standard with regards to background, Qualifications, Experience, and clearance requirements for each trusted role. Selection of personnel are made against these criteria.

5.3.2 Background Check Procedures

Background check procedures may include but are not limited to checks and confirmation of:

- Previous employment
- Professional references
- Educational qualifications
- Identity Verification
- Other relevant government records (e.g. national identifiers, etc.)

Where the checks and confirmations cannot be obtained due to a prohibition or limitation of law or other circumstances, All Issuing CAs of emSign PKI will utilize available substitute investigation techniques that

provide similar information, including background checks performed by applicable Government and/or Private agencies.

5.3.3 Training Requirements

All Issuing CAs of emSign PKI shall provide its personnel with on the job training covering the following areas to the extent relevant for the role of the concerned personnel.

- Basic PKI concepts
- This S/MIME CP/CPS
- Documented emSign PKI security and operational policies and procedures
- The use and operation of PKI system software.
- Common threats to the validation process including phishing and other social engineering

Tactics

- CA/Browser Forum Guidelines.

emSign maintains records of all training provided and ensures that personnel entrusted with Validation Specialist duties maintain a skill level enabling them to perform those duties satisfactorily. emSign documents that each Validation Specialist possesses the skills required by a task before allowing that Validation Specialist to perform the task, and requires all Validation Specialists to pass an examination provided by emSign on the information verification requirements of the S/MIME Baseline Requirements (including the TLS Baseline Requirements Section 3.2.2.4 methods used under Section 3.2.2(a) and (c)).

5.3.4 Retraining Frequency and Requirements

Whenever there is any change in the Issuer CA's or RA's operations appropriate training is provided to the individuals acting in trusted roles so that they are aware of the changes. Apart from this a general yearly training update is provided to all personnel on related topics

5.3.5 Job Rotation Frequency and Sequence

No Stipulation.

5.3.6 Sanctions for Unauthorised Actions

Appropriate disciplinary actions will be taken for unauthorised actions by any of the personnel, including potential termination of employment and criminal actions.

5.3.7 Independent Contractor Requirements

All Issuing CAs of emSign PKI may employ independent contractors as may be necessary. When independent contractors are employed they will be subjected to the same process, procedures and controls as prescribed in this CP/CPS and other related documents.

5.3.8 Documentation Supplied to Personnel

All Issuing CAs of emSign PKI provides personnel in trusted roles with the documentation necessary to perform their roles including this CP/CPS.

5.4 Audit Logging Procedures

5.4.1 Types Of Events Recorded

Audit log shall be maintained for:

1. CA & Certificate Lifecycle Management Events:
    a. Generation, certification, backup, recovery and/or destruction of the CA Key Pairs are recorded. This includes all configuration data used in the process.
    b. Successful and unsuccessful Certificate applications, Certificate issuances, Certificate re-issuances and Certificate renewals for Subscriber Certificates. Also, the revocation requests for Subscriber Certificate including revocation reason
    c. Generations and issuances of CRLs.
    d. Custody of keys, devices and media holding keys
    e. Compromise of a Private Key
2. Security Related Events:
    a. Firewall and router activities
    b. Any downtime in system, software crashes and hardware failures.
    c. CA system actions performed by trusted personnel, including software updates, hardware replacements and upgrades.
    d. Successful and unsuccessful PKI system access attempts
    e. Cryptographic hardware security module events, such as usage, de-installation, service or repair and retirement
    f. CA facility entry/exit
    g. Each movement of the removable media
3. Certificate Application Information:
    a. All documentation & related information provided by the Applicant for application validation process
    b. Physical and/or electronic storage locations of applicant provided documents

In accordance with S/MIME BR Section 5.4.1 the recorded events also include: (i) for CA Certificate and key lifecycle – approval and rejection of Certificate Requests, cryptographic device lifecycle management events, signing of OCSP responses, and the introduction of new and retirement of existing Certificate Profiles; (ii) for Subscriber Certificate lifecycle – all verification activities performed under Section 3.2 and

this CP/CPS, approval and rejection of Certificate Requests, issuance, renewal, re-key and revocation, generation of CRLs and signing of OCSP responses; and (iii) security events – successful and unsuccessful PKI system access attempts, PKI and security system actions performed, security profile changes, installation, update and removal of software on Certificate Systems, system crashes, hardware failures and other anomalies, entries to and exits from the CA facility, and router and firewall activity comprising successful and unsuccessful login attempts, all administrative actions (configuration changes, firmware updates and access-control modifications), all changes to firewall rules and all system events and errors (S/MIME BR 5.4.1.1).

All logs include the following elements:

- Date and time of entry
- Sequence number of entry
- Description of the entry
- Identity of person/device making log entry

The Audit log files for all events relating to the security and services of the Issuing CA shall be generated and maintained. Where possible, the security audit logs shall be automatically generated. Where this is not possible, a logbook in paper form, or other physical mechanism shall be used. Security audit logs of all events as above shall be retained and made available during compliance audits.

The access to the systems are either protected by PIN protected Crypto Tokens or in the form of username - password as may be required by specific system or software or database. The administrative passwords in such cases are ensured to be split, so that minimum of two person will be required to perform critical / administrative activity.

5.4.2 Frequency Of Processing Log

Audit logs shall be verified at least monthly to see for any evidence of malicious activity.

5.4.3 Retention Period For Audit Log

The retention period for audit logs, as mentioned in Section 5.4.1, and applicable to all Issuing CAs of the emSign PKI, shall be as follows:

1. Logs of CA key management activity minimum 2 years
2. CA system logs of certificate management activity minimum 2 years
3. Operating system logs minimum 2 years
4. Physical access system logs minimum 2 years
5. Manual logs of physical access minimum 2 years
6. Video recording of CA facility accesses 90 days

In all cases, and in accordance with S/MIME BR Section 5.4.3, emSign retains (1) CA Certificate and key lifecycle event records for at least two (2) years after the later of the destruction of the CA Private Key or

the revocation or expiration of the final CA Certificate that shares that key; (2) Subscriber Certificate lifecycle event records for at least two (2) years after the expiration of the Subscriber Certificate; and (3) security event records for at least two (2) years after the event occurred.

5.4.4 Protection Of Audit Log

In all Issuing CAs of emSign PKI, Audit logs are protected using a combination of physical and logical access controls. The events are logged in a way that they cannot be deleted or destroyed for any period of time that they are retained. The events are logged in a manner to ensure that only individuals with authorized trusted access are able to perform any operations based on their profile without modifying integrity, authenticity and confidentiality of the data.

The records of events are protected in a manner to prevent alteration and detect tampering.

5.4.5 Audit Log Backup Procedures

All Issuing CAs of emSign PKI shall do onsite back up of the system generated audit logs on a daily basis. At least on a monthly basis all audit logs and audit summaries shall be backed-up in a secure off site location. These shall be under the control of an authorized trusted role. Audit log backup should be protected to the same degree as originals.

5.4.6 Audit collection system (internal vs. external)

The security audit process of each Issuing CA must be initiated at system start up and may finish only at system shutdown. The audit collection system should ensure the integrity and availability of the data collected. If necessary, the audit collection system should protect the data confidentiality. In the case of a problem occurring during the process of the audit collection the Issuing CAs must determine whether to suspend Issuing CA operations until the problem is remedied.

Automated audit data is generated and recorded at the application, network, and operating system level. Manually generated audit data is recorded by the trusted-personnel.

5.4.7 Notification To Event-Causing Subject

No stipulation.

5.4.8 Vulnerability Assessment

All Issuing CAs of emSign PKI shall perform regular vulnerability assessments. Such vulnerability assessments should focus on internal and external threats that could result in unauthorized access, tampering, modification, alteration or destruction of the Certificate issuance process.

The Vulnerability Assessments shall also include application scanning, as well as Penetration Testing. Any negative results out of such reports shall be put under corrective actions for such negative result. No common security vulnerabilities shall exist on public facing websites, hosted in the network.

The results of such vulnerability assessment tests shall be used to enhance the security of the environment.

emSign's security program includes an annual Risk Assessment that (1) identifies foreseeable internal and external threats that could result in unauthorised access, disclosure, misuse, alteration or destruction of any Certificate Data or Certificate Management Processes; (2) assesses the likelihood and potential damage of those threats, taking into consideration the sensitivity of the Certificate Data and Certificate Management Processes; and (3) assesses the sufficiency of the policies, procedures, information systems, technology and other arrangements that emSign has in place to counter such threats. In accordance with the Network and Certificate System Security Requirements, vulnerability scans of Certificate Systems are performed at least quarterly and after any significant change, penetration tests at least annually and after significant infrastructure or application changes, and findings are remediated within the time frames of Section 6.7.1.

5.5 Records Archival

All Issuing CAs of emSign PKI shall maintain an archive of the relevant records as per the record retention policies set forth in this CP/CPS and any record retention policies that apply by law. The CA shall include sufficient detail in archived records to show that a Certificate was issued in accordance with the CP/CPS.

5.5.1 Types Of Records Archived

All Issuing CAs of emSign PKI archives records that will include all relevant evidence in the Issuing CA's possession including:

- Audit logs;
- Digital Certificate requests and all related actions;
- Contents of issued Digital Certificates;
- Evidence of Digital Certificate acceptance and signed (electronically or otherwise) Certificate Holder Agreements;
- Revocation requests and all related actions;
- Archive and retrieval requests;
- Digital Certificate Revocation Lists posted;
- Audit Opinions as discussed in this emSign PKI CP/CPS; and

For each Digital Certificate, the records contain information related to creation, issuance, intended use, revocation and expiration. Upon authorized request, the CA makes available, documentation related to each Digital Certificate subject to the emSign PKI Document Access Policy.

5.5.2 Retention Period For Archive

Archived audit logs are retained for at least two (2) years from their record creation timestamp, or for as long as Section 5.4.3 requires, whichever is longer. Documentation relating to the security of Certificate

Systems, Certificate Management Systems, Root CA Systems and Delegated Third Party Systems is retained for at least two (2) years. Documentation relating to the verification, issuance and revocation of Certificate Requests and Certificates is retained for at least two (2) years after the later of the date on which it was last relied upon in a verification, issuance or revocation and the expiration of the Subscriber Certificates relying upon it.

5.5.3 Protection Of Archive

All Issuing CAs of emSign PKI archives and protects audit logs in accordance the audit log protection policy described in this CP/CPS.

5.5.4 Archive Backup Procedures

All Issuing CAs of emSign PKI maintains and implements backup procedures so that backup copies of the archived records are stored in a separate location so that in the event of the loss or destruction of the primary archives a complete set of backup copies is readily available.

5.5.5 Requirements For Time-Stamping Of Records

All Issuing CAs of emSign PKI shall automatically timestamp its records as they are created. All events that are recorded within the emSign PKI include the date and time of when the event took place. This date and time are based on the system time on which the CA system is operating. emSign PKI uses procedures to review and ensure that all systems operating within the emSign PKI rely on a trusted time source.

5.5.6 Archive collection system (internal or external)

emSign PKI's Archive Collection System is internal.

5.5.7 Procedures To Obtain And Verify Archive Information

Only specific Trusted Roles and auditors may view the archives in whole. The Issuer CA may allow Subscribers to obtain a copy of their archived information. The contents of the archives will not be released, except as required by law.

5.6 Key Changeover

To enable smooth transition of expiring CA certificates, new CA Private key shall be certified towards the end of old certificate expiry date. The new CA private key and certificate will be commissioned and used for issuing new subscriber certificates henceforth.

In this case, both old and new CA private keys may be concurrently active.

Old CA Private Keys used to sign previous Subscriber Certificates are maintained till such time that all Subscriber Certificates underneath that gets expired. Until then, the old private key will be used for purposes including CRL and OCSP.

5.7 Compromise And Disaster Recovery

5.7.1 Incident and compromise handling procedures

emSign maintains an Incident Response Plan and a Business Continuity and Disaster Recovery Plan designed to notify and reasonably protect Application Software Suppliers, Subscribers and Relying Parties in the event of a disaster, security compromise or business failure, and to provide for the resumption of revocation services as quickly as practicable. The Business Continuity Plan includes: the conditions for activating the plan; emergency procedures; fallback procedures; resumption procedures; a maintenance schedule for the plan; awareness and education requirements; the responsibilities of the individuals involved; the recovery time objective (RTO); regular testing of contingency plans; emSign's plan to maintain or restore business operations in a timely manner following interruption to or failure of critical business processes; a requirement to store critical cryptographic materials (secure cryptographic devices and activation materials) at an alternate location; what constitutes an acceptable system outage and recovery time; how frequently backup copies of essential business information and software are taken; the distance of the recovery facilities from emSign's main site; and procedures for securing the facility to the extent possible following a disaster and prior to restoring a secure environment at the original or a remote site.

The plans are proprietary, security-sensitive and confidential and are not published, but are made available to emSign's Qualified Auditor on request and are tested, reviewed and updated at least annually.

All Issuing CAs under emSign PKI have in place an appropriate Key compromise plan detailing the activities taken in the event of a compromise of an emSign Issuing CA Private Key. Such plans include procedures for:

- Revoking all Digital Certificates signed with that emSign Issuing CA’s Private Key;
- Notifying emSign Issuing CA and all of the Holders of Digital Certificates issued by that emSign PKI’s Issuing CA.

5.7.1.1 Mass Revocation Plan

emSign maintains a documented Mass Revocation Plan to manage large-scale certificate revocation events, such as widespread mis issuance or compromise. This plan is reviewed, tested, and updated at least annually and is integrated into emSign’s overall business continuity and incident response frameworks. It outlines clear roles and responsibilities for executing revocation actions, including notification to affected Subscribers, revocation timelines, and post-revocation validation.

The plan ensures rapid response while minimizing disruption to relying parties. Revocation actions are initiated in accordance with emSign’s incident handling procedures and under the supervision of the emSign Policy Authority. Communication protocols include timely updates through appropriate channels and coordination with root programs and ecosystem stakeholders as required.

5.7.2 Computing resources, software, and/or data are corrupted

Any compromise detected on emSign PKI's computing resources, software, or data operations, it shall be investigated to the extent of the compromise and the risk presented to affected parties. Depending on the extent of the compromise, if it is determined that a continued operation could pose a significant risk to Relying Parties or Subscribers, such operation shall be suspended until it is ensured that the risk is mitigated.

5.7.3 Entity private key compromise procedures

The CA Private Keys are classified as highly critical to the business operations and continuity. If any of the CA's private signing keys were compromised or were suspected of having been compromised, an assessment shall be made to determine the nature and extent of the compromise. In the most severe circumstances, all Certificates ever issued by the use of those keys shall be revoked and a notification shall be sent to all owners of Certificates of that revocation, and offer to re-issue the Certificates to the customers with an alternative /new key.

5.7.4 Business continuity capabilities after a disaster

emSign PKI's Business Continuity Plan shall provide for a minimum of:

- Private Key compromise procedures as well as Public Key Revocation procedures.
- Incident & compromise handling procedures.
- Software, Computing resources and/or Corrupted data handling procedures.
- Business continuity capabilities and procedures after a disaster.

The stated goals of this plan shall ensure that certificate status services be only minimally affected by any disaster involving CA facility and that it shall be capable of maintaining other services or resuming them as quickly as possible following a disaster. The business continuity plans are made available to the auditors and audited during defined audit cycles. These are also subjected to annual test, review, and update of the procedures.

5.8 CA or RA termination

When it is necessary to terminate an Issuing CA or Registration Authority service, emSign PKI shall:

- Provide notice & information about the termination by sending notice by email to its customers, Vendors, cross-certifiers (if any), and any other applicable entities.
- By posting such information on the web site
- Minimize any disruption caused by the termination of an Issuing CA
- Take care of retention of archived records of the Issuing CA
- Check and transfer all responsibilities to a qualified successor entity.

All CAs under emSign PKI specify the procedures they will follow when terminating all or a portion of their Digital Certificate issuance and management operations.

The successor CA should assume the same obligations, duties and rights of terminating CA, and issue new keys / certificates to all users whose keys / certificates were revoked by terminating CA. Such new certificate issuance shall comply by, user making an application and meeting the requirements of identification & authentication requirements as well as Subscriber agreement of new issuing CA.

Where practical, Key / Digital Certificate revocation shall be timed to coincide with the progressive & planned rollout of new Keys and Digital Certificates by a successor Issuing CA.

6 Technical Security Controls

emSign Certification Authority has put in place sufficient security controls to protect the private keys and access to various modules within the Certifying Authority environment.

The Issuing CA Private Keys are stored securely in a Hardware Security Module validated as meeting at least FIPS 140-2 Level 3, FIPS 140-3 Level 3, or an appropriate Common Criteria Protection Profile or Security Target at EAL 4 or higher. Access to systems/module within the Certification Authority environment are restricted using tokens or smartcards and associated pass phrases in such a manner that no single member holds total control over any component of the system. The Hardware Security Modules are always stored in a physically secure environment that is subject to security control.

6.1 Key Pair Generation and Installation

6.1.1 Key Pair Generation

Issuing CA key pairs are generated in a secure manner as part of a key ceremony in a physically trusted environment by trusted personnel. Issuing CA key generation is carried out in a cryptographic module validated as meeting at least FIPS 140-2 Level 3, FIPS 140-3 Level 3, or an appropriate Common Criteria Protection Profile or Security Target at EAL 4 or higher.

emSign generates every CA Key Pair in a physically secured environment. Key generation is carried out by personnel in Trusted Roles, under multiple person control and split knowledge, inside cryptographic modules that meet the requirements set out in this CP/CPS. emSign logs all CA Key Pair generation activities and maintains controls that give reasonable assurance the Private Key was generated and protected in line with this CP/CPS and, where one applies, the Key Generation Script.

Additional controls apply to the following CA Key Pairs:

- a Key Pair for a Root CA Certificate; or
- a Key Pair for a Subordinate CA Certificate, where the Subordinate CA is not the operator of the Root CA and is not an Affiliate of the Root CA.

For these Key Pairs, emSign also:

1. prepares a written Key Generation Script and follows it during the ceremony;
2. arranges for a Qualified Auditor either to witness the key generation in person or to record the entire process on video; and
3. obtains a report from the Qualified Auditor confirming that emSign followed its key ceremony during key and certificate generation, and assessing the controls used to protect the integrity and confidentiality of the Key Pair

Subscriber key pairs:

1. Subscriber key pairs are generally generated by the Subscriber using secure methods (software or hardware) prior to submitting a Certificate Signing Request (CSR).
2. For S/MIME Certificates, key generation normally occurs within the Subscriber's mail client, browser, operating-system key store or hardware token. Where an Enterprise Subscriber uses the CERTInext key-escrow service, encryption Key Pairs may be generated centrally under the controls of Section 6.1.2.

Issuing CA SHALL reject a certificate request if one or more of the following conditions are met:

1. The Key Pair does not meet the requirements set forth in Section 6.1.5 and/or Section 6.1.6;
2. There is clear evidence that the specific method used to generate the Private Key was flawed;
3. Issuing CA is aware of a demonstrated or proven method that exposes the Applicant's Private Key to compromise;
4. Issuing CA has previously been made aware that the Applicant's Private Key has suffered a Key Compromise, such as through the provisions of Section 4.9.1; or
5. Issuing CA is aware of a demonstrated or proven method to easily compute the Applicant's Private Key based on the Public Key (such as a Debian weak key, see https://wiki.debian.org/SSLkeys).
    a) In the case of Debian weak keys vulnerability (https://wiki.debian.org/SSLkeys), the Issuer CA shall reject all keys found at https://github.com/cabforum/Debianweakkeys/ for each key type (e.g. RSA, ECDSA).
    b) In the case of ROCA vulnerability, the Issuer CA shall reject keys identified by the tools available at https://github.com/crocs-muni/roca or equivalent.

In the case of Close Primes vulnerability (https://fermatattack.secvuln.info/), the Issuer CA shall reject weak keys which can be factored within 100 rounds using Fermat's factorization method.

6.1.2 Private Key Delivery to Certificate Holder

Subscriber Key Pairs are normally generated by the Subscriber, who is solely responsible for protecting the Private Key. emSign or a Delegated Third Party generates a Private Key on behalf of a Subscriber only where an Enterprise Subscriber has contracted the CERTInext key-escrow service described in Section 4.12, and then only for encryption Key Pairs. In that case the entity generating the Private Key either (1)

transports the Private Key in hardware with an activation method equivalent to 128 bits of encryption, the activation material being delivered to the Subscriber securely and separately from the container holding the Private Key, or (2) encrypts the Private Key with at least 112 bits of encryption strength – for example AES-128 key wrapping, or a PKCS#12 file protected by a password and algorithm whose combination provides at least 112 bits of encryption strength, delivered over a TLS-protected or otherwise authenticated and encrypted channel. Subscriber Private Keys are never stored in clear text. Parties other than the Subscriber do not archive a Subscriber Private Key without the Subscriber's authorisation. If emSign or any of its RAs becomes aware that a Subscriber's Private Key has been communicated to a person or organization not authorised by the Subscriber, emSign revokes all Certificates that include the corresponding Public Key.

6.1.3 Public Key Delivery to Certificate Issuer

For S/MIME Certificates, the Subscriber delivers the public key to the Issuing CA as part of a Certificate Signing Request (CSR). The CSR must be delivered over a secure channel and contain a valid digital signature that demonstrates the Subscriber’s possession of the corresponding private key. The Issuing CA ensures the integrity of the public key during transmission and verifies that it corresponds to the Subscriber's verified identity before certificate issuance.

6.1.4 Certification Authority Public Key to Relying Parties

All Issuing CAs of emSign PKI shall ensure that Public Key delivery to Relying Parties is done in a secure manner to serve as a trust anchor in commercial browsers and operating system root stores, or may be specified in a Certificate validation or path discovery policy file. CA may deliver its Public Key certificate through its repository available on emSign or Issuer website.

6.1.5 Key Sizes

Within the emSign PKI, key algorithms and lengths for S/MIME Certificates are defined by the applicable certificate profile and comply with Sections 6.1.5, 6.1.6 and 7.1.3 of the S/MIME Baseline Requirements. emSign currently issues Certificates only for the key types listed below.

For S/MIME Subscriber Certificates:

- RSA keys MUST have a modulus of at least 2048 bits whose length in bits is evenly divisible by 8.
- ECDSA keys MUST represent a valid point on the NIST P-256, NIST P-384 or NIST P-521 elliptic curve.

For S/MIME CA Certificates (Root, Subordinate and Cross Certificates):

- RSA keys MUST have a modulus of at least 4096 bits, evenly divisible by 8, for CA Certificates signed on or after 15 September 2026 (S/MIME BR 6.1.5); emSign Root and Subordinate CA RSA keys are 4096 bits or longer as shown in Appendix B. From 15 September 2027 emSign does not issue any S/MIME Subscriber Certificate from a CA whose RSA key modulus is shorter than 3072 bits.

- ECDSA keys MUST represent a valid point on the NIST P-256, NIST P-384 or NIST P-521 elliptic curve.

emSign does not currently issue Certificates for EdDSA (Curve25519 / Curve448), ML-DSA or ML-KEM keys. Should it do so, the key sizes, algorithm identifiers and encodings of S/MIME BR Sections 6.1.5 and 7.1.3 will be followed and this CP/CPS will be updated first.

The Issuing CA SHALL ensure that all key lengths and algorithms are compliant with current Baseline Requirements and are sufficient to protect against known cryptographic attacks.

Following points shall be noted on Hash algorithms:

All signature algorithms are used in conjunction with SHA-256 or a stronger hash. emSign does not sign any Certificate or CRL using a signature algorithm that incorporates SHA-1. In accordance with S/MIME BR Sections 7.1.3.1.1 and 1.2.1 (Ballot SMC016), any unexpired Subordinate CA Certificate whose signature algorithm incorporated SHA-1 was revoked before 15 September 2026; as at the date of this CP/CPS no such Certificate remains unexpired and unrevoked within the emSign S/MIME hierarchies.

AlgorithmIdentifier encodings for subjectPublicKeyInfo and for signatures are byte-for-byte identical to the encodings mandated in S/MIME BR Sections 7.1.3.1 and 7.1.3.2. RSA keys are indicated using rsaEncryption (1.2.840.113549.1.1.1) with an explicit NULL parameter; the id-RSASSA-PSS algorithm identifier is not used to indicate an RSA key.

MD5 is not used for any purpose. SHA-1 is not used in any signature algorithm (see the sunset statement above); it appears only in the derivation of subjectKeyIdentifier and authorityKeyIdentifier values as permitted by RFC 5280 Section 4.2.1.2, which is not a security-relevant use.

6.1.6 Public Key Parameters Generation And Quality Checking

All CA keys are generated on cryptographic modules validated as meeting at least FIPS 140-2 Level 3, FIPS 140-3 Level 3, or an appropriate Common Criteria Protection Profile or Security Target at EAL 4 or higher, and meet the requirements of FIPS 186-4, which ensures proper parameter generation and quality for Public Keys.

For RSA Subscriber keys emSign confirms that the public exponent is an odd number equal to 3 or more (and in the range 2^16+1 to 2^256−1), and that the modulus is an odd number, is not the power of a prime and has no factors smaller than 752 (NIST SP 800-89 Section 5.3.3). For ECDSA keys emSign confirms validity using the ECC Partial or Full Public Key Validation Routine of NIST SP 800-56A. Known weak keys (Section 6.1.1) are tested for and rejected at the point of submission.

6.1.7 Key Usage Purposes (As Per X.509 V3 Key Usage Field)

Root CA and Subordinate CA Certificates assert the keyCertSign and cRLSign key usages; the digitalSignature bit is additionally set only where the CA Private Key directly signs OCSP responses (S/MIME BR 7.1.2.1(b) and 7.1.2.2(e)). Root CA Private Keys are used only to sign the self-signed Root

Certificate, Subordinate CA and Cross Certificates, certificates for infrastructure purposes and OCSP Responder Certificates (S/MIME BR 6.1.7).

For S/MIME Subscriber Certificates the keyUsage extension is marked critical and is populated in accordance with S/MIME BR Section 7.1.2.3(e) according to the intended use of the key: for RSA keys, digitalSignature for signing-only Certificates, keyEncipherment for key-management-only Certificates, or both for dual-use Certificates, with nonRepudiation optional and, in Multipurpose Generation Certificates, dataEncipherment optional for key-management-only and dual-use Certificates; for ECDSA keys, digitalSignature for signing-only Certificates, keyAgreement for key-management-only Certificates, or both for dual-use Certificates, with nonRepudiation optional and encipherOnly or decipherOnly optional only where keyAgreement is set. No other key usage bits are set.

The extKeyUsage extension of every S/MIME Subscriber Certificate contains id-kp-emailProtection (1.3.6.1.5.5.7.3.4). In Strict Generation Certificates no other KeyPurposeId is present. In Multipurpose Generation Certificates id-kp-clientAuth (1.3.6.1.5.5.7.3.2) MAY additionally be present. id-kp-serverAuth, id-kp-codeSigning, id-kp-timeStamping and anyExtendedKeyUsage are never present.

The specific key usages and extended key usages for each certificate type are defined in the Certificate Profiles section of this CP/CPS.

6.2 Private Key Protection And Cryptographic Module Engineering Controls

Issuing CA, RA, Subscribers and other participates are required to take appropriate and adequate steps to protect Private Keys in line with the requirements of this CP/CPS.

This includes:

- Securing their Private Key
- Taking necessary precautions to prevent loss, damage, disclosure, alteration or unauthorized access or use of their Private Key
- Exercise sole and complete control and use of the Private Key

6.2.1 Cryptographic Module Standards and Controls

All CA Private Keys under emSign PKI must be generated and maintained in a Hardware Security Module validated as meeting at least FIPS 140-2 Level 3, FIPS 140-3 Level 3, or an appropriate Common Criteria Protection Profile or Security Target at EAL 4 or higher.

6.2.2 Private key (n out of m) multi-person control

All Issuer CA Private Keys are accessed / activated in CA System through n-of-m multiple trusted person control including for any Private Key backups.

6.2.3 Private Key Escrow

CA Private Keys are never escrowed. Subscriber Private Keys are escrowed only under the CERTInext enterprise key-escrow service described in Section 4.12: encryption Key Pairs only, stored in encrypted form, with the Subscriber notified that the key is escrowed, and recovered only in the circumstances listed in Section 4.12.1. Recovery of an escrowed Private Key by a party other than the Subscriber is logged, notified to the Subscriber, and assessed under Section 4.9.1; emSign revokes the corresponding Certificate where the recovery constitutes or indicates a Key Compromise. Recovery by or at the direction of the Subscriber does not of itself require revocation.

6.2.4 Private Key Backup

Issuing CAs under emSign PKI may backup their Private Keys using a secure cryptographic device and store the Private Keys in an encrypted state if private keys are stored outside the cryptographic module.

Subscribers may choose to backup up their Private Keys using a secure manner. Issuing CA may provide backup services of Private Key for Subscriber provided that the backups shall be secured in a manner that only the Subscriber can control the Private Key.

6.2.5 Private key archival

CA Private Keys are not archived. When a CA Certificate has expired or been revoked and no unexpired Certificate signed with the corresponding Private Key remains (including CRLs and OCSP responses that must still be signed under Section 5.6), the Private Key and all of its backup copies are destroyed under Section 6.2.10 by personnel in Trusted Roles under multi-person control, and the destruction is recorded in accordance with Section 5.4.1. Parties other than a Subordinate CA do not archive that Subordinate CA's Private Key without its authorisation (S/MIME BR 6.2.5).

6.2.6 Private Key Transfer into or from a Cryptographic Module

CA Keys are always generated in cryptographic modules. They are copied to similar cryptographic modules for recovery / business continuity purposes. Such copying shall also happen in encrypted form, and the private key must never exist in plain text form outside the cryptographic module.

6.2.7 Private Key Storage on Cryptographic Module

CA Private Keys shall be stored on a Hardware Security Module validated as meeting at least FIPS 140-2 Level 3, FIPS 140-3 Level 3, or an appropriate Common Criteria Protection Profile or Security Target at EAL 4 or higher.

Subscriber Private Keys can be stored on a Cryptographic Module.

6.2.8 Method Of Activating Private Key

CA Private Keys are activated in accordance with the specifications of the Cryptographic Module Manufacturer.

6.2.9 Method Of Deactivating Private Key

When not in use, Issuing CA shall deactivate its Private Keys by ending (logging out) the sessions with cryptographic modules. These are based on specifications of the Cryptographic Module Manufacturer.

6.2.10 Method Of Destroying Private Key

Issuing CA shall use individuals in trusted roles to destroy Private Keys when they are no longer needed or upon expiry or upon revocation of the Certificate by deleting or overwriting the data or using physical destruction.

Subscribers may destroy their Private Keys when the corresponding Certificate is revoked or expired of if the Private Key is no longer needed. This must be done in a secure manner so as to ensure that there is no loss, theft, compromise or unauthorized disclosure or use.

6.2.11 Cryptographic Module Rating

The rating of the Cryptographic Module shall meet the requirements laid down in "Cryptographic Module Standards and Controls" section of this CP/CPS.

6.3 Other Aspects of Key Pair Management

6.3.1 Public Key Archival

Issuer CA shall archive a copy of each public key.

6.3.2 Certificate Operational Periods and Key Pair Usage Periods

The maximum validity periods for Digital Certificates issued within the emSign CA PKI are:

Type	Private Key Use (signing the certificates)	Private Key Use (signing the CRL)	Certificate Term
Root CA Certificate	20 years	25 years	25 years
All Subordinate CAs of Root CA	12 years	15 years	15 years
S/MIME Subscriber Certificates (Strict and Multipurpose Generations)	Not Applicable	Not Applicable	825 days

The validity period of Issuing CA Certificates is set in accordance with this CP/CPS and Section 6.3.2 of the S/MIME Baseline Requirements. emSign manages the lifecycle and planned replacement of its Issuing CAs under its internal CA lifecycle management procedures, and no Issuing CA is used to issue Subscriber Certificates whose notAfter date exceeds the notAfter date of the Issuing CA Certificate.

Maximum validity period of S/MIME Subscriber Certificates (S/MIME BR Section 6.3.2): 825 days for the Strict and Multipurpose Generations. The Legacy Generation (1185 days) is not issued by emSign. For the purpose of this calculation a day is 86,400 seconds, and any amount of time greater than this – including fractional and leap seconds – represents an additional day; emSign therefore does not issue Subscriber Certificates for the maximum permissible period by default.

All certificates including subscriber certificates or any subordinate CA certificate end date shall not exceed the end date of its signing certificate (issuer).

6.4 Activation Data

6.4.1 Activation Data Generation and Installation

Issuing CAs under emSign PKI shall ensure that activation data used to protect access to private keys such as PINs, passphrases, or cryptographic tokens has sufficient entropy and strength to prevent unauthorized access. Activation mechanisms must include multi-factor authentication wherever applicable.

All personnel involved in CA operations, including emSign PKI Officers, shall use strong, complex passwords or cryptographic authentication methods to safeguard sensitive systems, in line with emSign PKI's internal security policies.

6.4.2 Activation Data Protection

If activation data must be transmitted to subscribers, it shall be via a channel of appropriate protection, and distinct in time and place from the associated Cryptographic Module. Personal Identification Codes may be supplied to Subscriber in a secure manner.

6.4.3 Other Aspects of Activation Data

Where a PIN or Passphrase is used, User is required to enter PIN or Passphrase along with other personal identification details to be able to access and install their keys or digital certificates.

6.5 Computer Security Controls

6.5.1 Specific computer security technical requirements

emSign PKI has an Information Security Policy that documents the policies, standards and guidelines relating to information security. This Information Security Policy has been approved by the emSign Policy Authority and is communicated to all employees that pertain to the emSign PKI business.

Some of the security controls and policies include:

- Clearly defined processes, systems and safeguards for ensuring physical, logical access to the systems
- Usage of HSM for protection of Issuing CA Private key material.

- Access controls to Certificate Authority services and PKI roles.
- Enforced separation of duties for Certificate Authority Services and PKI roles.
- Trusted personnel checks, roles of responsibility in the emSign PKI.
- Application, Session and Database security
- Archival process for Certificate Authority history and Audit data.
- Controls are in place to prevent unauthorized or illegitimate software from executing within its systems, including but not limited to anti-virus and anti-malware software.
- Comprehensive incident response plan to respond to compromise or breach of its online systems as well as its certificate issuance systems.
- Enforcement of Multi-factor authentication for all accounts capable of directly causing a certificate issuance.

6.5.2 Computer Security Rating

No stipulation.

6.6 Life Cycle Technical Controls

Following lifecycle controls are required to be followed to ensure mitigation of risk during operation of emSign PKI ecosystem.

- Hardware and software procured should follow methodologies that ensure no scope for any particular component to be tampered
- Systems used within emSign PKI shall be developed using strict change control procedures
- Only trusted personnel shall be authorized to use core systems of emSign PKI
- Issuing CA shall not install applications or component software that is not part of the Issuing CA configuration
- The Issuer CA shall purchase or develop updates in the same manner as original equipment, and shall use trusted trained personnel to install the software and equipment.
- System administrators in network do not have access to certificate issuance systems due to proper segmentation of duties and least privilege principles.

6.6.1 System Development Controls

Adequate controls are put in place for System Development as follows

- Software Development Lifecycle practices are followed for development and implementation of new systems.
- Security analysis is conducted at the design stage.
- Outsourcing of projects (if any) is closely monitored and controlled.

6.6.2 Security Management Controls

Issuing CA installation, configuration, as well as any modifications are documented and controlled by Issuing CA through formal mechanisms.

Issuing CA change control process shall include procedures to detect unauthorized modification to the Issuing CA systems. Any third-party software procured shall be verified for integrity, appropriate versioning and for being free of any modifications.

6.6.3 Life Cycle Security Controls

emSign PKI periodically verifies the integrity of the Certifying Authority software and monitors the configuration of CA systems.

6.7 Network Security Controls

Issuing CA shall ensure that the network in which the CA system is hosted is protected by network firewalls and other systems that to the extent possible prevent unauthorized access by parties. Other measures include:

- Turning off any unused network ports or services.
- Firewalls and filtering routers used for CA equipment limits services to and from the CA equipment to those required to perform CA functions.
- Maintain network security controls that at minimum meet the Network and Certificate System Security Requirements.
- Check for mis-issuance of certificates, especially for high-profile domains.
- Shut down certificate issuance quickly if we are alerted of intrusion.
- Review network infrastructure, monitoring, passwords, etc. for signs of intrusion or weakness.
- Ensure IDS (Intrusion Detection System) and IPS (Intrusion Prevention System) systems, and other monitoring software are in place and are up-to-date.
- Segmentation of key certificate issuance systems from non-related servers and systems such as marketing websites, etc.

6.7.1 Timeframe for Responding to and Remediating Vulnerabilities

eMudhra shall maintain a documented process for the identification, assessment, prioritization, and remediation of vulnerabilities affecting systems, applications, and infrastructure supporting Certification Authority operations. Each identified vulnerability is risk-assessed within 48 hours of identification. For a Critical Vulnerability not previously addressed, emSign does one of the following within ninety-six (96) hours of discovery, as required by the Network and Certificate System Security Requirements: remediates the vulnerability; or, where remediation within that period is not possible, creates and implements a plan to mitigate it; or documents the factual basis for its determination that the vulnerability does not require

remediation. Vulnerabilities shall be remediated within the following timeframes based on their severity classification:

Severity Level	Remediation Timeline
Critical	Within 96 hours of discovery (remediate, mitigate, or document per NCSSR)
High	Within 14 Working Days
Medium	Within 30 Working Days
Low	Within 60 Working Days

6.8 Time-Stamping

Issuing CAs shall ensure that their components are regularly synchronized with a time service such an atomic clock or Network Time Protocol. The system time on computers shall be updated using the Network Time Protocol (NTP) to synchronize system clocks at least once every eight hours.

This shall be used for establishing the time of:

- Initial validity time of a CA Certificate;
- Revocation of a CA Certificate;
- Posting of CRL updates; and
- Issuance of Subscriber Certificates

An internal NTP server is maintained that synchronizes with external sources and maintains the accuracy of its clock within one second or less.

7 Certificate, CRL, And OCSP Profiles

7.1 Certificate Profile

All emSign PKI Digital Certificates conform to Digital Certificate and Certificate Revocation List profiles as described in RFC 5280 and utilise the ITU-T X.509 version 3 Digital Certificate standards.

Refer to APPENDIX B for Certificate contents that are specific to the individual classes of Digital Certificates.

7.1.1 Version Number(s)

All Certificates issued by emSign are X.509 version 3.

7.1.2 Certificate Extensions

Certificate extensions shall be in conformance to RFC 5280 and the Baseline Requirements.

The certificates are with the extensions required by respective certificate profiles. Private extensions are permissible, but the use of private extensions is not warranted under this CP/CPS unless specifically included by reference.

7.1.2.1 Key Usage

The keyUsage extension marked critical in all Root CA, Subordinate CA and Subscriber Certificates issued under this CP/CPS.

7.1.2.2 Certificate Policies Extension

The certificatePolicies extension in S/MIME Certificates issued under emSign PKI includes exactly one of the reserved CA/Browser Forum policy identifiers listed in S/MIME BR Section 7.1.6.1 and reproduced in Section 1.2 of this CP/CPS, and may additionally include one or more emSign policy identifiers documented in Section 1.2. The extension is not marked critical. Where a qualifier of type id-qt-cps (1.3.6.1.5.5.7.2.1) is included, its value is an HTTP or HTTPS URL for this CP/CPS; where a qualifier of type id-qt-unotice (1.3.6.1.5.5.7.2.2) is included, it contains explicitText and does not contain noticeRef.

Additional policy OIDs MAY be included to reflect compliance with relevant standards or program requirements, such as the CA/Browser Forum Baseline Requirements or other industry-specific criteria, where applicable.

Reserved Certificate Policy Identifiers

emSign Issuing CAs include the reserved policy identifier corresponding to the Certificate Type and Generation being issued: Mailbox-validated Multipurpose (2.23.140.1.5.1.2), Mailbox-validated Strict (2.23.140.1.5.1.3), Organization-validated Multipurpose (2.23.140.1.5.2.2), Organization-validated Strict (2.23.140.1.5.2.3), Sponsor-validated Multipurpose (2.23.140.1.5.3.2), Sponsor-validated Strict (2.23.140.1.5.3.3), Individual-validated Multipurpose (2.23.140.1.5.4.2) or Individual-validated Strict (2.23.140.1.5.4.3). Where such an identifier is present, the subject field is populated in accordance with the corresponding Subject DN attribute table in Appendix B and Section 7.1.4.

Root CA Certificates emSign Root CA Certificates SHALL NOT contain the certificatePolicies extension.

Subordinate CA Certificates

A Subordinate CA Certificate issued to a Subordinate CA that is an Affiliate of the Issuing CA includes either one or more explicit policy identifiers defined in Section 7.1.6.1 of the S/MIME BR or the anyPolicy identifier (2.5.29.32.0). A Subordinate CA Certificate issued to a Subordinate CA that is not an Affiliate includes one or more explicit policy identifiers and never includes anyPolicy. Every Subordinate CA Certificate used to issue S/MIME Certificates contains id-kp-emailProtection in the extKeyUsage extension, and never contains id-kp-serverAuth, id-kp-codeSigning, id-kp-timeStamping or anyExtendedKeyUsage.

- Should emSign issue a Subordinate CA Certificate to a Subordinate CA not operated by emSign or an Affiliate (an external subordinate CA), that Certificate SHALL include only explicit policy OIDs and SHALL NOT include the *anyPolicy* OID.

Subscriber Certificates

- Subscriber Certificates SHALL include exactly one of the reserved CA/Browser Forum policy identifiers listed in Section 1.2 for the Certificate Type and Generation issued, and MAY include one or more emSign policy identifiers documented in Section 1.2.
- One policy OID MAY represent the emSign CPS and include a URI pointing to the CP/CPS document.
- Additional policy OIDs SHALL represent the certificate's validation level and compliance with verification, issuance, and other requirements, as specified in Appendix A and Appendix B, and referenced in Section 1.2 of this CP/CPS.

7.1.3 Algorithm Object Identifiers

The certificate contains the Signing Algorithm information as per RFC 5280 specifications.

7.1.4 Name Forms

The certificates with name forms compliant to RFC 5280. Each certificate includes a unique certificate serial number (non-sequential) among respective Issuing CA, that is greater than zero and less than 2^159 and exhibits at least 64 bits of output from a CSPRNG.

For S/MIME Subscriber Certificates, the subjectAltName extension is present in every Certificate and contains at least one GeneralName entry of type rfc822Name and/or otherName of type id-on-SmtpUTF8Mailbox encoded in accordance with RFC 9598. Every Mailbox Address appearing in the subject field, or in a directoryName entry of the subjectAltName extension, is repeated as an rfc822Name or id-on-SmtpUTF8Mailbox value in that extension. The extension is not marked critical unless the subject field is an empty sequence.

Where present, subject:commonName contains a Mailbox Address for the Mailbox-validated Type; the subject:organizationName or a Mailbox Address for the Organization-validated Type; and a Personal Name, Pseudonym or Mailbox Address for the Sponsor-validated and Individual-validated Types. Where subject:commonName contains a Pseudonym, subject:givenName and subject:surname are absent; where it contains a Personal Name, subject:pseudonym is absent.

subject:organizationIdentifier is present in every Organization-validated and Sponsor-validated Certificate and contains the Registration Reference of the Legal Entity verified under Section 3.2.3, encoded as a PrintableString or UTF8String in the structure required by S/MIME BR Section 7.1.4.2.2(d) and Appendix A: the 3-character Registration Scheme identifier (NTR, VAT, PSD, LEI, GOV or INT); the 2-character ISO 3166-1 country code of the nation operating the scheme, or 'XG' for the LEI and INT schemes; where the Registration Reference is assigned at subdivision level and is not unique nationally, a plus sign '+' followed by the up-to-3-character ISO 3166-2 subdivision identifier; a hyphen-minus '-'; and the Registration Reference allocated under the scheme (for example NTRIN-U72900KA2008PTC046037, NTRUS+CA-12345678, PSDBE-NBB-1234.567.890, VATEL-123456789). Government Entities without a scheme identifier use GOV followed by the country code and, where applicable, '+' and the subdivision, with no

Registration Reference (e.g. GOVIN, GOVUS+CA); International Organization Entities use INTXG. For the VAT scheme the country prefix of EU Council Directive 2006/112/EC Article 215 MAY replace the ISO code; for the NTR scheme in the EU/EEA the EUID MAY be used (SHOULD for Germany), e.g. NTRDE-DER3306.HRB12345. Except for the LEI and INT schemes, the country code matches subject:countryName where present. emSign confirms that the organization represented by the Registration Reference is the organization named in subject:organizationName and that the reference matches the other information verified under Section 3.2.3. The full encoding rule is repeated in the Appendix B profiles.

subject:serialNumber, where present, may contain an identifier assigned by emSign or the RA to disambiguate the Subscriber, or – in the Sponsor-validated and Individual-validated Types – a Natural Person Identifier as described in ETSI EN 319 412-1 Section 5.1.3 using the PAS, IDC, PNO, TAX, TIN or EID schemes.

For the Strict Generation, subject:streetAddress and subject:postalCode are not present. subject:localityName, subject:stateOrProvinceName and subject:postalCode are included only where subject:countryName is also present, and subject:streetAddress only where subject:localityName or subject:stateOrProvinceName is present (S/MIME BR Section 7.1.4.2.2(j) to (m)). The subjectDirectoryAttributes extension is prohibited in the Strict and Multipurpose Generations, and the Adobe Time-stamp (1.2.840.113583.1.1.9.1) and ArchiveRevInfo (1.2.840.113583.1.1.9.2) extensions are prohibited in the Strict Generation (S/MIME BR 7.1.2.3(j) and (m)). The smimeCapabilities (RFC 4262) and qcStatements (RFC 3739 / ETSI EN 319 412-5) extensions MAY be present and are never marked critical. The Legal Entity Identifier extension (1.3.6.1.4.1.52266.1) may be present in Organization-validated and Sponsor-validated Certificates only, and the role LEI (1.3.6.1.4.1.52266.2) in Sponsor-validated Certificates only.

The Issuer Name shall be populated in each Certificate issued containing the Country, Organization Name and the Common Name of the Issuer CA. In accordance with S/MIME BR Section 7.1.4.1, the encoded Issuer Distinguished Name of every Certificate is byte-for-byte identical with the encoded Subject Distinguished Name of the Issuing CA Certificate, and the encoded Subject Distinguished Name of each emSign CA is byte-for-byte identical across all Certificates (including expired and revoked Certificates) whose Subject Distinguished Names compare as equal under RFC 5280 Section 7.1. The Distinguished Name for each Certificate type is set forth as per the respective certificate profile. Optional Sub fields in the Subject contains only verified information, or left empty. The subject fields shall not contain values as meta data of period, hyphen, empty space, etc (Eg: '.' OR '-' OR ' ') indicating the field as not applicable.

emSign does not issue a Certificate containing a keyUsage flag, extKeyUsage value, extension or other data that is not specified in S/MIME BR Sections 7.1.2.1, 7.1.2.2 or 7.1.2.3 unless emSign is aware of a reason for including that data, in which case the validation processes and procedures for it are documented in this CP/CPS.

7.1.5 Name constraints

For a Subordinate CA Certificate to be considered Technically Constrained under S/MIME BR Section 7.1.5, it includes an extKeyUsage extension specifying all extended key usages for which it is authorised to issue, never including anyExtendedKeyUsage. Where the Subordinate CA Certificate includes id-kp-emailProtection, it additionally includes the nameConstraints extension with constraints on rfc822Name and directoryName:

(1) each rfc822Name in permittedSubtrees contains either an FQDN, or a full stop followed by an FQDN, and never an email address; emSign confirms that the Applicant has registered the FQDN or has been authorised by the domain registrant to act on the registrant's behalf;

(2) for each directoryName in permittedSubtrees, emSign confirms the Applicant's and/or Subsidiary's organizational name and location such that end entity Certificates issued from the Subordinate CA Certificate will comply with S/MIME BR Section 7.1.2.4.

emSign places name constraints in a nameConstraints extension which should be marked critical.

7.1.6 Certificate policy object identifier

The OIDs used by emSign PKI are listed in Section 1.2.

7.1.7 Usage of Policy Constraints extension

No stipulation.

7.1.8 Policy qualifiers syntax and semantics

emSign PKI includes in End Entity Certificates a non-critical Certificate Policies extension as defined in RFC5280. It includes a one or more PolicyInformation extension that includes the Certificate Policy Identifier and a single Policy Qualifier referring to the CPS URI or a userNotice.

7.1.9 Processing semantics for the critical Certificate Policies extension

No stipulation.

7.2 CRL Profile

Certificate Revocation Lists are issued in the X.509 version 2 format in accordance with RFC 5280.

7.2.1 Version Number(s)

Issuing CAs within the emSign PKI issue X.509 version 2 Certificate Revocation Lists.

7.2.2 CRL and CRL entry extensions

7.2.2.1 Fields in CRL

The CRL contains following fields:

1. Issuer DN
2. Effective date of CRL issuance
3. Next update date
4. Signature Algorithm
5. Signature Hash Algorithm

7.2.2.2 CRL Extensions

CRL contains the following extensions:

1. CRL Number: Sequential number for CRL under specific issuer.
2. Authority Key Identifier: Identifier of Issuing CA.

Revocation entries remain on CRLs and in OCSP responses until after the Expiry Date of the revoked Certificate. Where present, the reasonCode (2.5.29.21) CRL entry extension is not marked critical. For a CRL entry relating to a Root CA or Subordinate CA Certificate, including Cross Certificates, the reasonCode extension is present and the CRLreason certificateHold (6) is never used. For a CRL entry relating to a Certificate not technically capable of causing issuance the reasonCode extension should be present. The CRLReason unspecified (0) is never indicated; where the reason is unspecified the reasonCode entry extension is omitted. The CRLReason certificateHold (6) is not used for Strict Generation Certificates in any circumstances, and is not presently used for Multipurpose Generation Certificates because emSign does not currently offer suspension (Section 4.9.13).

7.2.2.3 CRL Entries

CRL contains the entries of certificates revoked under that issuer. Each of these entries contain:

1. Certificate Serial Number
2. Revocation Date
3. Revocation reason

7.3 OCSP Profile

Issuing CAs operate OCSP responders conforming to RFC 6960 and/or RFC 5019 as described in Sections 4.9.9 and 4.9.10. OCSP Responder Certificates conform to the profile stated in Section 4.9.9 (id-kp-OCSPSigning, id-pkix-ocsp-nocheck).

7.3.1 Version Number(s)

Issuing CAs within the emSign PKI issue Version 1 OCSP Responses.

Where an OCSP response relates to a Root CA or Subordinate CA Certificate (including a Cross Certificate) that has been revoked, the revocationReason field within the RevokedInfo of the CertStatus is present and indicates a value permitted for CRLs under Section 7.2.2.

7.3.2 OCSP Extensions

The singleExtensions of an OCSP response SHALL NOT contain the reasonCode (OID 2.5.29.21) CRL entry extension (S/MIME BR 7.3.2). emSign may include the Nonce extension (1.3.6.1.5.5.7.48.1.2) in accordance with RFC 8954 where requested. Requirements for delegated OCSP Responder Certificates are stated in Sections 4.9.9 and 7.3.

8 COMPLIANCE AUDIT AND OTHER ASSESSMENTS

8.1 Frequency or circumstances of assessment

All Issuing Certification Authorities under the emSign PKI are subject to an annual compliance audit. These audits are conducted by qualified independent auditors and are designed to confirm conformance with the latest versions of AICPA/CICA:

- WebTrust: for Certification Authorities
- WebTrust: Principles and Criteria for Certification Authorities – Network Security
- WebTrust: for Certification Authorities – S/MIME Baseline Requirements

These assessments ensure that emSign PKI's practices align with the CA/Browser Forum's Baseline Requirements and applicable browser root program policies. Additional assessments may be performed in response to significant changes in CA operations, incidents, or at the discretion of the Policy Authority.

The period during which emSign issues Certificates is divided into an unbroken sequence of audit periods, and no audit period exceeds one year in duration. Any Subordinate CA Certificate capable of issuing Certificates is either Technically Constrained in accordance with Section 7.1.5 of this CP/CPS and subject only to the review and monitoring of delegated parties under Section 8.8 of this CP/CPS (S/MIME BR Section 8.8), or is unconstrained and fully audited under this Section.

Before issuing Publicly-Trusted S/MIME Certificates from a Root CA or Subordinate CA that is not yet covered by a currently valid Audit Report under an audit scheme listed in Section 8.4, emSign successfully completes a point-in-time readiness assessment under that scheme no earlier than twelve (12) months before the first issuance, followed by a complete period-of-time audit under the same scheme within ninety (90) days of issuing the first Publicly-Trusted S/MIME Certificate (S/MIME BR 8.1).

8.2 Identity and Qualifications of Assessor

External compliance audits of emSign PKI's Issuing Certification Authorities are conducted by a Qualified Auditor who is independent of emSign, credible, and recognized by AICPA/WebTrust. The auditor must have substantial experience in auditing Information Security systems, PKI operations, and cryptographic technologies. The auditor is bound by applicable laws, regulations, or professional codes of ethics and must maintain professional liability or errors and omissions insurance with coverage of at least USD 1,000,000. The auditor must be licensed by CPA Canada to conduct WebTrust audits, including WebTrust for Certification Authorities, WebTrust for Certification Authorities – S/MIME Baseline Requirements and WebTrust for Certification Authorities – Network Security.

emSign PKI audits have been carried out by BDO.

8.3 Assessor's Relationship to Assessed Entity

emSign PKI has selected an auditor that is completely independent from emSign CA

8.4 Topics Covered by Assessment

Topics covered by the Assessment include but are not limited to CA business practice disclosure (CP/CPS), service integrity of emSign Operations and emSign's operational compliance to this CP/CPS and to the WebTrust guidelines.

emSign undergoes an audit against the WebTrust Principles and Criteria for Certification Authorities, together with the WebTrust Principles and Criteria for Certification Authorities – S/MIME Baseline Requirementsand, for audit periods starting on or after 1 April 2025, the WebTrust Principles and Criteria for Certification Authorities – Network Security , as required by S/MIME BR Section 8.4. Audit reports state explicitly that they cover the systems and processes used in the issuance of all Certificates asserting one or more of the policy identifiers listed in Section 1.2 of this CP/CPS.

For each Delegated Third Party that is not an Enterprise RA, emSign obtains an audit report, issued under the auditing standards that underlie the audit schemes above, opining on whether the Delegated Third Party's performance complies with its practice statement or with this CP/CPS as described in Section 1.3.2; the audit period does not exceed one year and, where the opinion is that the Delegated Third Party does not comply, emSign does not allow it to continue performing delegated functions (S/MIME BR 8.4).

8.5 Actions Taken As a Result of Deficiency

For any material non-compliance or deficiency presented by the Auditors, emSign, at its sole discretion will determine an appropriate corrective action plan with appropriate time frame to remove the deficiency.

8.6 Communication of results

Results of the audit are reported to the Policy Authority for analysis and resolution of any deficiency through a subsequent corrective action plan.

emSign makes its Audit Report publicly available in the emSign repository and in the Common CA Database no later than three (3) months after the end of the audit period. Where publication is delayed beyond three months, emSign provides an explanatory letter signed by the Qualified Auditor. The Audit Report states explicitly that it covers the relevant systems and processes used in the issuance of all Certificates asserting one or more of the reserved policy identifiers listed in Section 7.1.6 of this CP/CPS, and contains at least: the name of the organization audited; the name and address of the organization performing the audit; the SHA-256 fingerprint of all Root and Subordinate CA Certificates in scope; the audit criteria and version numbers applied; the CA policy documents and version numbers referenced; whether the audit assessed a period of time or a point in time; the start and end dates of the audit period, or the point-in-time date; and the date the report was issued. An authoritative English language version is provided by the Qualified Auditor and made publicly available. The Audit Report is published as a text-searchable PDF, and each SHA-256 fingerprint is rendered in uppercase without colons, spaces or line feeds.

8.7 Self Audits

During the period in which it issues Certificates, emSign monitors adherence to this CP/CPS and the S/MIME Baseline Requirements and controls its service quality by performing self-audits on at least a quarterly basis against a randomly selected sample of Certificates.

The self-audit sample includes a minimum of the greater of thirty (30) Certificates or three percent (3%) of the Certificates issued by emSign during the period commencing immediately after the previous self-audit sample was taken. emSign uses a Linting process to verify the technical accuracy of the Certificates in the selected sample, independently of any linting performed on those Certificates at issuance, in accordance with S/MIME BR Section 8.7.

8.8 Review of Delegated Parties

Except for Delegated Third Parties, Enterprise RAs and Technically Constrained Subordinate CAs that themselves undergo an annual audit meeting the criteria of Section 8.4, emSign documents the obligations of each delegated party and monitors adherence to those obligations at least annually, in accordance with S/MIME BR Section 8.8.

9 Other Business and Legal Matters

9.1 Fees

9.1.1 Certificate Issuance or Renewal Fees

emSign PKI charges fee to its customers for certificate issuance and renewal. The fees are indicated to the customers through suitable web interface or through sales and marketing materials. The fees can be changed from time to time at emSign's discretion.

9.1.2 Certificate Access Fees

emSign PKI may charge access fee for bulk access to its certificate databases/repository as specified in applicable agreements.

9.1.3 Revocation or Status Information Access Fees

emSign does not charge any fee for the revocation of a Certificate, or for a Relying Party or any other party to check the validity status of an emSign-issued Certificate using CRLs or the OCSP service.

9.1.4 Fees for Other Services

emSign PKI reserves the right to charge fee for enterprise support and/or any other additional services.

9.1.5 Refund Policy

emSign PKI will provide refund to subscribers under certain circumstances and subject to certain conditions. The details of these will be contained in the relevant contractual document.

9.2 Financial Responsibilities

9.2.1 Insurance Cover

emSign maintains Commercial General Liability insurance and Errors and Omissions / Professional Liability insurance appropriate to the scale of its CA operations, with a reputable insurer. Policy limits and terms are available to emSign's Qualified Auditor and to Application Software Suppliers on request.

9.2.2 Other Assets

No stipulation.

9.2.3 Insurance or warranty coverage for end-entities

Subscribers and Relying parties can apply to Commercial Insurance Providers for Financial Protection against accidental occurrences such as theft, corruption, loss or unintentional disclosure of the private key that corresponds to the public key in their emSign Certificate.

9.2.4 Financial Records

emSign PKI shall maintain its financial records, including books of accounts, in a commercially reasonable manner.

9.2.5 No Partnership or Agency

No partnership or agency is implied in any subscriber or relying party agreement under this CP/CPS. Hence emSign is not the agent, fiduciary trustee or other representative of subscribers or the relying parties. Further the subscribers and relying parties shall not represent themselves as agent, partner, affiliate, employee or representative of emSign and shall have no authority to commit anything on behalf of emSign.

9.3 Confidentiality of Business Information

9.3.1 Scope of Confidential Information

emSign PKI considers the following information as confidential information and protects them from disclosure using a reasonable degree of care:

1. Private Keys;
2. Activation data used to access Private Keys or to gain access to the CA system;
3. Business continuity, incident response, contingency, and disaster recovery plans;
4. Other security practices used to protect the confidentiality, integrity, or availability of information;
5. Information held by emSign PKI as private information in accordance with this CP/CPS;
6. Audit logs and archive records;
7. Transaction records, financial audit records, and external or internal audit trail records and any audit reports (with the exception of an auditor's letter confirming the effectiveness of the controls set forth in this CPS).
8. Any other information relating to subscriber or emSign PKI, which may be sensitive in nature.

9.3.2 Information not Within the Scope of Confidential Information

Any information other than information indicated as confidential in this CP/CPS shall be deemed public. Further Information appearing in certificates and in the Repository, are considered public.

9.3.3 Responsibility to Protect Private Information

emSign PKI's employees, agents and contractors are contractually obliged to protect confidential information. Further emSign provides training to employees on protection of confidential information.

9.4 Privacy of Personal Information

9.4.1 Privacy Plan

emSign PKI protects personal information as per the Privacy Policy published in emSign Repository.

The emSign Privacy Policy, published at https://repository.emsign.com, sets out how emSign collects, uses, shares, stores, deletes and retains personal data, and provides contact information for the exercise of privacy rights, as required by S/MIME BR Section 9.4.1.

9.4.2 Information Treated as Private

All personal information about an applicant that is not publicly available in the contents of a Certificate or CRL are treated as private information by emSign PKI.

This includes any information that links a Pseudonym to the real identity of the Subject Individual, and all Individual identity evidence collected under Section 3.2.4. emSign and its RAs protect private information using appropriate safeguards and a reasonable degree of care, and require the same of any service provider handling private information on their behalf.

9.4.3 Information not deemed private

Any certificate content and certificate status information is deemed not private in emSign PKI.

9.4.4 Responsibility to Protect Private Information

emSign PKI shall store private information in accordance with the published Privacy Policy document published in emSign repository. All private information is securely stored and protected against accidental disclosure.

9.4.5 Notice and Consent to Use Private Information

Personal information obtained from an applicant during the application or identity verification process, to the extent not included in a certificate, is considered private information. Such private information will be used by emSign PKI only after obtaining the subject's consent or as required by applicable law or regulation. All subscribers are deemed to have consented to the global transfer and publication of any personal data contained in a Certificate.

9.4.6 Disclosure pursuant to Judicial or Administrative Process

emSign PKI may disclose private information without notice to the applicants or subscribers where such disclosure is required by law or regulation.

9.4.7 Other information disclosure circumstances

No stipulation.

9.5 Intellectual Property Rights

emSign does not knowingly violate the intellectual property rights of third parties.

All Intellectual Property Rights including all copyright in all Certificates, all documents including this CP/CPS and all proprietary marks belong to and will remain the property of eMudhra. eMudhra retains the exclusive right to use and licence its intellectual property.

Certificates are the exclusive property of emSign PKI. emSign PKI gives permission to reproduce and distribute Certificates on a royalty free, non-exclusive basis, provided that they are reproduced and distributed in full.

emSign PKI reserves the right to revoke a Certificate at any time and at its sole discretion.

Public keys and Private keys are the property of the applicable Certificate Holders who rightfully hold them.

emSign excludes all liability for breach of any other intellectual property rights.

9.6 Representations and Warranties

9.6.1 Certification Authority Representation and Warranties

emSign PKI represents and warrants to the Certificate Beneficiaries that it has complied with the S/MIME Baseline Requirements and with the provisions of this S/MIME CP/CPS in issuing and managing Certificates. emSign's compliance with applicable law is addressed in Section 9.15 and is not a warranty made to Certificate Beneficiaries.

By issuing a Certificate, emSign PKI makes the following Certificate Warranties to the Certificate Beneficiaries – the Subscriber that is a party to the Subscriber Agreement or Terms of Use for the Certificate, all Application Software Suppliers with whom the Root CA has entered into a contract for inclusion of its Root Certificate in software distributed by such Application Software Supplier, and all Relying Parties who reasonably rely on a Valid Certificate – and represents and warrants that, during the period when the Certificate is valid, it has complied with the S/MIME Baseline Requirements and this CP/CPS in issuing and managing the Certificate. The Certificate Warranties specifically include, but are not limited to: (1) Right to Use Mailbox Address – that, at the time of issuance, emSign implemented a procedure for verifying that the Applicant either had the right to use, or had control of, every Mailbox Address listed in the Certificate's subject field and subjectAltName extension (or was delegated such right or control by someone who had it), followed the procedure when issuing the Certificate, and accurately described the procedure in this CP/CPS; (2) Authorization for Certificate – that emSign implemented, followed and accurately described a procedure for verifying that the Subject authorised the issuance of the Certificate and that the Applicant Representative was authorised to request the Certificate on behalf of the Subject; (3) Accuracy of Information – that emSign implemented, followed and accurately described a procedure for verifying the accuracy of all of the information contained in the Certificate (with the exception of the subject:serialNumber attribute); (4) Identity of Applicant – that, if the Certificate contains

Subject Identity Information, emSign implemented, followed and accurately described a procedure to verify the identity of the Applicant in accordance with Sections 3.2 and 7.1.4; (5) Subscriber Agreement – that, if emSign and the Subscriber are not Affiliated, the Subscriber and emSign are parties to a legally valid and enforceable Subscriber Agreement that satisfies the S/MIME Baseline Requirements, or, if they are the same entity or are Affiliated, the Applicant Representative acknowledged the Terms of Use; (6) Status – that emSign maintains a 24x7 publicly accessible Repository with current information regarding the status (Valid or Revoked) of all unexpired Certificates; and (7) Revocation – that emSign will revoke the Certificate for any of the reasons specified in the S/MIME Baseline Requirements and Section 4.9 of this CP/CPS. The Root CA is responsible for the performance and warranties of each Subordinate CA, for the Subordinate CA's compliance with the S/MIME Baseline Requirements, and for all liabilities and indemnification obligations of the Subordinate CA, as if the Root CA were the Subordinate CA issuing the Certificates.

No other warranties are made by emSign. All other warranties, whether express, implied, statutory, or otherwise including, but not limited to, implied warranties of merchantability and fitness for a particular purpose are disclaimed to the fullest extent permitted by applicable law.

9.6.2 RA representations and warranties

RAs and LRAs warrant that:

1. They carry out the issuance process in compliance with this CP/CPS.
2. The information provided by them does not contain any false or misleading information.
3. Translations performed by them are an accurate translation of the original information.
4. All Certificates requested by them meet all material requirements of this CP/CPS.

Additional representations and warranties may be contained in emSign’s agreement with RA/LRAs.

9.6.3 Subscriber Representation and Warranties

Prior to the issuance of a Certificate, emSign obtains, for the express benefit of emSign and the Certificate Beneficiaries, either the Applicant's agreement to the Subscriber Agreement or, where the Applicant is emSign or an Affiliate of emSign, the Applicant Representative's acknowledgement of the Terms of Use. emSign ensures that each Subscriber Agreement or Terms of Use is legally enforceable against the Applicant (an electronic or click-through agreement may be used where emSign has determined it to be enforceable) and that every Certificate issued is clearly covered by it. The Subscriber Agreement or Terms of Use requires the Applicant, for itself or on behalf of its principal or agent under a subcontractor or hosting service relationship, to make the following commitments and warranties for the benefit of emSign and the Certificate Beneficiaries:

1. Accuracy of Information – provide accurate and complete information at all times to emSign, both in the Certificate Request and as otherwise requested in connection with the issuance of the Certificate;

2. Protection of Private Key – take all reasonable measures to assure control of, keep confidential and properly protect at all times the Private Key that corresponds to the Public Key in the Certificate, and any associated activation data or device such as a password or token;
3. Acceptance of Certificate – review and verify the Certificate contents for accuracy before using the Certificate;
4. Use of Certificate – use the Certificate only for the Mailbox Addresses listed in it, solely in compliance with all applicable laws and solely in accordance with the Subscriber Agreement or Terms of Use;
5. Reporting and Revocation – promptly request revocation of the Certificate, and cease using it and its associated Private Key, if there is any actual or suspected misuse or compromise of the Private Key, and promptly request revocation and cease using the Certificate if any information in it is or becomes incorrect or inaccurate;
6. Termination of Use of Certificate – promptly cease all use of the Private Key corresponding to the Public Key in the Certificate upon revocation of the Certificate for reasons of Key Compromise, and upon expiration of the Certificate;
7. Responsiveness – respond to emSign's instructions concerning Key Compromise or Certificate misuse within the time period specified in the Subscriber Agreement; and
8. Acknowledgment and Acceptance – acknowledge and accept that emSign is entitled to revoke the Certificate immediately if the Applicant violates the terms of the Subscriber Agreement or Terms of Use, or if revocation is required by this CP/CPS or by the S/MIME Baseline Requirements.

These commitments and warranties correspond to those required by S/MIME BR Section 9.6.3 and Section 4.1.2.

9.6.4 Relying Party Representation and Warranties

The Relying Party is solely responsible for making the decision to rely on a emSign PKI Certificate.

A Relying Party accepts that to reasonably rely on a emSign PKI Certificate, the Relying Party must have:

1. Obtained sufficient knowledge on the use of digital Certificates and PKI,
2. Studied the applicable limitations on the usage of Certificates and agrees to emSign’s limitations on liability related to the use of Certificates,
3. Read, understood, and agreed to the emSign’s Relying Party Agreement and this CP/CPS,
4. Verified both the emSign Certificate and the Certificates in the certificate chain using the relevant CRL or OCSP
5. Not used a emSign Certificate which has expired or been revoked,
6. Taken all reasonable steps to minimize the risk associated with relying on a digital signature certificate after considering:

a) applicable law and the legal requirements for identification of a party, protection of the confidentiality or privacy of information, and enforceability of the transaction;

b) the intended use of the Certificate as listed in the certificate or this CPS,

c) the data listed in the Certificate,

d) the economic value of the transaction or communication,

e) the potential loss or damage that would be caused by an erroneous identification or a loss of confidentiality or privacy of information in the application, transaction, or communication,

f) the Relying Party's previous course of dealing with the Subscriber,

g) the Relying Party's understanding of trade, including experience with computer-based methods of trade, and

h) any other indicia of reliability or unreliability pertaining to the Subscriber and/or the application, communication, or transaction.

Any unauthorized reliance on a Certificate is at the Relying Party's own risk.

9.6.5 Representation and Warranties of Other Parties

No stipulation.

9.7 Disclaimer of Warranties

Except for the Certificate Warranties expressly stated in Section 9.6.1, the indemnification obligations in Section 9.9.1, emSign's mandatory obligations under the S/MIME Baseline Requirements and applicable Application Software Supplier requirements, and to the extent that a warranty or liability cannot be excluded by applicable law, emSign PKI disclaims all warranties and obligations of any type, including any warranty of merchantability, fitness for a particular purpose, or non-infringement.

Without limiting the foregoing, and except as required by applicable law, emSign does not warrant: (1) the accuracy, authenticity, completeness or fitness of any information that this CP/CPS identifies as non-verified, or of any information compiled, published or disseminated by or on behalf of emSign other than Subject Information verified under Section 3.2; (2) the quality, functions, security or performance of any software, hardware device or key store used by a Subscriber or Relying Party, including whether such software correctly enforces the key usage, extended key usage, validity, revocation-checking or other controls described in this CP/CPS; (3) the availability, completeness or accuracy of any certificate directory or status service operated by a third party; or (4) the execution of a revocation that emSign is prevented from performing for reasons outside its reasonable control, although emSign remains responsible for performing revocation in accordance with Section 4.9.

9.8 Limitation of Liability

Issuing CAs under emSign PKI shall not be liable for delay or omission to issue/revoke/activate a digital certificate or any other consequences arising from events beyond the control of Issuing CAs under emSign PKI. emSign PKI shall not be liable, for any certificates obtained from it, by representing false or inaccurate or misleading or untrue information.

All warranties and any disclaimers thereof, and any limitations of liability among Issuing CAs under emSign PKI, its Intermediaries (RAs/partners) and their respective customers shall be in strict adherence to the terms and conditions of the Agreement amongst them.

To the extent Issuing CAs under emSign PKI has issued and managed the certificate in accordance with this CP/CPS, Issuing CAs under emSign PKI shall not have any liability to the Subscriber, Relying Party or any Third Parties for any losses or damages suffered as a result of use or reliance on such a certificate.

Issuing CAs under emSign PKI shall be liable to Certificate Holders or Relying Parties for direct loss arising from any breach of this CP/CPS or for any other liability it may incur in contract, tort or otherwise, including liability for negligence up to the following limits per Subscriber or Relying Party or Third Party per Certificate, provided the Subscriber, the Relying Party or the Third Party is in full compliance of this CP/CPS.

Limits of Liability per Subscriber or Relying party or Third Party per certificate:

(1) US Dollars One Thousand only (USD 1,000/-) per Certificate, for all Certificate Types and Generations issued under this CP/CPS.

The limit for aggregate maximum liability for all claims related to a single certificate or service shall be a liability of US Dollars Ten Thousand (USD 10,000/- only) or the amount paid by the subscriber in respect of that certificate or service during the past 12 months, whichever is higher.

The aggregate maximum liability for all claims, regardless of the number and source of claims shall be USD 1 million (USD 1,000,000/-) only.

Issuing CA's liability, under emSign PKI, to any person for damages arising under, out of or related in any way to this CP/CPS, Subscriber Agreement, the applicable contract or any related agreement, whether in contract, warranty, tort or otherwise, shall be limited to actual damages suffered by that person. Issuing CAs under emSign PKI shall not be liable for indirect, consequential, incidental, special, exemplary, or punitive damages with respect to any person, even if emSign PKI has been advised of the possibility of such damages, regardless of how such damages or liability may arise, whether in tort, negligence, equity, contract, statute, common law, or otherwise.

By participating within the Issuing CAs under emSign PKI, any person that participates within the emSign PKI irrevocably agrees that they shall not apply for or otherwise seek either indirect, exemplary, consequential, special, incidental, or punitive damages and irrevocably confirms to Issuing CAs under emSign PKI their acceptance of the foregoing and the fact that emSign has relied upon the foregoing as a

condition and inducement to permit that person to participate within the emSign Public Key Infrastructure.

Nothing in this Section 9.8 limits or applies to: (1) emSign PKI's obligation to defend, indemnify and hold harmless Application Software Suppliers under Section 9.9.1; (2) the responsibility of the Root CA for its Subordinate CAs, and of emSign for Delegated Third Parties, imposed by the S/MIME Baseline Requirements; or (3) liability for fraud or wilful misconduct, or any other liability that cannot be limited or excluded under applicable law.

9.9 Indemnities

9.9.1 Indemnification by emSign PKI

Notwithstanding any limitation on its liability to Subscribers and Relying Parties, emSign PKI understands and acknowledges that the Application Software Suppliers who have agreed to distribute the Root CA Certificate do not assume any obligation or potential liability of emSign PKI under the S/MIME Baseline Requirements, or that might otherwise exist because of the issuance or maintenance of Certificates or reliance thereon by Relying Parties or others.

emSign PKI is not a government entity and does not rely on the government-entity carve-out in Section 9.9 of the S/MIME Baseline Requirements. Accordingly, to the extent permitted by applicable law, emSign PKI SHALL defend, indemnify and hold harmless each Application Software Supplier that has agreed to distribute an emSign Root CA Certificate for any and all claims, damages and losses suffered by such Application Software Supplier related to a Certificate issued by emSign PKI under this CP/CPS, regardless of the cause of action or legal theory involved.

This obligation does not extend to any claim, damage or loss that was directly caused by the Application Software Supplier's software displaying either (a) a valid and trustworthy Certificate as not valid or not trustworthy, or (b) as trustworthy, a Certificate that has expired, or a revoked Certificate where the revocation status was available online but the Application Software Supplier's software failed to check or ignored that status.

9.9.2 Indemnification by Subscribers

To the extent permitted by applicable law and as provided in the applicable Subscriber Agreement, Terms of Use or Relying Party Agreement, any subscriber of a emSign Certificate, shall indemnify and hold harmless emSign PKI, its Affiliates and their respective directors, officers, employees, agents, and contractors from any and all damages and losses arising out of:

(1) use of the emSign PKI Certificate in a manner not authorised by emSign PKI;

(2) tampering with the emSign Certificate; or

(3) misrepresentation or omission of material fact in order to obtain or use a Certificate, whether or not such misrepresentation or omission was intentional.

In addition, Subscribers shall indemnify and hold harmless emSign PKI from any and all damages (including legal fees) for lawsuits, claims or actions by third-parties relying on or otherwise using a emSign Certificate relating to:

(1) Subscriber's breach of their obligations under the Subscriber Agreement or this CP/CPS;

(2) Subscriber's failure to protect its private key; or

(3) claims (including without limitation infringement claims) pertaining to content or other information or data supplied by Certificate Holder.

9.9.3 Indemnification by Relying Parties

To the extent permitted by applicable law and as provided in the applicable Subscriber Agreement, Terms of Use or Relying Party Agreement, any relying party of a emSign Certificate, , shall indemnify and hold harmless emSign PKI, its Affiliates and their respective directors, officers, employees, agents, and contractors from any and all damages and losses arising out of:

(1) breach of the Relying Party Agreement, this CPS, or applicable law;

(2) unreasonable reliance on a Certificate;

(3) failure to check the Certificate's status prior to use.

(4) use of the emSign Certificate in a manner not authorised by emSign PKI;

(5) tampering with the emSign Certificate; or

(6) misrepresentation or omission of material fact in order to obtain or use a Certificate, whether or not such misrepresentation or omission was intentional.

9.10 Term and Termination

9.10.1 Term

This CP/CPS and any amendments to this shall become effective upon publication in the emSign repository and shall remain in effect until it is replaced by a newer version.

9.10.2 Termination

This CP/CPS and any amendments shall remain in force until it is amended or replaced by a newer version.

9.10.3 Effect of Termination and Survival

Upon termination or replacement of this CP/CPS, all PKI Participants remain bound by its terms for Certificates issued during its term, for the remainder of the validity periods of those Certificates. The following survive termination: all unpaid fees under Section 9.1; all obligations relating to confidential information (Section 9.3) and private information (Section 9.4); all representations and warranties in Section 9.6; all disclaimers of warranty in Section 9.7; all limitations of liability in Section 9.8; and all indemnities in Section 9.9.

9.11 Individual Notices and Communications with Participants

Notices related to this CP/CPS may be submitted to emSign PKI in either paper or electronic form, using the contact details provided in Section 1.5.2 of this document. A notice is considered effective only upon receipt of a valid and signed acknowledgment from emSign PKI. If an acknowledgment is not received within seven (7) calendar days, the sender is required to resend the notice in physical form to the postal address specified in this CP/CPS, using a courier service that provides delivery confirmation.

emSign PKI may send required notices to Participants via electronic or physical means, unless otherwise explicitly agreed upon in writing.

9.12 Amendments

9.12.1 Procedure for Amendment

Amendments to this CP/CPS are approved by emSign Policy Authority. Upon any amendment the amended CP/CPS shall be posted on the online repository within the duration defined in this CP/CPS.

9.12.2 Notification Mechanism and Period

emSign PKI may make changes to this CP/CPS without notice; further emSign PKI does not guarantee or set a notice-and-comment period.

9.12.3 Circumstances under which OID must be changed

No stipulation.

9.13 Dispute Resolution Procedures

If any dispute arises between the parties participating in the emSign PKI the parties shall first attempt to solve the dispute by good faith negotiations by referring directly to emSign, before resorting to any other dispute resolution mechanism. If such good faith negotiations fail then the parties may refer the matter to arbitration or adjudication.

9.14 Governing Law

This CP/CPS shall be governed by and construed in accordance with the laws applicable to the issuing Certification Authority (CA) under the emSign PKI that issued the relevant certificate, except in circumstances where issuing CAs under emSign PKI have explicitly agreed with the subscriber / relying party / any other party to be governed by the laws of any other country.

Where a certificate is issued by an issuing CA under the emSign PKI operating in the United States, this CP/CPS and any dispute arising out of or in connection with such certificate shall be governed by the laws

of the State of New Jersey and shall be subject to the exclusive jurisdiction of the courts of the State of New Jersey.

Where a certificate is issued by an issuing CA under the emSign PKI operating in India, this CPS and any dispute arising out of or in connection with such certificate shall be governed by the laws of India and shall be subject to the exclusive jurisdiction of the courts in Bangalore, India.

9.15 Compliance with Applicable Law

The certificates issued under emSign PKI shall be used by the subscribers and relying parties only in accordance with the laws and regulations of the jurisdiction in which they are used or relied upon. Issuing CAs under emSign PKI may refuse to issue or may revoke Certificates if, in their opinion, issuance or the continued use of the emSign PKI Certificates would violate applicable laws or regulations.

9.16 Miscellaneous Provisions

9.16.1 Entire Agreement

No stipulation.

9.16.2 Assignment

Issuing CAs, subscribers, relying parties, Registering Authorities or any other entities operating under this CP/CPS are not entitled to assign any of their rights or obligations under this CP/CPS without the prior written consent of eMudhra.

9.16.3 Severability

In the event of a conflict between the S/MIME Baseline Requirements and a law, regulation or government order ("Law") of any jurisdiction in which emSign operates or issues Certificates, emSign may modify any conflicting requirement to the minimum extent necessary to make the requirement valid and legal in that jurisdiction, and only for operations or Certificate issuances subject to that Law. In such event emSign shall immediately, and prior to issuing a Certificate under the modified requirement, include in this Section a detailed reference to the Law requiring the modification and the specific modification implemented. emSign shall also, prior to issuing a Certificate under the modified requirement, notify the CA/Browser Forum of the information newly added to this CP/CPS by sending a message to public@cabforum.org and receiving confirmation that it has been posted to the Public Mailing List and is indexed in the Public Mail Archives available at https://cabforum.org/pipermail/public/ (or such other email addresses and links as the Forum may designate). Any modification enabled under this Section shall be discontinued if and when the Law no longer applies or the Requirements are modified to make compliance with both possible; the corresponding change in practice, amendment to this CP/CPS and notice to the CA/Browser Forum shall be made within 90 days. As at the date of this CP/CPS, emSign has not modified any requirement under this Section.

9.16.4 Enforcement (attorneys' fees and waiver of rights)

Issuing CAs under emSign PKI may seek indemnification and attorneys' fees from a party for damages, losses and expenses related to that party's conduct.

emSign PKI's failure to enforce a provision of this CP/CPS does not waive emSign PKI 's right to enforce the same provision later or right to enforce any other provision of this CP/CPS.

No waiver to any party shall be effective unless it is given in writing by respective issuing CAs under emSign PKI.

In its specific agreements with subscribers, relying parties or any other parties emSign PKI may agree to further provisions relating to enforcement.

9.16.5 Force Majeure

emSign PKI accepts no liability for any delay or failure to perform an obligation under this CP/CPS to the extent those delay or failure is caused by events beyond its reasonable control.

9.17 Other Provisions

No stipulation.

10 Appendix A: Verification Requirements for Subscriber

10.1 emSign Mailbox-Validated Strict SMIME Certificate

Usage/Purpose	E-Mail Protection
Email Verification	Control over each Mailbox Address to be included in the Certificate is confirmed by emSign itself – never by an RA, Enterprise RA or other Delegated Third Party – using only the methods described in Section 3.2.2 of this CP/CPS (S/MIME BR Sections 3.2.2.1 to 3.2.2.4): (a) validating authority over the mailbox via control of the domain portion of the Mailbox Address, using only the TLS BR Section 3.2.2.4 methods listed under 'Control of the domain portion of the Mailbox Address / SMTP FQDN' below or in Section 3.2.2(a); (b) validating control over the mailbox via email using a Random Value; (c) validating the Applicant as operator of the associated mail server(s); or (d) validating control over the mailbox using ACME for S/MIME (RFC 8823). Where the email method (b) is used, emSign sends a Random Value exhibiting at least 112 bits of entropy only to the Mailbox Address being validated; the Random Value is unique in each email, is not shared in any other way, is reset upon each instance of an email sent to that Mailbox Address (all relevant Random Values sent to that Mailbox Address remaining valid within the validity period), and remains valid for use in a

	confirming response for no more than twenty-four (24) hours from its creation. Mailbox control validated under method (b) or method (d) is reused for no more than 30 days,, mailbox control validated under method (d) for no more than 398 days, and control of the domain portion of the Mailbox Address or of the associated SMTP FQDN validated under method (a) or (c) for no more than 398 days (Section 4.2.1). Pre-verified or bank-verified information and mere delivery of an email are not accepted as evidence of mailbox control. For every validation emSign records the Mailbox Address validated, the method used and the version of the S/MIME Baseline Requirements (or TLS Baseline Requirements) under which it was performed.

10.2 emSign Individual -Validated Strict SMIME Certificate

Usage/Purpose	E-Mail Protection
Email Verification	Control over each Mailbox Address to be included in the Certificate is confirmed by emSign itself – never by an RA, Enterprise RA or other Delegated Third Party – using only the methods described in Section 3.2.2 of this CP/CPS (S/MIME BR Sections 3.2.2.1 to 3.2.2.4): (a) validating authority over the mailbox via control of the domain portion of the Mailbox Address, using only the TLS BR Section 3.2.2.4 methods listed under 'Control of the domain portion of the Mailbox Address / SMTP FQDN' below or in Section 3.2.2(a); (b) validating control over the mailbox via email using a Random Value; (c) validating the Applicant as operator of the associated mail server(s); or (d) validating control over the mailbox using ACME for S/MIME (RFC 8823). Where the email method (b) is used, emSign sends a Random Value exhibiting at least 112 bits of entropy only to the Mailbox Address being validated; the Random Value is unique in each email, is not shared in any other way, is reset upon each instance of an email sent to that Mailbox Address (all relevant Random Values sent to that Mailbox Address remaining valid within the validity period), and remains valid for use in a confirming response for no more than twenty-four (24) hours from its creation. Mailbox control validated under method (b) or method (d) is reused for no more than 30 days, and control of the domain portion of the Mailbox Address or of the associated mail server(s) under method (a) or (c) for no more than 398 days, and control of the domain portion of the Mailbox Address or of the associated SMTP FQDN validated under method (a) or (c) for no more than 398 days (Section 4.2.1). Pre-verified or bank-verified information and mere delivery of an email are not accepted as evidence of mailbox control. For every validation emSign records the Mailbox Address validated, the method used and the version of the S/MIME Baseline Requirements (or TLS Baseline Requirements) under which it was performed.

Individual Verification	Individual identity is verified under Section 3.2.4 of this CP/CPS using at least one of the authoritative sources permitted by S/MIME BR Section 3.2.4.1: (1) a government-issued passport, identity card or other official identity document of comparable reliability bearing a face photo, presented in its original form either in person or remotely in real time before a camera, with a visual comparison of the Applicant against the photo and recording of the issuer, validity period and unique document number – photocopies or scanned images are not accepted as authoritative evidence; (2) an ICAO 9303 part 10 eMRTD whose issuer signature validates against the relevant country signing certificates, with the issuer, validity period, unique document number, identity attributes and face photo recorded and a visual comparison of the Applicant against the face photo; (3) a notified eIDAS eID scheme at LoA Substantial or High, with the individual eID confirmed as not expired, suspended or revoked; (4) a digital signature created with a personal Certificate issued under an Approved Framework; (5) Enterprise RA records (Sponsor-validated Certificates approved by an Enterprise RA only); (6) an Attestation from the Sponsoring Organization confirming the Individual's affiliation (Sponsor-validated Certificates not approved by an Enterprise RA), verified under Section 3.2.8; (7) an Attestation from a qualified legal practitioner or notary in the Applicant's jurisdiction, verified under Section 3.2.8; or (8) an ISO/IEC 18013-5 Mobile Driver Licence authenticated in real time under Section 3.2.4(9). Supplementary evidence from official documents, government or regulatory registers or national population registers may corroborate a change of name, a Title or an address, but is never the sole authoritative source. An address (but not identity) may additionally be verified using a utility bill, bank statement, credit card statement or government-issued tax document. An Attestation is accepted only where the attestor is an accountant, lawyer, notary, government official or other reliable third party in the Applicant’s jurisdiction customarily relied upon for the fact attested, the Attestation includes a copy of the supporting documentation, and its authenticity is confirmed under Section 3.2.8. A declaration by emSign’s own RA personnel is not accepted as authoritative evidence of Individual identity. Where evidence has an explicit validity period, the identity validation is performed within that period, and evidence is reused only within the 825-day limit of Section 4.2.1. The identity document types, eID schemes and mDL issuing jurisdictions accepted by emSign are published at https://repository.emsign.com.

10.3 emSign Sponsor -Validated Strict SMIME Certificate

Usage/Purpose	E-Mail Protection

Email Verification	Control over each Mailbox Address to be included in the Certificate is confirmed by emSign itself – never by an RA, Enterprise RA or other Delegated Third Party – using only the methods described in Section 3.2.2 of this CP/CPS (S/MIME BR Sections 3.2.2.1 to 3.2.2.4): (a) validating authority over the mailbox via control of the domain portion of the Mailbox Address, using only the TLS BR Section 3.2.2.4 methods listed under 'Control of the domain portion of the Mailbox Address / SMTP FQDN' below or in Section 3.2.2(a); (b) validating control over the mailbox via email using a Random Value; (c) validating the Applicant as operator of the associated mail server(s); or (d) validating control over the mailbox using ACME for S/MIME (RFC 8823). Where the email method (b) is used, emSign sends a Random Value exhibiting at least 112 bits of entropy only to the Mailbox Address being validated; the Random Value is unique in each email, is not shared in any other way, is reset upon each instance of an email sent to that Mailbox Address (all relevant Random Values sent to that Mailbox Address remaining valid within the validity period), and remains valid for use in a confirming response for no more than twenty-four (24) hours from its creation. Mailbox control validated under method (b) or method (d) is reused for no more than 30 days, mailbox control validated under method (d) for no more than 398 days, and control of the domain portion of the Mailbox Address or of the associated SMTP FQDN validated under method (a) or (c) for no more than 398 days (Section 4.2.1). Pre-verified or bank-verified information and mere delivery of an email are not accepted as evidence of mailbox control. For every validation emSign records the Mailbox Address validated, the method used and the version of the S/MIME Baseline Requirements (or TLS Baseline Requirements) under which it was performed.
Individual Verification	Individual identity is verified under Section 3.2.4 of this CP/CPS using at least one of the authoritative sources permitted by S/MIME BR Section 3.2.4.1: (1) a government-issued passport, identity card or other official identity document of comparable reliability bearing a face photo, presented in its original form either in person or remotely in real time before a camera, with a visual comparison of the Applicant against the photo and recording of the issuer, validity period and unique document number – photocopies or scanned images are not accepted as authoritative evidence; (2) an ICAO 9303 part 10 eMRTD whose issuer signature validates against the relevant country signing certificates, with the issuer, validity period, unique document number, identity attributes and face photo recorded and a visual comparison of the Applicant against the face photo; (3) a notified eIDAS eID scheme at LoA Substantial or High, with the individual eID confirmed as not expired, suspended or revoked; (4) a digital signature created with a personal Certificate issued under an Approved Framework; (5) Enterprise RA records (Sponsor-validated Certificates approved by an

	Enterprise RA only); (6) an Attestation from the Sponsoring Organization confirming the Individual's affiliation (Sponsor-validated Certificates not approved by an Enterprise RA), verified under Section 3.2.8; (7) an Attestation from a qualified legal practitioner or notary in the Applicant's jurisdiction, verified under Section 3.2.8; or (8) an ISO/IEC 18013-5 Mobile Driver Licence authenticated in real time under Section 3.2.4(9). Supplementary evidence from official documents, government or regulatory registers or national population registers may corroborate a change of name, a Title or an address, but is never the sole authoritative source. An address (but not identity) may additionally be verified using a utility bill, bank statement, credit card statement or government-issued tax document. An Attestation is accepted only where the attestor is an accountant, lawyer, notary, government official or other reliable third party in the Applicant's jurisdiction customarily relied upon for the fact attested, the Attestation includes a copy of the supporting documentation, and its authenticity is confirmed under Section 3.2.8. A declaration by emSign's own RA personnel is not accepted as authoritative evidence of Individual identity. Where evidence has an explicit validity period, the identity validation is performed within that period, and evidence is reused only within the 825-day limit of Section 4.2.1. The identity document types, eID schemes and mDL issuing jurisdictions accepted by emSign are published at https://repository.emsign.com.
Control of the domain portion of the Mailbox Address / SMTP FQDN	Where mailbox control is established via the domain (Section 3.2.2(a)) or via the mail server (Section 3.2.2(c)), control of the domain portion of the Mailbox Address or of the SMTP FQDN is confirmed using only the TLS Baseline Requirements Section 3.2.2.4 methods listed in Section 3.2.2(e) of this CP/CPS, with Multi-Perspective Issuance Corroboration under Section 4.2.5 where applicable, and is reused for no more than 398 days (Section 4.2.1).
Organization Verification	The full legal name, Jurisdiction of Incorporation or Registration, Registration Reference and (where included in the Subject) address of the Legal Entity are verified under Section 3.2.3 of this CP/CPS using documentation from, or communication with, at least one of: (1) a government agency in the jurisdiction of the Legal Entity's creation, existence or recognition; (2) a Legal Entity Identifier (LEI) data reference whose RegistrationStatus is ISSUED, EntityStatus is ACTIVE and ValidationSources is FULLY_CORROBORATED, verified with the Global Legal Entity Identifier Foundation; (3) a site visit by emSign or a third party acting as emSign's agent; or (4) an Attestation accompanied by supporting documentation of legal existence (such as a certificate of registration or articles of incorporation) and current status, verified under Section 3.2.8. In cases (1) and (4) emSign confirms that the Applicant's status is not designated 'ceased', 'inactive', 'invalid', 'not current' or the equivalent.

	The Registration Reference placed in subject:organizationIdentifier is verified from a register maintained or authorised by the relevant government agency (or with GLEIF for an LEI), and emSign confirms that the organization it identifies is the organization named in subject:organizationName. Assumed Names are verified against the government agency with which they are registered, or by Attestation (S/MIME BR 3.2.3.2.2). The authority of the Applicant Representative is verified under Section 3.2.6 using a Reliable Method of Communication. The authorised verification sources and the jurisdictions they cover are published at https://repository.emsign.com. For Sponsor-validated Certificates the Individual's affiliation with the Organization is evidenced by Enterprise RA records or by an Attestation from the Organization (Section 3.2.4); affiliation evidence does not replace verification of the Organization's identity. Organization identity evidence is reused only within the 825-day limit of Section 4.2.1.
MPIC	emSign applies Multi-Perspective Issuance Corroboration to every CAA record lookup and to every DNS-, HTTP- or ACME-based validation of the domain portion of a Mailbox Address or of an SMTP FQDN, using at least the number of remote Network Perspectives and the quorum required by TLS BR Section 3.2.2.9 in force at the time of validation, as described in Section 4.2.5 of this CP/CPS.

10.4 emSign Organization-Validated Strict SMIME Certificate

Usage/Purpose	E-Mail Protection
Email Verification	Control over each Mailbox Address to be included in the Certificate is confirmed by emSign itself – never by an RA, Enterprise RA or other Delegated Third Party – using only the methods described in Section 3.2.2 of this CP/CPS (S/MIME BR Sections 3.2.2.1 to 3.2.2.4): (a) validating authority over the mailbox via control of the domain portion of the Mailbox Address, using only the TLS BR Section 3.2.2.4 methods listed under 'Control of the domain portion of the Mailbox Address / SMTP FQDN' below or in Section 3.2.2(a); (b) validating control over the mailbox via email using a Random Value; (c) validating the Applicant as operator of the associated mail server(s); or (d) validating control over the mailbox using ACME for S/MIME (RFC 8823). Where the email method (b) is used, emSign sends a Random Value exhibiting at least 112 bits of entropy only to the Mailbox Address being validated; the Random Value is unique in each email, is not shared in any other way, is reset upon each instance of an email sent to that Mailbox Address (all relevant Random Values sent to that Mailbox Address remaining valid within the validity period), and remains valid for use in a confirming response for no more than twenty-four (24) hours from its

	creation. Mailbox control validated under method (b) or method (d) is reused for no more than 30 days, , mailbox control validated under method (d) for no more than 398 days, and control of the domain portion of the Mailbox Address or of the associated SMTP FQDN validated under method (a) or (c) for no more than 398 days (Section 4.2.1). Pre-verified or bank-verified information and mere delivery of an email are not accepted as evidence of mailbox control. For every validation emSign records the Mailbox Address validated, the method used and the version of the S/MIME Baseline Requirements (or TLS Baseline Requirements) under which it was performed.
Organization Verification	The full legal name, Jurisdiction of Incorporation or Registration, Registration Reference and (where included in the Subject) address of the Legal Entity are verified under Section 3.2.3 of this CP/CPS using documentation from, or communication with, at least one of: (1) a government agency in the jurisdiction of the Legal Entity's creation, existence or recognition; (2) a Legal Entity Identifier (LEI) data reference whose RegistrationStatus is ISSUED, EntityStatus is ACTIVE and ValidationSources is FULLY_CORROBORATED, verified with the Global Legal Entity Identifier Foundation; (3) a site visit by emSign or a third party acting as emSign's agent; or (4) an Attestation accompanied by supporting documentation of legal existence (such as a certificate of registration or articles of incorporation) and current status, verified under Section 3.2.8. In cases (1) and (4) emSign confirms that the Applicant's status is not designated 'ceased', 'inactive', 'invalid', 'not current' or the equivalent. The Registration Reference placed in subject:organizationIdentifier is verified from a register maintained or authorised by the relevant government agency (or with GLEIF for an LEI), and emSign confirms that the organization it identifies is the organization named in subject:organizationName. Assumed Names are verified against the government agency with which they are registered, or by Attestation (S/MIME BR 3.2.3.2.2). The authority of the Applicant Representative is verified under Section 3.2.6 using a Reliable Method of Communication. The authorised verification sources and the jurisdictions they cover are published at https://repository.emsign.com. For Sponsor-validated Certificates the Individual's affiliation with the Organization is evidenced by Enterprise RA records or by an Attestation from the Organization (Section 3.2.4); affiliation evidence does not replace verification of the Organization's identity. Organization identity evidence is reused only within the 825-day limit of Section 4.2.1.

10.5 emSign Organization-Validated Multipurpose SMIME Certificate

Usage/Purpose	E-Mail Protection

Email Verification	Control over each Mailbox Address to be included in the Certificate is confirmed by emSign itself – never by an RA, Enterprise RA or other Delegated Third Party – using only the methods described in Section 3.2.2 of this CP/CPS (S/MIME BR Sections 3.2.2.1 to 3.2.2.4): (a) validating authority over the mailbox via control of the domain portion of the Mailbox Address, using only the TLS BR Section 3.2.2.4 methods listed under 'Control of the domain portion of the Mailbox Address / SMTP FQDN' below or in Section 3.2.2(a); (b) validating control over the mailbox via email using a Random Value; (c) validating the Applicant as operator of the associated mail server(s); or (d) validating control over the mailbox using ACME for S/MIME (RFC 8823). Where the email method (b) is used, emSign sends a Random Value exhibiting at least 112 bits of entropy only to the Mailbox Address being validated; the Random Value is unique in each email, is not shared in any other way, is reset upon each instance of an email sent to that Mailbox Address (all relevant Random Values sent to that Mailbox Address remaining valid within the validity period), and remains valid for use in a confirming response for no more than twenty-four (24) hours from its creation. Mailbox control validated under method (b) or method (d) is reused for no more than 30 days, mailbox control validated under method (d) for no more than 398 days, and control of the domain portion of the Mailbox Address or of the associated SMTP FQDN validated under method (a) or (c) for no more than 398 days (Section 4.2.1). Pre-verified or bank-verified information and mere delivery of an email are not accepted as evidence of mailbox control. For every validation emSign records the Mailbox Address validated, the method used and the version of the S/MIME Baseline Requirements (or TLS Baseline Requirements) under which it was performed.
Organization Verification	The full legal name, Jurisdiction of Incorporation or Registration, Registration Reference and (where included in the Subject) address of the Legal Entity are verified under Section 3.2.3 of this CP/CPS using documentation from, or communication with, at least one of: (1) a government agency in the jurisdiction of the Legal Entity's creation, existence or recognition; (2) a Legal Entity Identifier (LEI) data reference whose RegistrationStatus is ISSUED, EntityStatus is ACTIVE and ValidationSources is FULLY_CORROBORATED, verified with the Global Legal Entity Identifier Foundation; (3) a site visit by emSign or a third party acting as emSign's agent; or (4) an Attestation accompanied by supporting documentation of legal existence (such as a certificate of registration or articles of incorporation) and current status, verified under Section 3.2.8. In cases (1) and (4) emSign confirms that the Applicant's status is not designated 'ceased', 'inactive', 'invalid', 'not current' or the equivalent. The Registration Reference placed in subject:organizationIdentifier is verified from a register maintained or authorised by the relevant

	government agency (or with GLEIF for an LEI), and emSign confirms that the organization it identifies is the organization named in subject:organizationName. Assumed Names are verified against the government agency with which they are registered, or by Attestation (S/MIME BR 3.2.3.2.2). The authority of the Applicant Representative is verified under Section 3.2.6 using a Reliable Method of Communication. The authorised verification sources and the jurisdictions they cover are published at https://repository.emsign.com. For Sponsor-validated Certificates the Individual's affiliation with the Organization is evidenced by Enterprise RA records or by an Attestation from the Organization (Section 3.2.4); affiliation evidence does not replace verification of the Organization's identity. Organization identity evidence is reused only within the 825-day limit of Section 4.2.1.

10.6 emSign Sponsor -Validated Multipurpose SMIME Certificate

Usage/Purpose	E-Mail Protection
Email Verification	Control over each Mailbox Address to be included in the Certificate is confirmed by emSign itself – never by an RA, Enterprise RA or other Delegated Third Party – using only the methods described in Section 3.2.2 of this CP/CPS (S/MIME BR Sections 3.2.2.1 to 3.2.2.4): (a) validating authority over the mailbox via control of the domain portion of the Mailbox Address, using only the TLS BR Section 3.2.2.4 methods listed under 'Control of the domain portion of the Mailbox Address / SMTP FQDN' below or in Section 3.2.2(a); (b) validating control over the mailbox via email using a Random Value; (c) validating the Applicant as operator of the associated mail server(s); or (d) validating control over the mailbox using ACME for S/MIME (RFC 8823). Where the email method (b) is used, emSign sends a Random Value exhibiting at least 112 bits of entropy only to the Mailbox Address being validated; the Random Value is unique in each email, is not shared in any other way, is reset upon each instance of an email sent to that Mailbox Address (all relevant Random Values sent to that Mailbox Address remaining valid within the validity period), and remains valid for use in a confirming response for no more than twenty-four (24) hours from its creation. Mailbox control validated under method (b) or method (d) is reused for no more than 30 days, mailbox control validated under method (d) for no more than 398 days, and control of the domain portion of the Mailbox Address or of the associated SMTP FQDN validated under method (a) or (c) for no more than 398 days (Section 4.2.1). Pre-verified or bank-verified information and mere delivery of an email are not accepted as evidence of mailbox control. For every validation emSign records the Mailbox Address validated, the method used and the version of the S/MIME

	Baseline Requirements (or TLS Baseline Requirements) under which it was performed.
Individual Verification	Individual identity is verified under Section 3.2.4 of this CP/CPS using at least one of the authoritative sources permitted by S/MIME BR Section 3.2.4.1: (1) a government-issued passport, identity card or other official identity document of comparable reliability bearing a face photo, presented in its original form either in person or remotely in real time before a camera, with a visual comparison of the Applicant against the photo and recording of the issuer, validity period and unique document number – photocopies or scanned images are not accepted as authoritative evidence; (2) an ICAO 9303 part 10 eMRTD whose issuer signature validates against the relevant country signing certificates, with the issuer, validity period, unique document number, identity attributes and face photo recorded and a visual comparison of the Applicant against the face photo; (3) a notified eIDAS eID scheme at LoA Substantial or High, with the individual eID confirmed as not expired, suspended or revoked; (4) a digital signature created with a personal Certificate issued under an Approved Framework; (5) Enterprise RA records (Sponsor-validated Certificates approved by an Enterprise RA only); (6) an Attestation from the Sponsoring Organization confirming the Individual's affiliation (Sponsor-validated Certificates not approved by an Enterprise RA), verified under Section 3.2.8; (7) an Attestation from a qualified legal practitioner or notary in the Applicant's jurisdiction, verified under Section 3.2.8; or (8) an ISO/IEC 18013-5 Mobile Driver Licence authenticated in real time under Section 3.2.4(9). Supplementary evidence from official documents, government or regulatory registers or national population registers may corroborate a change of name, a Title or an address, but is never the sole authoritative source. An address (but not identity) may additionally be verified using a utility bill, bank statement, credit card statement or government-issued tax document. An Attestation is accepted only where the attestor is an accountant, lawyer, notary, government official or other reliable third party in the Applicant’s jurisdiction customarily relied upon for the fact attested, the Attestation includes a copy of the supporting documentation, and its authenticity is confirmed under Section 3.2.8. A declaration by emSign’s own RA personnel is not accepted as authoritative evidence of Individual identity. Where evidence has an explicit validity period, the identity validation is performed within that period, and evidence is reused only within the 825-day limit of Section 4.2.1. The identity document types, eID schemes and mDL issuing jurisdictions accepted by emSign are published at https://repository.emsign.com.
Control of the domain portion of the Mailbox Address / SMTP FQDN	Where mailbox control is established via the domain (Section 3.2.2(a)) or via the mail server (Section 3.2.2(c)), control of the domain portion of the Mailbox Address or of the SMTP FQDN is confirmed using only the TLS

	Baseline Requirements Section 3.2.2.4 methods listed in Section 3.2.2(e) of this CP/CPS, with Multi-Perspective Issuance Corroboration under Section 4.2.5 where applicable, and is reused for no more than 398 days (Section 4.2.1).
Organization Verification	The full legal name, Jurisdiction of Incorporation or Registration, Registration Reference and (where included in the Subject) address of the Legal Entity are verified under Section 3.2.3 of this CP/CPS using documentation from, or communication with, at least one of: (1) a government agency in the jurisdiction of the Legal Entity's creation, existence or recognition; (2) a Legal Entity Identifier (LEI) data reference whose RegistrationStatus is ISSUED, EntityStatus is ACTIVE and ValidationSources is FULLY_CORROBORATED, verified with the Global Legal Entity Identifier Foundation; (3) a site visit by emSign or a third party acting as emSign's agent; or (4) an Attestation accompanied by supporting documentation of legal existence (such as a certificate of registration or articles of incorporation) and current status, verified under Section 3.2.8. In cases (1) and (4) emSign confirms that the Applicant's status is not designated 'ceased', 'inactive', 'invalid', 'not current' or the equivalent. The Registration Reference placed in subject:organizationIdentifier is verified from a register maintained or authorised by the relevant government agency (or with GLEIF for an LEI), and emSign confirms that the organization it identifies is the organization named in subject:organizationName. Assumed Names are verified against the government agency with which they are registered, or by Attestation (S/MIME BR 3.2.3.2.2). The authority of the Applicant Representative is verified under Section 3.2.6 using a Reliable Method of Communication. The authorised verification sources and the jurisdictions they cover are published at https://repository.emsign.com. For Sponsor-validated Certificates the Individual's affiliation with the Organization is evidenced by Enterprise RA records or by an Attestation from the Organization (Section 3.2.4); affiliation evidence does not replace verification of the Organization's identity. Organization identity evidence is reused only within the 825-day limit of Section 4.2.1.
MPIC	emSign applies Multi-Perspective Issuance Corroboration to every CAA record lookup and to every DNS-, HTTP- or ACME-based validation of the domain portion of a Mailbox Address or of an SMTP FQDN, using at least the number of remote Network Perspectives and the quorum required by TLS BR Section 3.2.2.9 in force at the time of validation, as described in Section 4.2.5 of this CP/CPS.

11 Appendix B: Certificate Profiles

11.1 Root Certificates

Version	V3
Serial Number	Unique Non-Sequential CSPRNG Number and is greater than zero.
Signature Algorithm	SHA-256, SHA-384 or SHA-512 with RSA Encryption or ECDSA with SHA-256, SHA-384 or SHA-512
Issuer: CN	<Issuing CA Common Name>
Issuer: O	<Issuing CA Organization name>
Issuer: OU	<Issuing CA Organization unit>
Issuer: C	<Issuing CA Country>
Valid From	Start date expressed in UTC format
Valid To	End date (notAfter) expressed in UTC format
Public Key	RSA 4096 (OR) RSA 8192 ECC curves NIST P-256, P-384, or P-521
Subject: CommonName	Common Name of Root CA
Subject: OrganizationName	Legal Name of CA Organization
Subject: OrganizationalUnitName	Variable Information
Subject: CountryName	Country of CA
Key Usage	Critical=TRUE Certificate Signing, Off-line CRL Signing, CRL Signing (06)
Subject Key Identifier	Critical=FALSE 160 bit hash (SHA-1)
Basic Constraints	Critical=TRUE Subject Type=CA, Path Length Constraint=None

11.2 Subordinate CA Certificates (Issuer / Intermediate)

Version	V3
Serial Number	Unique Non-Sequential CSPRNG Number and is greater than zero.
Signature Algorithm	SHA-256, SHA-384 or SHA-512 with RSA Encryption or ECDSA with SHA-256, SHA-384 or SHA-512
Issuer: CN	<Issuing CA Common Name>

Issuer: O	<Issuing CA Organization name>
Issuer: OU	<Issuing CA Organization unit>
Issuer: C	<Issuing CA Country>
Valid From	Start date expressed in UTC format
Valid To	End date (notAfter) expressed in UTC format
Public Key	RSA 4096 (OR) RSA 8192 ECC curves NIST P-256, P-384, or P-521
Subject: CommonName	Common Name of CA
Subject: OrganizationName	Legal Name of CA Organization
Subject: OrganizationalUnitName	Variable Information
Subject: CountryName	Country of CA
Key Usage	Critical=TRUE Certificate Signing, Off-line CRL Signing, CRL Signing (06)
Enhanced Key Usage	Critical=FALSE id-kp-emailProtection (1.3.6.1.5.5.7.3.4) – always present for Subordinate CAs that issue S/MIME Certificates; id-kp-clientAuth (1.3.6.1.5.5.7.3.2) MAY be present. anyExtendedKeyUsage, id-kp-serverAuth, id-kp-codeSigning and id-kp-timeStamping are never present (S/MIME BR 7.1.2.2(g)).
Certificate Policies	Critical=FALSE Either the anyPolicy identifier (2.5.29.32.0) – permitted only for a Subordinate CA that is an Affiliate of the Issuing CA, which as at the date of this CP/CPS is the case for every emSign Subordinate CA – or one or more of the reserved CA/Browser Forum policy identifiers of S/MIME BR 7.1.6.1 for which the Subordinate CA is authorised to issue (2.23.140.1.5.1.2, 2.23.140.1.5.1.3, 2.23.140.1.5.2.2, 2.23.140.1.5.2.3, 2.23.140.1.5.3.2, 2.23.140.1.5.3.3, 2.23.140.1.5.4.2, 2.23.140.1.5.4.3), optionally together with the emSign S/MIME CP/CPS identifier 1.3.6.1.4.1.50977.1.0.1.3; policy qualifier id-qt-cps = https://repository.emsign.com.
Subject Key Identifier	Critical=FALSE 160 bit hash (SHA-1)
Authority Key Identifier	Critical=FALSE keyIdentifier field only (matches the Issuing CA's subjectKeyIdentifier); authorityCertIssuer and authorityCertSerialNumber are absent

Basic Constraints	Critical=TRUE Subject Type=CA, Path Length Constraint=n
Authority Information access	Critical=FALSE Access Method=OCSP (1.3.6.1.5.5.7.48.1), URL=http://ocsp.emSign.com Access Method=Certification Authority Issuer (1.3.6.1.5.5.7.48.2), URL=http://repository.emsign.com/certs/<IssuerName>.crt/p7c/cer
CRL Distribution Points	Critical=FALSE CRL HTTP URL = http://crl.emsign.com?<IssuerName>.crl

11.3 emSign Mailbox-Validated Strict SMIME Certificate

Version	V3
Serial Number	Unique Non-Sequential CSPRNG Number and is greater than zero.
Signature Algorithm	SHA-256, SHA-384 or SHA-512 with RSA Encryption or ECDSA with SHA-256, SHA-384 or SHA-512
Issuer: CN	<Issuing CA Common Name>
Issuer: O	<Issuing CA Organization name>
Issuer: OU	<Issuing CA Organization unit>
Issuer: C	<Issuing CA Country>
Valid From	Start date expressed in UTC format
Valid To	End date (notAfter) expressed in UTC format
Public Key	As per Section 6.1.5.
Subject: EmailAddress	Verified Email Address
Authority Key Identifier	Critical=FALSE keyIdentifier field only (matches the Issuing CA's subjectKeyIdentifier); authorityCertIssuer and authorityCertSerialNumber are absent
Subject Key Identifier	Critical=FALSE 160 bit hash (SHA-1)
Enhanced Key Usage	Critical=FALSE Email Protection (1.3.6.1.5.5.7.3.4)
Certificate Policies	Critical=FALSE CA/Browser Forum reserved policy identifier: 2.23.140.1.5.1.3 (Mailbox-validated Strict) emSign policy identifier: 1.3.6.1.4.1.50977.1.2.460.1.3 (Section 1.2)

	emSign S/MIME CP/CPS identifier: 1.3.6.1.4.1.50977.1.0.1.3 with id-qt-cps qualifier = https://repository.emsign.com
CRL Distribution Points	Critical=FALSE CRL HTTP URL = http://crl.emsign.com?<IssuerName>.crl
Authority Information access	Critical=FALSE Access Method=OCSP (1.3.6.1.5.5.7.48.1), URL=http://ocsp.emsign.com Access Method=Certification Authority Issuer (1.3.6.1.5.5.7.48.2), URL=http://repository.emsign.com/certs/<IssuerName>.crt
Subject Alternative Name	Critical=FALSE (critical only if the subject field is empty) rfc822Name and/or otherName of type id-on-SmtpUTF8Mailbox (RFC 9598) for every Mailbox Address in the Certificate; every Mailbox Address appearing in the subject field or in a directoryName entry is repeated here (S/MIME BR 7.1.4.2.1).
Key Usage	Critical=TRUE Populated per S/MIME BR 7.1.2.3(e) according to the intended use of the key: RSA keys – digitalSignature (signing only), keyEncipherment (key management only) or both (dual use), nonRepudiation optional; ECDSA keys – digitalSignature (signing only), keyAgreement (key management only) or both (dual use), nonRepudiation optional, encipherOnly/decipherOnly optional only with keyAgreement. No other bits are set.
Basic Constraints	Critical=TRUE cA=FALSE (End Entity); pathLenConstraint absent

11.4 emSign Individual -Validated Strict SMIME Certificate

Version	V3
Serial Number	Unique Non-Sequential CSPRNG Number and is greater than zero.
Signature Algorithm	SHA-256, SHA-384 or SHA-512 with RSA Encryption or ECDSA with SHA-256, SHA-384 or SHA-512
Issuer: CN	<Issuing CA Common Name>
Issuer: O	<Issuing CA Organization name>
Issuer: OU	<Issuing CA Organization unit>
Issuer: C	<Issuing CA Country>
Valid From	Start date expressed in UTC format
Valid To	End date (notAfter) expressed in UTC format
Public Key	As per Section 6.1.5.

Subject: Common Name	Optional. If present: Personal Name, Pseudonym or Mailbox Address, as verified under Section 3.2.4 / 3.2.2.
Subject: EmailAddress	Verified Email Address (Optional)
Subject: GivenName	First name
Subject: Surname	Last name
Subject: Pseudonym	Optional. Pseudonym verified under Section 3.1.3; mutually exclusive with GivenName/Surname. Sponsor-validated and Individual-validated Certificates SHALL contain either GivenName and/or Surname, or Pseudonym (S/MIME BR 7.1.4.2.5/7.1.4.2.6 Note 2).
Subject: Serial Number	Serial Number (Optional)
Subject: Title	Title (Optional)
Subject: Locality	Verified Locality. Optional; present only where Subject:CountryName is present.
Subject: StateOrProvinceName	Verified State/Province. Optional; present only where Subject:CountryName is present.
Subject: CountryName	Verified Country (Optional). If present, SHALL contain the two-letter ISO 3166-1 country code associated with the location of the Subject verified under Section 3.2.3 for Organization-validated and Sponsor-validated Certificate Types, or under Section 3.2.4 for Individual-validated Certificate Types. Where a country is not represented by an official ISO 3166-1 country code, emSign SHALL specify the ISO 3166-1 user-assigned code XX to indicate that an official ISO 3166-1 alpha-2 code has not been assigned (S/MIME BR 7.1.4.2.2(n)).
Authority Key Identifier	Critical=FALSE keyIdentifier field only (matches the Issuing CA's subjectKeyIdentifier); authorityCertIssuer and authorityCertSerialNumber are absent
Subject Key Identifier	Critical=FALSE
Enhanced Key Usage	Critical=FALSE Email Protection (1.3.6.1.5.5.7.3.4)
Certificate Policies	Critical=FALSE CA/Browser Forum reserved policy identifier: 2.23.140.1.5.4.3 (Individual-validated Strict) emSign policy identifier: 1.3.6.1.4.1.50977.1.2.460.2.3 (Section 1.2) emSign S/MIME CP/CPS identifier: 1.3.6.1.4.1.50977.1.0.1.3 with id-qt-cps qualifier = https://repository.emsign.com
CRL Distribution Points	Critical=FALSE CRL HTTP URL = http://crl.emsign.com?<IssuerName>.crl

Authority Information access	Critical=FALSE Access Method=OCSP (1.3.6.1.5.5.7.48.1), URL=http://ocsp.emsign.com Access Method=Certification Authority Issuer (1.3.6.1.5.5.7.48.2), URL=http://repository.emsign.com/certs/<IssuerName>.crt
Subject Alternative Name	Critical=FALSE (critical only if the subject field is empty) rfc822Name and/or otherName of type id-on-SmtpUTF8Mailbox (RFC 9598) for every Mailbox Address in the Certificate; every Mailbox Address appearing in the subject field or in a directoryName entry is repeated here (S/MIME BR 7.1.4.2.1).
Key Usage	Critical=TRUE Populated per S/MIME BR 7.1.2.3(e) according to the intended use of the key: RSA keys – digitalSignature (signing only), keyEncipherment (key management only) or both (dual use), nonRepudiation optional; ECDSA keys – digitalSignature (signing only), keyAgreement (key management only) or both (dual use), nonRepudiation optional, encipherOnly/decipherOnly optional only with keyAgreement. No other bits are set.
Basic Constraints	Critical=TRUE cA=FALSE (End Entity); pathLenConstraint absent

11.5 emSign Sponsor -Validated Strict SMIME Certificate

Version	V3
Serial Number	Unique Non-Sequential CSPRNG Number and is greater than zero.
Signature Algorithm	SHA-256, SHA-384 or SHA-512 with RSA Encryption or ECDSA with SHA-256, SHA-384 or SHA-512
Issuer: CN	<Issuing CA Common Name>
Issuer: O	<Issuing CA Organization name>
Issuer: OU	<Issuing CA Organization unit>
Issuer: C	<Issuing CA Country>
Valid From	Start date expressed in UTC format
Valid To	End date (notAfter) expressed in UTC format
Public Key	As per Section 6.1.5.
Subject: CommonName	Optional. If present: Personal Name, Pseudonym or Mailbox Address, as verified under Section 3.2.4 / 3.2.2.
Subject: OrganizationName	Verified Organization name

Subject: OrganizationIdentifier	SHALL be present. Verified Registration Reference of the Legal Entity (Section 3.2.3), encoded as PrintableString or UTF8String in the structure of S/MIME BR 7.1.4.2.2(d) and Appendix A: 3-character Registration Scheme identifier (NTR, VAT, PSD, LEI, GOV or INT); 2-character ISO 3166-1 country code of the nation operating the scheme, or 'XG' for the LEI and INT schemes; where the Registration Reference is assigned at subdivision level and is not unique nationally, a plus sign '+' followed by the up-to-3-character ISO 3166-2 subdivision identifier; a hyphen-minus '-'; and the Registration Reference allocated under the scheme. Examples: NTRIN-U72900KA2008PTC046037; NTRUS+CA-12345678; PSDBE-NBB-1234.567.890; VATEL-123456789; LEIXG-<20-character LEI>. Government Entities without a scheme identifier: GOV + country code (+ subdivision where applicable), no Registration Reference, e.g. GOVIN, GOVUS+CA. International Organization Entities: INTXG. For the VAT scheme the EU Council Directive 2006/112/EC Article 215 country prefix MAY replace the ISO code; for the NTR scheme in the EU/EEA the EUID MAY be used (SHOULD for Germany), e.g. NTRDE-DER3306.HRB12345. Except for LEI and INT, the country code matches subject:countryName where present. emSign confirms that the organization represented by the Registration Reference is the organization named in subject:organizationName. The Registration Reference carries no semantics other than those defined by the scheme.
Subject: EmailAddress	Verified Email Address (Optional)
Subject: GivenName	Verified GivenName
Subject: Surname	Verified Surname
Subject: Pseudonym	Optional. Pseudonym verified under Section 3.1.3; mutually exclusive with GivenName/Surname. Sponsor-validated and Individual-validated Certificates SHALL contain either GivenName and/or Surname, or Pseudonym (S/MIME BR 7.1.4.2.5/7.1.4.2.6 Note 2).
Subject: Serial Number	Serial Number (Optional)
Subject: Title	Title (Optional)
Subject: Locality	Verified Locality. Optional; present only where Subject:CountryName is present.
Subject: StateOrProvinceName	Verified State/Province. Optional; present only where Subject:CountryName is present.
Subject: CountryName	Verified Country (Optional). If present, SHALL contain the two-letter ISO 3166-1 country code associated with the location of the Subject

	verified under Section 3.2.3 for Organization-validated and Sponsor-validated Certificate Types, or under Section 3.2.4 for Individual-validated Certificate Types. Where a country is not represented by an official ISO 3166-1 country code, emSign SHALL specify the ISO 3166-1 user-assigned code XX to indicate that an official ISO 3166-1 alpha-2 code has not been assigned (S/MIME BR 7.1.4.2.2(n)).
Authority Key Identifier	Critical=FALSE keyIdentifier field only (matches the Issuing CA's subjectKeyIdentifier); authorityCertIssuer and authorityCertSerialNumber are absent
Subject Key Identifier	Critical=FALSE
Enhanced Key Usage	Critical=FALSE Email Protection (1.3.6.1.5.5.7.3.4)
Certificate Policies	Critical=FALSE CA/Browser Forum reserved policy identifier: 2.23.140.1.5.3.3 (Sponsor-validated Strict) emSign policy identifier: 1.3.6.1.4.1.50977.1.2.460.4.3 (Section 1.2) emSign S/MIME CP/CPS identifier: 1.3.6.1.4.1.50977.1.0.1.3 with id-qt-cps qualifier = https://repository.emsign.com
CRL Distribution Points	Critical=FALSE CRL HTTP URL = http://crl.emsign.com?<IssuerName>.crl
Authority Information access	Critical=FALSE Access Method=OCSP (1.3.6.1.5.5.7.48.1), URL=http://ocsp.emsign.com Access Method=Certification Authority Issuer (1.3.6.1.5.5.7.48.2), URL=http://repository.emsign.com/certs/<IssuerName>.crt
Subject Alternative Name	Critical=FALSE (critical only if the subject field is empty) rfc822Name and/or otherName of type id-on-SmtpUTF8Mailbox (RFC 9598) for every Mailbox Address in the Certificate; every Mailbox Address appearing in the subject field or in a directoryName entry is repeated here (S/MIME BR 7.1.4.2.1).
Key Usage	Critical=TRUE Populated per S/MIME BR 7.1.2.3(e) according to the intended use of the key: RSA keys – digitalSignature (signing only), keyEncipherment (key management only) or both (dual use), nonRepudiation optional; ECDSA keys – digitalSignature (signing only), keyAgreement (key management only) or both (dual use), nonRepudiation optional, encipherOnly/decipherOnly optional only with keyAgreement. No other bits are set.
Basic Constraints	Critical=TRUE

	cA=FALSE (End Entity); pathLenConstraint absent

11.6 emSign Organization-Validated Strict SMIME Certificate

Version	V3
Serial Number	Unique Non-Sequential CSPRNG Number and is greater than zero.
Signature Algorithm	SHA-256, SHA-384 or SHA-512 with RSA Encryption or ECDSA with SHA-256, SHA-384 or SHA-512
Issuer: CN	<Issuing CA Common Name>
Issuer: O	<Issuing CA Organization name>
Issuer: OU	<Issuing CA Organization unit>
Issuer: C	<Issuing CA Country>
Valid From	Start date expressed in UTC format
Valid To	End date (notAfter) expressed in UTC format
Public Key	As per Section 6.1.5.
Subject: CommonName	Optional. If present: the verified subject:organizationName or a Mailbox Address.
Subject: OrganizationName	Verified Organization name
Subject: OrganizationIdentifier	SHALL be present. Verified Registration Reference of the Legal Entity (Section 3.2.3), encoded as PrintableString or UTF8String in the structure of S/MIME BR 7.1.4.2.2(d) and Appendix A: 3-character Registration Scheme identifier (NTR, VAT, PSD, LEI, GOV or INT); 2-character ISO 3166-1 country code of the nation operating the scheme, or 'XG' for the LEI and INT schemes; where the Registration Reference is assigned at subdivision level and is not unique nationally, a plus sign '+' followed by the up-to-3-character ISO 3166-2 subdivision identifier; a hyphen-minus '-'; and the Registration Reference allocated under the scheme. Examples: NTRIN-U72900KA2008PTC046037; NTRUS+CA-12345678; PSDBE-NBB-1234.567.890; VATEL-123456789; LEIXG-<20-character LEI>. Government Entities without a scheme identifier: GOV + country code (+ subdivision where applicable), no Registration Reference, e.g. GOVIN, GOVUS+CA. International Organization Entities: INTXG. For the VAT scheme the EU Council Directive 2006/112/EC Article 215 country prefix MAY replace the ISO code; for the NTR scheme in the EU/EEA the EUID MAY be used (SHOULD for Germany), e.g. NTRDE-DER3306.HRB12345. Except for LEI and INT, the country code matches subject:countryName where present. emSign confirms that the organization represented by the Registration

	Reference is the organization named in subject:organizationName. The Registration Reference carries no semantics other than those defined by the scheme.
Subject: EmailAddress	Verified Email Address (Optional)
Subject: Serial Number	Serial Number (Optional)
Subject: Locality	Verified Locality. Optional; present only where Subject:CountryName is present.
Subject: StateOrProvinceName	Verified State/Province. Optional; present only where Subject:CountryName is present.
Subject: CountryName	Verified Country (Optional). If present, SHALL contain the two-letter ISO 3166-1 country code associated with the location of the Subject verified under Section 3.2.3 for Organization- validated and Sponsor-validated Certificate Types, or under Section 3.2.4 for Individual-validated Certificate Types. Where a country is not represented by an official ISO 3166-1 country code, emSign SHALL specify the ISO 3166-1 user-assigned code XX to indicate that an official ISO 3166-1 alpha-2 code has not been assigned (S/MIME BR 7.1.4.2.2(n)).
Authority Key Identifier	Critical=FALSE keyIdentifier field only (matches the Issuing CA's subjectKeyIdentifier); authorityCertIssuer and authorityCertSerialNumber are absent
Subject Key Identifier	Critical=FALSE
Enhanced Key Usage	Critical=FALSE Email Protection (1.3.6.1.5.5.7.3.4)
Certificate Policies	Critical=FALSE CA/Browser Forum reserved policy identifier: 2.23.140.1.5.2.3 (Organization-validated Strict) emSign policy identifier: 1.3.6.1.4.1.50977.1.2.460.3.3 (Section 1.2) emSign S/MIME CP/CPS identifier: 1.3.6.1.4.1.50977.1.0.1.3 with id-qt-cps qualifier = https://repository.emsign.com
CRL Distribution Points	Critical=FALSE CRL HTTP URL = http://crl.emsign.com?<IssuerName>.crl
Authority Information access	Critical=FALSE Access Method=OCSP (1.3.6.1.5.5.7.48.1), URL=http://ocsp.emsign.com Access Method=Certification Authority Issuer (1.3.6.1.5.5.7.48.2), URL=http://repository.emsign.com/certs/<IssuerName>.crt
Subject Alternative Name	Critical=FALSE (critical only if the subject field is empty)

	rfc822Name and/or otherName of type id-on-SmtpUTF8Mailbox (RFC 9598) for every Mailbox Address in the Certificate; every Mailbox Address appearing in the subject field or in a directoryName entry is repeated here (S/MIME BR 7.1.4.2.1).
Key Usage	Critical=TRUE Populated per S/MIME BR 7.1.2.3(e) according to the intended use of the key: RSA keys – digitalSignature (signing only), keyEncipherment (key management only) or both (dual use), nonRepudiation optional; ECDSA keys – digitalSignature (signing only), keyAgreement (key management only) or both (dual use), nonRepudiation optional, encipherOnly/decipherOnly optional only with keyAgreement. No other bits are set.
Basic Constraints	Critical=TRUE cA=FALSE (End Entity); pathLenConstraint absent

11.7 emSign Organization-Validated Multipurpose SMIME Certificate

Version	V3
Serial Number	Unique Non-Sequential CSPRNG Number and is greater than zero.
Signature Algorithm	SHA-256, SHA-384 or SHA-512 with RSA Encryption or ECDSA with SHA-256, SHA-384 or SHA-512
Issuer: CN	<Issuing CA Common Name>
Issuer: O	<Issuing CA Organization name>
Issuer: OU	<Issuing CA Organization unit>
Issuer: C	<Issuing CA Country>
Valid From	Start date expressed in UTC format
Valid To	End date (notAfter) expressed in UTC format
Public Key	As per Section 6.1.5.
Subject: CommonName	Optional. If present: the verified subject:organizationName or a Mailbox Address.
Subject: OrganizationName	Verified Organization name
Subject: OrganizationIdentifier	SHALL be present. Verified Registration Reference of the Legal Entity (Section 3.2.3), encoded as PrintableString or UTF8String in the structure of S/MIME BR 7.1.4.2.2(d) and Appendix A: 3-character Registration Scheme identifier (NTR, VAT, PSD, LEI, GOV or INT); 2-character ISO 3166-1 country code of the nation operating the scheme, or 'XG' for the LEI and INT schemes; where the Registration Reference is assigned at subdivision level and is not unique

	nationally, a plus sign '+' followed by the up-to-3-character ISO 3166-2 subdivision identifier; a hyphen-minus '-'; and the Registration Reference allocated under the scheme. Examples: NTRIN-U72900KA2008PTC046037; NTRUS+CA-12345678; PSDBE-NBB-1234.567.890; VATEL-123456789; LEIXG-<20-character LEI>. Government Entities without a scheme identifier: GOV + country code (+ subdivision where applicable), no Registration Reference, e.g. GOVIN, GOVUS+CA. International Organization Entities: INTXG. For the VAT scheme the EU Council Directive 2006/112/EC Article 215 country prefix MAY replace the ISO code; for the NTR scheme in the EU/EEA the EUID MAY be used (SHOULD for Germany), e.g. NTRDE-DER3306.HRB12345. Except for LEI and INT, the country code matches subject:countryName where present. emSign confirms that the organization represented by the Registration Reference is the organization named in subject:organizationName. The Registration Reference carries no semantics other than those defined by the scheme.
Subject: EmailAddress	Verified Email Address (Optional)
Subject: Serial Number	Serial Number (Optional)
Subject: Locality	Verified Locality. Optional; present only where Subject:CountryName is present.
Subject: StateOrProvinceName	Verified State/Province. Optional; present only where Subject:CountryName is present.
Subject: CountryName	Verified Country (Optional). If present, SHALL contain the two-letter ISO 3166-1 country code associated with the location of the Subject verified under Section 3.2.3 for Organization-validated and Sponsor-validated Certificate Types, or under Section 3.2.4 for Individual-validated Certificate Types. Where a country is not represented by an official ISO 3166-1 country code, emSign SHALL specify the ISO 3166-1 user-assigned code XX to indicate that an official ISO 3166-1 alpha-2 code has not been assigned (S/MIME BR 7.1.4.2.2(n)).
Authority Key Identifier	Critical=FALSE keyIdentifier field only (matches the Issuing CA's subjectKeyIdentifier); authorityCertIssuer and authorityCertSerialNumber are absent
Subject Key Identifier	Critical=FALSE
Enhanced Key Usage	Critical=FALSE Email Protection (1.3.6.1.5.5.7.3.4) Client Authentication (1.3.6.1.5.5.7.3.2)

Certificate Policies	Critical=FALSE CA/Browser Forum reserved policy identifier: 2.23.140.1.5.2.2 (Organization-validated Multipurpose) emSign policy identifier: 1.3.6.1.4.1.50977.1.2.460.3.2 (Section 1.2) emSign S/MIME CP/CPS identifier: 1.3.6.1.4.1.50977.1.0.1.3 with id-qt-cps qualifier = https://repository.emsign.com
CRL Distribution Points	Critical=FALSE CRL HTTP URL = http://crl.emsign.com?<IssuerName>.crl
Authority Information access	Critical=FALSE Access Method=OCSP (1.3.6.1.5.5.7.48.1), URL=http://ocsp.emsign.com Access Method=Certification Authority Issuer (1.3.6.1.5.5.7.48.2), URL=http://repository.emsign.com/certs/<IssuerName>.crt
Subject Alternative Name	Critical=FALSE (critical only if the subject field is empty) rfc822Name and/or otherName of type id-on-SmtpUTF8Mailbox (RFC 9598) for every Mailbox Address in the Certificate; every Mailbox Address appearing in the subject field or in a directoryName entry is repeated here (S/MIME BR 7.1.4.2.1).
Key Usage	Critical=TRUE Populated per S/MIME BR 7.1.2.3(e) according to the intended use of the key: RSA keys – digitalSignature (signing only), keyEncipherment (key management only) or both (dual use), nonRepudiation optional, dataEncipherment optional for key management only and dual use; ECDSA keys – digitalSignature (signing only), keyAgreement (key management only) or both (dual use), nonRepudiation optional, encipherOnly/decipherOnly optional only with keyAgreement. No other bits are set.
Basic Constraints	Critical=TRUE cA=FALSE (End Entity); pathLenConstraint absent

11.8 emSign Sponsor -Validated Multipurpose SMIME Certificate

Version	V3
Serial Number	Unique Non-Sequential CSPRNG Number and is greater than zero.
Signature Algorithm	SHA-256, SHA-384 or SHA-512 with RSA Encryption or ECDSA with SHA-256, SHA-384 or SHA-512
Issuer: CN	<Issuing CA Common Name>
Issuer: O	<Issuing CA Organization name>
Issuer: OU	<Issuing CA Organization unit>

Issuer: C	<Issuing CA Country>
Valid From	Start date expressed in UTC format
Valid To	End date (notAfter) expressed in UTC format
Public Key	As per Section 6.1.5.
Subject: CommonName	Optional. If present: Personal Name, Pseudonym or Mailbox Address, as verified under Section 3.2.4 / 3.2.2.
Subject: OrganizationName	Verified Organization name
Subject: OrganizationIdentifier	SHALL be present. Verified Registration Reference of the Legal Entity (Section 3.2.3), encoded as PrintableString or UTF8String in the structure of S/MIME BR 7.1.4.2.2(d) and Appendix A: 3-character Registration Scheme identifier (NTR, VAT, PSD, LEI, GOV or INT); 2-character ISO 3166-1 country code of the nation operating the scheme, or 'XG' for the LEI and INT schemes; where the Registration Reference is assigned at subdivision level and is not unique nationally, a plus sign '+' followed by the up-to-3-character ISO 3166-2 subdivision identifier; a hyphen-minus '-'; and the Registration Reference allocated under the scheme. Examples: NTRIN-U72900KA2008PTC046037; NTRUS+CA-12345678; PSDBE-NBB-1234.567.890; VATEL-123456789; LEIXG-<20-character LEI>. Government Entities without a scheme identifier: GOV + country code (+ subdivision where applicable), no Registration Reference, e.g. GOVIN, GOVUS+CA. International Organization Entities: INTXG. For the VAT scheme the EU Council Directive 2006/112/EC Article 215 country prefix MAY replace the ISO code; for the NTR scheme in the EU/EEA the EUID MAY be used (SHOULD for Germany), e.g. NTRDE-DER3306.HRB12345. Except for LEI and INT, the country code matches subject:countryName where present. emSign confirms that the organization represented by the Registration Reference is the organization named in subject:organizationName. The Registration Reference carries no semantics other than those defined by the scheme.
Subject: EmailAddress	Verified Email Address (Optional)
Subject: GivenName	Verified GivenName
Subject: Surname	Verified Surname
Subject: Pseudonym	Optional. Pseudonym verified under Section 3.1.3; mutually exclusive with GivenName/Surname. Sponsor-validated and Individual-validated Certificates SHALL contain either GivenName and/or Surname, or Pseudonym (S/MIME BR 7.1.4.2.5/7.1.4.2.6 Note 2).
Subject: Serial Number	Serial Number (Optional)

Subject: Title	Title (Optional)
Subject: Locality	Verified Locality. Optional; present only where Subject:CountryName is present.
Subject: StateOrProvinceName	Verified State/Province. Optional; present only where Subject:CountryName is present.
Subject: CountryName	Verified Country (Optional). If present, SHALL contain the two-letter ISO 3166-1 country code associated with the location of the Subject verified under Section 3.2.3 for Organization-validated and Sponsor-validated Certificate Types, or under Section 3.2.4 for Individual-validated Certificate Types. Where a country is not represented by an official ISO 3166-1 country code, emSign SHALL specify the ISO 3166-1 user-assigned code XX to indicate that an official ISO 3166-1 alpha-2 code has not been assigned (S/MIME BR 7.1.4.2.2(n)).
Authority Key Identifier	Critical=FALSE keyIdentifier field only (matches the Issuing CA's subjectKeyIdentifier); authorityCertIssuer and authorityCertSerialNumber are absent
Subject Key Identifier	Critical=FALSE
Enhanced Key Usage	Critical=FALSE Email Protection (1.3.6.1.5.5.7.3.4)
Certificate Policies	Critical=FALSE CA/Browser Forum reserved policy identifier: 2.23.140.1.5.3.2 (Sponsor-validated Multipurpose) emSign policy identifier: 1.3.6.1.4.1.50977.1.2.460.4.2 (Section 1.2) emSign S/MIME CP/CPS identifier: 1.3.6.1.4.1.50977.1.0.1.3 with id-qt-cps qualifier = https://repository.emsign.com
CRL Distribution Points	Critical=FALSE CRL HTTP URL = http://crl.emsign.com?<IssuerName>.crl
Authority Information access	Critical=FALSE Access Method=OCSP (1.3.6.1.5.5.7.48.1), URL=http://ocsp.emsign.com Access Method=Certification Authority Issuer (1.3.6.1.5.5.7.48.2), URL=http://repository.emsign.com/certs/<IssuerName>.crt
Subject Alternative Name	Critical=FALSE (critical only if the subject field is empty) rfc822Name and/or otherName of type id-on-SmtpUTF8Mailbox (RFC 9598) for every Mailbox Address in the Certificate; every Mailbox Address appearing in the subject field or in a directoryName entry is repeated here (S/MIME BR 7.1.4.2.1).
Key Usage	Critical=TRUE

	Populated per S/MIME BR 7.1.2.3(e) according to the intended use of the key: RSA keys – digitalSignature (signing only), keyEncipherment (key management only) or both (dual use), nonRepudiation optional, dataEncipherment optional for key management only and dual use; ECDSA keys – digitalSignature (signing only), keyAgreement (key management only) or both (dual use), nonRepudiation optional, encipherOnly/decipherOnly optional only with keyAgreement. No other bits are set.
Basic Constraints	Critical=TRUE cA=FALSE (End Entity); pathLenConstraint absent

12 Appendix C: Change History

This section contains the summary of changes made to the CP-CPS. Please check the archived document versions for detailed comparative differences.

Version 1.00: 05-Sept-2026

- Base Version

Version 1.01: 17-Oct-2026

- Section 1: Multipurpose Generation scope and reserved identifiers, Issuing CA operation, delegation of CAA and MPIC, and definitions (Subject, Subject Identity Information, Mailbox Address, CAA) aligned with the S/MIME BR; unused TLS-only definitions removed (SMIME-01, 05, 06, 07, 08, 32).
- Section 2: CP/CPS disclosure commitments, repository availability and 365-day review with dated changelog entry (SMIME-02, 03, 04).
- Sections 3 and 4: eMRTD and eID validation, test certificates, re-key validity, ACME validation reuse, CAA processing, renewal, revocation triggers and timelines, CRL and OCSP publication, key compromise notification, suspension and key escrow recovery (SMIME-09 to 23, 26, 32).
- Sections 5, 6, 7 and 9: trusted roles, cryptographic module standard, algorithms and key usage, SHA-1 sunset statement, subject name dependencies and CA/Browser Forum notification address (SMIME-24, 25, 27, 28, 29, 31).
- Appendices A and B updated consistently with the above (SMIME-09, 10, 12, 25, 30, 31).